RÉPUBLIQUE DU CAMEROUN

Chaire UNESCO d'Afrique Centrale Accès TIC

Sous la tutelle académique de l'École Nationale Supérieure Polytechnique de l'Université de Yaoundé I

Master Professionnel en Sécurité des Systèmes Numériques

Audit de Protection des Données et Conformité

Prouver la conformité, protéger les personnes : auditer l'application de la loi n° 2024/017

APDC - UE MSN-2S4-SEC02



Chaque exigence : oui / non / nek, la constatation séparée de l'analyse

MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

Chaire UNESCO d'Afrique Centrale Accès TIC

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE MSN-2S4-SEC02

AVANT-PROPOS

Le 23 juin 2026, le délai de dix-huit mois que la loi n° 2024/017 accordait aux organisations camerounaises pour se mettre en conformité a expiré. Le lendemain, une microfinance de Bafoussam reçoit la lettre d'un client dont le dossier a fuité quinze mois plus tôt. Il demande ce que l'établissement sait de lui, à qui il l'a transmis, et pourquoi personne ne l'a prévenu. Le directeur général pose alors à ses équipes la question qui ouvre ce cours : sommes-nous en règle ?

Répondre exige un audit. Un audit de protection des données ne se contente pas de lire des procédures : il recense les traitements réels, les compare à ce que la loi permet, vérifie que les personnes peuvent exercer leurs droits, que les données sont protégées, que les sous-traitants et les transferts sont encadrés, puis il conclut. Ce cours enseigne cette démarche, dans le cadre de la loi camerounaise, avec les normes internationales qui l'outillent.

Il s'adresse aux étudiants du Master Professionnel en Sécurité des Systèmes Numériques de la Chaire UNESCO d'Afrique centrale, et aux praticiens qui exercent ou exerceront comme auditeurs de la protection des données, délégués à la protection des données, juristes conformité, RSSI ou responsables de traitement. Il suppose acquis le droit du numérique (UE MSN-2S3-JUR01) et la méthode générale de l'audit de cybersécurité (UE MSN-2S3-SEC08). Il laisse au cours de forensique (UE MSN-2S3-SEC07) l'enquête sur l'incident lui-même.

Trois partis pris le traversent. Le premier est de lire la loi dans son texte officiel, article par article, sans lui prêter ce qu'elle ne dit pas : elle ne crée pas de délégué à la protection des données, elle ne fixe pas de délai chiffré de notification, et de nombreuses dispositions attendent leurs textes d'application. Le deuxième est de séparer, à chaque constat, le fait établi de son interprétation, avec un niveau de confiance. Le troisième est de coter ce que l'on ignore : l'instrument OUI / NON / NEK du programme de recherche de l'auditologie sert ici à dire, pour chaque exigence, si la conformité est établie, si l'écart est établi, ou si les preuves manquent pour trancher. Une loi dont certains décrets ne sont pas publiés produit des NEK que l'auditeur doit assumer.

Avant la méthode, deux parties situent cette loi. La première présente le contexte international : les sources dont elle hérite, le règlement européen qui atteint les organisations camerounaises tournées vers l'Europe, le cadre du NIST et les normes ISO. La seconde présente le contexte national : la loi de 2024 elle-même, la loi n° 2010/012 sur la cybersécurité et les textes connexes. Le lecteur y apprend à choisir ses critères avant d'auditer.

Les trois organisations qui accompagnent le lecteur, NYANGA CRÉDIT, le CENTRE MÉDICAL MBOLO et NOUN PAY, sont fictives, comme leurs dirigeants, leurs presta-

© *MaletYon*

taires, les dates, les adresses et les montants. Les mécanismes, les normes et les textes cités sont exacts. Les articles de loi sont cités dans leur texte officiel ; les normes sous licence sont paraphrasées.

Le livre est accompagné d'un livret des corrigés et de NDAP SUKULU, où les fiches de questions et les dix laboratoires du cours permettent de pratiquer chaque chapitre.



Yaoundé, novembre 2026

MODE D'EMPLOI DU COURS

Structure générale

Le cours compte un prologue et sept parties, soit dix-neuf chapitres, pour 30 heures de cours magistral réparties en quinze séances de deux heures. Les travaux dirigés et les travaux pratiques se font à la maison, hors de ces 30 heures : pour les travaux dirigés, la fiche de questions de chaque chapitre et ses exercices de fin de chapitre (environ dix heures au total) ; pour les travaux pratiques, les dix laboratoires de NDAP SUKULU, d'une heure chacun. Les corrigés des exercices sont réunis dans un livret séparé.

Partie	Thème	Chap.	Niveau
0	Prologue : le 24 juin 2026	P	introductif
I	Fondements : la donnée, la personne, le traitement	1–2	fondamental
II	Le contexte international	3–5	fondamental
III	Le contexte national	6–7	fondamental
IV	Méthode : auditer la protection des données	8–12	fondamental à intermédiaire
V	Pratique : de l'écart à la conformité	13–16	intermédiaire
VI	Défis avancés	17–18	intermédiaire à expert
VII	Recherche : mesurer la conformité, articuler les normes	19	recherche

Les quinze séances

© *MaletYon*

Séance	Contenu	Travail à la maison
1	Prologue et Chap. 1 : données, traitements, acteurs	Fiches P et 1
2	Chap. 2 : les principes du traitement	Fiche 2, lab 01
3	Chap. 3 et 4 : sources internationales et africaines, RGPD	Fiches 3 et 4
4	Chap. 5 : NIST et normes ISO	Fiche 5
5	Chap. 6 et 7 : loi n° 2024/017, loi n° 2010/012, choix des critères	Fiches 6 et 7
6	Chap. 8 : conduire un audit de protection des données	Fiche 8
7	Chap. 9 : cartographier les traitements	Fiche 9, lab 02
8	Chap. 10 : évaluer le risque pour les personnes	Fiche 10, lab 03
9	Chap. 11 : auditer les droits des personnes	Fiche 11, lab 04
10	Chap. 12 : auditer la sécurité des données	Fiche 12, lab 05
11	Chap. 13 et 14 : sous-traitants, transferts internationaux	Fiches 13 et 14, labs 06 et 07
12	Chap. 15 : violations de données	Fiche 15, lab 08
13	Chap. 16 : programme de conformité et rapport	Fiche 16, lab 09
14	Chap. 17 : profilage, décisions automatisées, IA	Fiche 17, lab 10
15	Chap. 18 et 19 : secteurs sensibles, mesurer et articuler	Fiches 18 et 19

Cette répartition est indicative ; l'enseignant l'adapte au calendrier et au rythme du groupe.

Le gabarit des chapitres

Chaque chapitre suit le même plan : une épigraphe, le niveau et les prérequis, les objectifs, une situation d'ouverture tirée de l'un des trois cas, des sections numérotées, ce qu'il faut retenir, des points de contrôle, trois à quatre exercices gradués, des lectures, et une transition.

Les encadrés

Encadré	Rôle
Objectifs	Ce que l'on doit savoir faire à la fin du chapitre
Définition	Les notions, en gras dans le texte et indexées
Violation typique	Une erreur fréquente, et la règle qui l'évite
Information	Un complément, un renvoi, une nuance
Mission (NYANGA, MBOLO, NOUN PAY)	Le cas : les constatations, puis l'analyse, avec un niveau de confiance
Traitement	La fiche d'un traitement audité : finalité, base légale, données, destinataires, durée, ce que l'audit en a établi
Démarche d'audit	Les étapes d'une procédure d'audit, dans l'ordre
Lecture	Un décompte de cotes OUI / NON / NEK et sa lecture
Métier	Ce que la notion change pour chacun des métiers du cours
Texte juridique	Un article cité dans son texte officiel, et sa portée
Ce qu'il faut retenir	Les faits et les règles du chapitre
Exercice	Trois niveaux de difficulté : ★☆☆, ★★☆, ★★★

Les conventions

- Les cotes : OUI (conformité établie par une preuve), NON (écart établi par une preuve), NEK (connaissance insuffisante pour trancher). Chaque exigence auditée reçoit l'une de ces trois cotes.
- Constatation et analyse sont toujours séparées ; l'analyse porte un niveau de confiance (faible, moyenne, élevée).
- « La loi » désigne la loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel au Cameroun ; ses articles sont cités sans autre précision.
- Les textes : seuls les articles lus dans leur version officielle sont cités entre guillemets ; les normes sous licence sont paraphrasées ; le degré de vérification figure à l'annexe D.
- Les cas sont fictifs : noms en majuscules, montants en francs CFA, villes réelles. Les données personnelles des exemples sont inventées.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, *ndap sukulu* désigne la salle de classe et *malet yon* signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions et des pièces à examiner. Il est édité par MaletYon et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- Une fiche de questions par chapitre. Chaque tentative tire vingt questions d'une banque de cent (QCM, vrai ou faux, textes à trous) et dure trente minutes.
- Dix laboratoires. Chaque lab place l'étudiant devant les pièces d'une mission d'audit du cours (registres, exports, journaux d'accès, contrats, tableaux de flux) et se termine par des points de contrôle.
- Un espace enseignant, qui corrige les remises, établit la synthèse de la classe et publie les résultats.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

© *MaletYon*

Comment y accéder

1. En ligne, à l'adresse `https://maletyon.github.io/cours-apdc/ndap-sukulu/`, dans un navigateur récent ; sur téléphone, ajouter `telephone/` à la fin de l'adresse.
2. Hors ligne, en téléchargeant l'archive de l'édition ordinateur depuis le dépôt `MaletYon/cours-apdc`, dossier `ndap-sukulu`.
3. Se connecter avec le matricule et le mot de passe remis par l'enseignant. Pour essayer avant d'être inscrit, un compte de démonstration est ouvert à tous : matricule `ETU001`, mot de passe `eTU001` ; ses essais ne sont jamais transmis à l'enseignant.
4. Pour un lab, vérifier d'abord l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.tx`) puis travailler sur une copie. Les données personnelles des pièces sont inventées.

Note

Les fiches de questions sont aussi fournies au format texte dans le dossier `fiches` du dépôt du cours, prêtes à être distribuées. Leurs corrections figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code MSN-2S4-SEC02. Chacun place l'étudiant dans l'une des trois missions d'audit du cours, devant les pièces que l'auditeur réunit : exports, registres, journaux, contrats.

Lab	Sujet	Chapitre	Mission
APDC-LAB-01	Qualifier les données d'un export	1, 2	NYANGA
APDC-LAB-02	Registre déclaré, fichiers découverts	9	NYANGA
APDC-LAB-03	Évaluation d'impact de la téléconsultation	10	MBOLO
APDC-LAB-04	Demandes des personnes et délais	11	NYANGA
APDC-LAB-05	Journaux d'accès au dossier patient	12	MBOLO
APDC-LAB-06	Contrats de sous-traitance	13	NYANGA, MBOLO
APDC-LAB-07	Flux de données vers l'étranger	14	NOUN PAY
APDC-LAB-08	Violation de données et notification	15	NYANGA
APDC-LAB-09	Durées de conservation	16	NYANGA
APDC-LAB-10	Audit intégrateur du profilage	17, 19	NOUN PAY

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi du cours v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 Le 24 Juin 2026 3

0.1 Ce que l'on sait le 24 juin . . . 4
0.2 L'échéance du 23 juin . . . 5
0.3 Trois questions pour un audit . . . 5
0.4 Répondre à M. TAGNE . . . 6
0.5 Premières cotes . . . 7
0.6 Deux autres organisations . . . 8
0.7 Les métiers de l'affaire . . . 8
0.8 Cinq réflexes . . . 9

I Fondements : la Donnée, la Personne, le Traitement 13

1 Données, Traitements, Acteurs 15

1.1 La Donnée à Caractère Personnel . . . 16
1.1.1 Identifier directement ou indirectement . . . 16
1.1.2 Anonymiser n'est pas pseudonymiser . . . 16
1.2 Les Données Sensibles . . . 17
1.3 Le Traitement et le Fichier . . . 18
1.4 Les Acteurs du Traitement . . . 19
1.5 Le Champ d'Application . . . 20
1.6 L'Inventaire de NYANGA . . . 21
1.7 Ce que la Notion demande à chaque Métier . . . 22

2 Les Principes du Traitement 25

2.1 Six Principes, Six Questions d'Audit . . . 26
2.2 Le Consentement . . . 27
2.2.1 Les cinq qualités d'un consentement . . . 27

© *MaletYon*

2.2.2 Les trois dérogations, comparées au droit européen . . . 28
2.3 Finalité, Exactitude, Conservation . . . 28
2.4 L'Information des Personnes . . . 29
2.5 Les Principes à NYANGA . . . 30
2.6 Ce que les Principes demandent à chaque Métier . . . 31

II Le Contexte International 35

3 Les Sources Internationales et Africaines 37

3.1 La Filiation des Principes . . . 38
3.1.1 Les lignes directrices de l'OCDE . . . 38
3.1.2 Les principes directeurs des Nations Unies . . . 39
3.1.3 La Convention 108 et sa version modernisée . . . 39
3.2 Le Droit à la Vie Privée . . . 40
3.3 Le Cadre Africain . . . 40
3.3.1 La Convention de Malabo . . . 40
3.3.2 Le cadre stratégique de l'Union africaine . . . 41
3.3.3 Les textes régionaux . . . 41
3.4 Le Droit des Pays où Vont les Données . . . 42
3.5 La Coopération Pénale . . . 43
3.6 Le Statut de Chaque Instrument . . . 43
3.7 La Carte des Trois Missions . . . 44
3.8 Ce que les Sources demandent à chaque Métier . . . 45

4 Le RGPD et son Effet hors d'Europe 49

4.1 Le RGPD en Quinze Articles . . . 50
4.2 Quand le RGPD Oblige une Organisation Camerounaise . . . 51
4.3 Trois Voies d'Exposition . . . 53
4.3.1 La voie contractuelle . . . 53
4.3.2 La voie en cascade . . . 53
4.4 La Loi et le RGPD, Point par Point . . . 54
4.5 Emprunter sans Confondre . . . 55
4.6 La Double Conformité . . . 55
4.7 Ce que le RGPD demande à chaque Métier . . . 57

5 Le NIST Privacy Framework et les Normes ISO 61

5.1 Trois Natures de Référentiel . . . 62
5.2 Le Privacy Framework du NIST . . . 62
5.2.1 Le noyau . . . 63
5.2.2 Les profils . . . 63
5.2.3 Les niveaux de mise en œuvre . . . 64

5.2.4 Les autres publications utiles . . . 64
5.2.5 Ce que le cadre n'apporte pas . . . 64
5.3 La Famille des Normes . . . 65
5.3.1 Les onze principes de l'ISO/IEC 29100 . . . 65
5.3.2 L'ISO/IEC 27701 . . . 65
5.4 Deux Certifications . . . 66
5.5 Correspondances entre les Référentiels . . . 66
5.6 Le Diagnostic de NOUN PAY . . . 67
5.7 Ce que les Référentiels demandent à chaque Métier . . . 69

III Le Contexte National 71

6 La Loi n° 2024/017 : Autorisation, Autorité, Sanctions 73

6.1 Ce que la Loi a Internalisé . . . 74
6.2 L'Architecture de la Loi . . . 75
6.3 Ce qui Attend un Texte d'Application . . . 76
6.4 Le Régime d'Autorisation Préalable . . . 76
6.5 L'Autorité de Protection . . . 77
6.6 Contrôle et Certification . . . 78
6.7 Les Sanctions . . . 78
6.7.1 Sanctions administratives . . . 78
6.7.2 Sanctions civiles et pénales . . . 79
6.8 Dispositions Transitoires et Abrogation . . . 80
6.9 Ce que la Loi demande à chaque Métier . . . 81

7 La Loi n° 2010/012 et les Textes Connexes 83

7.1 Une Loi de Sécurité qui Parle de Données . . . 84
7.2 La Sécurité Obligatoire . . . 84
7.3 La Conservation Décennale . . . 85
7.4 La Vie Privée dans les Communications . . . 86
7.5 Interception, Réquisitions et Entraide . . . 88
7.6 Deux Lois, des Délits Voisins . . . 88
7.7 Les Textes Connexes . . . 89
7.8 Choisir ses Critères . . . 91
7.9 La Loi de 2010 à NYANGA . . . 92
7.10 Ce que les Textes demandent à chaque Métier . . . 93

IV Méthode : Auditer la Protection des Données 97

8 Conduire un Audit de Protection des Données 99

8.1 Trois Sortes d'Audit . . . 100
8.2 Les Principes de l'Auditeur . . . 100
8.3 La Déontologie de l'Auditeur . . . 101
8.3.1 Minimiser les données de l'audit . . . 101
8.3.2 L'indépendance . . . 101
8.3.3 Ce que l'auditeur découvre . . . 101
8.4 Mandat, Critères, Périmètre . . . 102
8.5 Les Preuves et leur Force . . . 102
8.6 Décomposer et Coter . . . 103
8.7 Lire les Mesures, Conclure . . . 104
8.8 Le Plan d'Audit de NYANGA . . . 104
8.9 Ce que la Méthode demande à chaque Métier . . . 105

9 Cartographier les Traitements 109

9.1 Le Registre de l'Article 29 . . . 110
9.2 Recenser par les Processus . . . 111
9.3 La Découverte des Données . . . 112
9.4 Cartographier les Flux . . . 112
9.5 Le Registre de NYANGA . . . 113
9.6 Ce que la Cartographie demande à chaque Métier . . . 114

10 Évaluer le Risque pour les Personnes 117

10.1 Deux Obligations . . . 118
10.2 Repérer le Risque Élevé . . . 118
10.3 Les Étapes d'une Évaluation d'Impact . . . 120
10.3.1 Trois événements redoutés . . . 120
10.3.2 Gravité et vraisemblance . . . 120
10.4 La Téléconsultation de MBOLO . . . 121
10.5 Auditer une Évaluation d'Impact . . . 122
10.6 Ce que le Risque demande à chaque Métier . . . 123

11 Auditer les Droits des Personnes 125

11.1 Les Droits de la Personne Concernée . . . 126
11.2 Le Délai, un Critère à Déclarer . . . 127
11.3 Auditer le Traitement des Demandes . . . 128
11.4 Les Demandes de NYANGA . . . 128
11.5 Ce que les Droits demandent à chaque Métier . . . 130

12 Auditer la Sécurité des Données 133

12.1 Les Obligations de Sécurité . . . 134

12.2 Dix Obligations, Dix Contrôles . . . 135
12.2.1 Les droits d'accès . . . 135
12.2.2 Les journaux de consultation . . . 136
12.3 Le Dossier de la Patiente . . . 136
12.4 La Sécurité à NYANGA, après l'Incident . . . 138
12.5 Ce que la Sécurité demande à chaque Métier . . . 139

V Pratique : de l'Écart à la Conformité 143

13 Sous-traitants et Responsables Conjoints 145

13.1 Les Obligations de la Loi . . . 146
13.2 Le Contrat de Sous-traitance . . . 146
13.3 Vérifier l'Exécution . . . 148
13.4 Les Responsables Conjoints . . . 148
13.5 Les Contrats de NYANGA et de MBOLO . . . 149
13.6 Ce que la Sous-traitance demande à chaque Métier . . . 150

14 Les Transferts Internationaux 153

14.1 Qu'est-ce qu'un Transfert . . . 154
14.2 L'Article 32 . . . 154
14.2.1 Coter sans liste ni clauses . . . 155
14.3 Cartographier les Flux Sortants . . . 155
14.4 Les Flux de NOUN PAY . . . 156
14.4.1 Les données qui reviennent de l'Union européenne . . . 157
14.5 Transferts et Coopération Pénale . . . 158
14.6 Ce que les Transferts demandent à chaque Métier . . . 158

15 Les Violations de Données 161

15.1 Qu'est-ce qu'une Violation . . . 162
15.2 L'Obligation d'Informer . . . 163
15.3 Gérer une Violation . . . 164
15.4 Informer pendant une Enquête Pénale . . . 164
15.5 Les Violations de NYANGA et de MBOLO . . . 165
15.6 Ce que les Violations demandent à chaque Métier . . . 166

16 Programme de Conformité et Rapport d'Audit 169

16.1 L'Observation en Sept Éléments . . . 170
16.2 La Synthèse par Domaine . . . 170
16.3 Prioriser les Recommandations . . . 172
16.4 L'Exposition Juridique . . . 173
16.5 La Conservation et la Purge . . . 174

16.6 Le Programme de Mise en Conformité . . . 174
16.7 Ce que le Rapport demande à chaque Métier . . . 175

VI Défis Avancés 179

17 Profilage, Décisions Automatisées et Intelligence Artificielle 181

17.1 Profilage et Décision Automatisée . . . 182
17.2 L'Article 65 . . . 183
17.3 Auditer un Modèle de Notation . . . 183
17.3.1 Les variables qui révèlent . . . 184
17.3.2 Mesurer une discrimination . . . 184
17.4 Les Données Biométriques . . . 184
17.5 L'Intelligence Artificielle : Trois Textes à Connaître . . . 184
17.5.1 Ce que ces textes changent pour l'audit . . . 185
17.5.2 Les questions propres aux systèmes qui apprennent . . . 186
17.6 L'Audit de NOUN SCORE . . . 186
17.7 Ce que le Profilage demande à chaque Métier . . . 187

18 Les Secteurs Sensibles 191

18.1 Les Renvois à des Textes Particuliers . . . 192
18.2 La Santé . . . 193
18.3 La Banque et la Finance . . . 193
18.4 Les Mineurs . . . 193
18.5 La Vidéosurveillance . . . 194
18.6 Les Télécommunications . . . 194
18.6.1 L'identification des abonnés . . . 195
18.6.2 L'opérateur comme sous-traitant . . . 195
18.7 La Justice et la Chaîne Pénale . . . 195
18.8 L'Audit de Suivi de MBOLO . . . 196
18.9 Ce que les Secteurs demandent à chaque Métier . . . 197

VII Recherche : Mesurer la Conformité, Articuler les Normes 199

19 Mesurer la Conformité, Articuler les Normes 201

19.1 Mesurer l'État de Conformité . . . 202
19.2 Deux Sortes d'Incertitude . . . 202
19.3 Une Piste de Recherche Actuelle : la Loi et la Chaîne Pénale . . . 203
19.3.1 La question . . . 203
19.3.2 Trois niveaux d'articulation . . . 203
19.3.3 La matrice d'analyse . . . 204
19.3.4 Trois zones de tension . . . 204

19.3.5 Une quatrième zone, proposée par ce cours . . . 205
19.3.6 Qualifier les acteurs opération par opération . . . 205
19.3.7 Quatre propositions . . . 206
19.4 Deux Échelles à Trois Niveaux . . . 206
19.5 Questions Ouvertes . . . 206
19.6 Ce que la Mesure demande à chaque Métier . . . 207

A Glossaire **209**

B Outils **213**

C Modèles de Documents **215**

D Textes et Normes **217**

E Bibliographie Commentée **221**

F Contacts et Ressources **223**

G Les Quarante-six Exigences de la Mission NYANGA **225**

Références bibliographiques **229**

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

LE 24 JUIN 2026

« Être en règle, c'est pouvoir le montrer.
Le dire ne suffit pas. »

Principe du cours

Niveau : *Introductif* • Aucun, sinon la lecture de l'avant-propos

✦ Objectifs du chapitre

- ➢ Reconnaître, dans une situation réelle, les questions qui relèvent de la protection des données à caractère personnel.
- ➢ Situer une organisation par rapport à l'échéance du 23 juin 2026 fixée par l'article 73 de la loi n° 2024/017.
- ➢ Distinguer une déclaration de conformité d'une conformité démontrée.
- ➢ Coter une exigence OUI, NON ou NEK et justifier la cote.
- ➢ Situer les métiers qui interviennent, de la réclamation au rapport d'audit.

Avant de commencer : une lettre, un mercredi matin

Bafoussam, mercredi 24 juin 2026, 8 h 15. Le courrier de NYANGA CRÉDIT[1], établissement de microfinance de vingt-deux agences et de 210 000 clients, contient une lettre recommandée de M. TAGNE Paul, commerçant au marché A, client depuis 2016.

M. TAGNE a assisté, en février, à l'audience du tribunal de grande instance de la Mifi qui jugeait l'affaire de la nuit du 14 mars 2025. Il y a appris que son dossier figurait parmi les 18 412 fichiers du dossier `Clients` copiés cette nuit-là vers l'étranger. Personne ne l'en avait informé. Sa lettre demande trois choses : savoir quelles données l'établissement détient sur lui et à qui il les a communiquées, obtenir l'effacement de celles qui ne sont plus nécessaires, et comprendre pourquoi il n'a pas été prévenu. Elle annonce qu'à défaut de réponse il saisira le juge des référés.

[1] NYANGA CRÉDIT, ses dirigeants, ses clients, ses prestataires et le cabinet KORO AUDIT & CONFORMITÉ sont fictifs, comme les dates, les adresses et les montants des cas de ce cours. Les mécanismes et les textes cités sont exacts.

© MaletYon

À 10 heures, le directeur général, M. TCHOUA, réunit la RSSI, Mme NDOUMBE, le DSI, M. KAMGA, et la juriste, Me ETOUNDI. Il pose une seule question : « Sommes-nous en règle ? » Me ETOUNDI rappelle que la veille, le 23 juin, a expiré le délai de dix-huit mois que la loi accordait aux organisations pour se mettre en conformité. M. KAMGA assure que « tout est sécurisé depuis l'incident ». Mme NDOUMBE répond qu'elle ne sait pas, et qu'elle ne peut pas le savoir sans un examen.

★ Attention

Violation typique. Répondre « nous sommes conformes » sur la foi d'une politique écrite, d'un pare-feu renforcé ou d'une absence de plainte.

Règle : la conformité se démontre traitement par traitement, par des preuves : un registre, des autorisations, des contrats, des journaux, des réponses aux personnes. Ce qui n'a pas été examiné reste inconnu, et se dit inconnu.

0.1 Ce que l'on sait le 24 juin

La réunion permet de réunir quelques faits. Ce sont des **constatations** : chacune se rattache à une pièce que quelqu'un d'autre pourrait vérifier.

- Le 14 mars 2025, 3,2 Go du dossier `Clients` ont été copiés vers une adresse étrangère ; l'enquête technique l'a établi, et le jugement de février 2026 le reprend.
- Le 20 mars 2025, l'officier de police judiciaire chargé de l'enquête a demandé par écrit à l'établissement de ne pas informer les clients, pour ne pas compromettre l'enquête. Aucun client n'a été informé depuis.
- L'établissement n'a jamais adressé de demande d'autorisation de traitement à l'Autorité prévue par la loi.
- Me ETOUNDI n'a trouvé aucune liste des traitements de l'établissement. Le DSI tient un inventaire des applications, qui n'est pas la même chose.

Les autres phrases entendues pendant la réunion sont des opinions : « tout est sécurisé », « les clients ont signé les conditions générales », « le prestataire de recouvrement est sérieux ». Elles ne sont ni vraies ni fausses à ce stade ; elles attendent leur preuve.

■ Définition

Donnée à caractère personnel : selon l'article 5 de la loi, « information se rapportant à une personne permettant de l'identifier directement ou indirectement, notamment par référence à toute forme d'identifiant ou à un ou plusieurs éléments, propres à son identité physique, psychologique, génétique, psychique, culturelle, socio-professionnelle ou économique ». La loi cite parmi les exemples un nom, une photo, une adresse, un numéro de téléphone, un matricule interne, une adresse IP et un enregistrement vocal.

Traitement : toute opération appliquée à de telles données, « notamment la collecte,

l'enregistrement, l'organisation, la conservation [...], la consultation, l'utilisation, la communication [...], ainsi que le verrouillage, l'effacement ou la destruction » (article 5).

0.2 L'échéance du 23 juin

La loi n° 2024/017 a été promulguée le 23 décembre 2024 [26]. Elle a laissé aux organisations un délai pour adapter leurs pratiques.

Jurisprudence & Droit applicable

Loi n° 2024/017, article 73 [26] : *« Les personnes physiques ou morales en charge du traitement des données à caractère personnel disposent d'un délai de dix-huit (18) mois, à compter de la date de promulgation de la présente loi, pour se conformer aux dispositions de celle-ci. »*

Portée. Le délai court du 23 décembre 2024 au 23 juin 2026. À partir du 24 juin, une organisation qui traite des données ne peut plus invoquer la période d'adaptation. L'article ne dit pas si les traitements commencés avant la loi doivent être régularisés rétroactivement ; la question est discutée au Chapitre 19.

La loi s'applique largement. Son article 2 vise tout traitement effectué par l'État, les collectivités territoriales décentralisées ou toute personne physique ou morale, tout traitement de données d'une personne établie, résidant ou en transit au Cameroun, et tout traitement effectué par un responsable ou un sous-traitant établi au Cameroun. NYANGA CRÉDIT entre dans chacun de ces cas.

Note

Ce que la loi ne dit pas. Elle ne crée pas de délégué à la protection des données ; elle ne fixe pas de délai chiffré pour informer d'une violation (l'article 22 dit « sans délai ») ; et de nombreuses modalités sont renvoyées à des textes d'application. Elle confie enfin la plus grande part du contrôle à une Autorité de protection des données à caractère personnel dont la création et le fonctionnement relèvent d'un décret (article 53, alinéa 2). Le cours lit la loi telle qu'elle est écrite, et cote NEK ce que ses textes d'application ne permettent pas encore de trancher.

0.3 Trois questions pour un audit

La question du directeur général, « sommes-nous en règle », est trop large pour recevoir une réponse. Mme NDOUMBE la décompose en trois questions, chacune vérifiable.

1. **Que traitons-nous ?** Quelles données, sur quelles personnes, pour quelles finalités, avec quels destinataires et pendant combien de temps. C'est l'objet du registre des activités de traitement que l'article 29 impose de tenir (Chapitre 9).

2. **Ce que nous faisons est-il permis ?** Le consentement ou l'une des trois dérogations de l'article 9, l'autorisation de l'article 19, l'information de l'article 21, la durée de conservation de l'article 13 (Chapitres 1 et 2).
3. **Pouvons-nous le prouver ?** Pour chaque exigence, une pièce qui l'établit, ou l'aveu qu'elle manque (Chapitre 8).

Le 30 juin, le conseil d'administration confie la mission au cabinet KORO AUDIT & CONFORMITÉ, de Yaoundé. Son auditrice principale, Mme BELLO Aïssatou, demande deux mois de terrain. Elle refuse de commencer par la sécurité informatique, que M. KAMGA voulait lui montrer en premier : « Nous commencerons par savoir ce que vous traitez. Protéger des données que l'on n'a pas recensées, c'est protéger au hasard. »

0.4 Répondre à M. TAGNE

La lettre n'attend pas l'audit. Me ETOUNDI prépare la réponse avec trois textes en main.

Jurisprudence & Droit applicable

Loi n° 2024/017, article 39 [26] : *« La personne concernée peut demander au responsable du traitement : les informations permettant de connaitre et de contester le traitement ; la confirmation que les données à caractère personnel la concernant font ou ne font pas l'objet de traitement ; la communication des données à caractère personnel qui la concerne ainsi que toute information disponible quant à l'origine de celle-ci ; [...] une copie de ses données à caractère personnel sous une forme intelligible contre paiement d'une somme ne pouvant excéder le coût de la reproduction. »*

Portée. M. TAGNE a droit à la liste de ses données, à leur origine et à leurs destinataires. Le délai de réponse doit être fixé par voie réglementaire (article 47) ; en attendant, l'auditrice recommande de répondre dans un délai raisonnable et de le dater.

La demande d'effacement est plus délicate. L'article 38 oblige à effacer « sans délai » les données qui ne sont plus nécessaires, mais « sous réserve des exigences de conservation » prévues par d'autres textes. Or les données de M. TAGNE sont aussi des pièces d'une procédure judiciaire et de la comptabilité de l'établissement. Me ETOUNDI ne peut ni tout effacer, ni tout garder : elle doit séparer, donnée par donnée, ce qui reste nécessaire et ce qui ne l'est plus. Cette séparation suppose de savoir où se trouvent les données de M. TAGNE, ce que personne ne sait encore.

Reste la troisième question : pourquoi n'a-t-il pas été prévenu ? L'article 22 impose d'informer « sans délai » l'Autorité et la personne concernée dès connaissance d'une violation. En mars 2025, l'officier de police judiciaire a demandé le silence pour protéger l'enquête. Deux obligations se sont rencontrées ; laquelle l'emportait, et à partir de

quand la loi s'appliquait-elle à cette violation antérieure à l'échéance ? Le Chapitre 15 examine la question pour la pratique, et le Chapitre 19 la présente comme un objet de recherche en cours.

0.5 Premières cotes

Mme BELLO ouvre son premier papier de travail le 6 juillet, premier jour de terrain. Elle cote huit propositions avec ce qu'elle a vu.

Définition

Cote oui, non, nek : réponse à une question d'audit fermée sur une exigence. OUI : la conformité est établie par une preuve. NON : l'écart est établi par une preuve. NEK (*not enough knowledge*) : les preuves disponibles ne permettent pas de trancher. L'instrument vient du programme de recherche de l'auditologie [27].

Lecture auditologique · Les huit premières propositions, 6 juillet 2026

Proposition	Cote	Pièce
NYANGA CRÉDIT traite des données à caractère personnel	OUI	Fichiers clients, paie
NYANGA CRÉDIT est soumise à la loi n° 2024/017	OUI	Art. 2
Un registre des activités de traitement existe	NON	Aucun produit, attestation de la juriste
Une autorisation de l'Autorité a été demandée	NON	Attestation de la direction
Les clients ont consenti aux traitements	NEK	Formulaires non encore examinés
Les données des clients sont protégées	NEK	Aucune mesure encore testée
Les prestataires sont liés par un contrat conforme	NEK	Contrats non encore reçus
Des données sont transférées hors du Cameroun	NEK	Hébergement du logiciel bancaire non encore examiné

Décompte. Deux OUI, deux NON, quatre NEK sur huit. $\mu = 0{,}25$ · $U = 0{,}50$ · $H = 1{,}50$ **bit**

Lecture. La moitié des propositions est inconnue. Ce n'est pas un mauvais résultat : c'est l'état normal d'un audit qui commence. Les deux NON sont, eux, établis dès le premier jour, et ils suffisent à répondre au directeur général que l'établissement n'est pas en règle sur ces deux points.

Les trois mesures se lisent ensemble. μ est la part des OUI, U celle des NEK, H l'entropie de la répartition, en bits. Le Chapitre 8 en donne la règle de lecture, et le Chapitre 19 en discute les limites.

0.6 Deux autres organisations

Deux autres organisations accompagnent NYANGA CRÉDIT dans ce cours.

Le **CENTRE MÉDICAL MBOLO**, à Bertoua, établissement privé de 120 lits, traite des données de santé, qui comptent parmi les données sensibles de l'article 5. Son dossier patient informatisé est édité et hébergé par un prestataire de Douala ; il prépare un service de téléconsultation pour les villages de la Kadey, et il a découvert en mai qu'un dossier de patiente avait été consulté par des agents sans lien avec ses soins. Sa directrice, le Dr ABENA, a commandé un audit de préparation avant l'échéance.

NOUN PAY, à Bafoussam, fintech de paiement mobile et de microcrédit, héberge tout son système d'information chez un fournisseur de nuage à l'étranger et décide de l'octroi de ses crédits par une notation automatique. Un client conteste un refus. Les transferts de données hors du Cameroun et les décisions automatisées sont au centre de son audit.

0.7 Les métiers de l'affaire

Application Auditeur de la protection des données

Mme BELLO examine, prouve et conclut. Elle ne corrige pas elle-même : elle dit ce qui est établi, ce qui manque, et ce qu'il faut faire. Son indépendance à l'égard de la direction qu'elle audite conditionne la valeur de ses conclusions.

Application Délégué à la protection des données

La loi n'impose pas cette fonction. Beaucoup d'organisations la créent pourtant, sur le modèle européen, pour qu'une personne tienne le registre, conseille les équipes et réponde aux personnes. NYANGA CRÉDIT n'en a pas : la lettre de M. TAGNE est arrivée sur le bureau du directeur général.

Application Juriste conformité

Me ETOUNDI lit les textes, répond aux personnes et mesure le risque de contentieux. Elle doit savoir dire où la loi est claire, où elle renvoie à des textes non publiés, et où deux obligations se contredisent.

Application RSSI

Mme NDOUMBE tient la sécurité des données, exigée par les articles 22, 24 et 27. Elle sait aussi que la sécurité n'est qu'une partie de la conformité : des données bien protégées peuvent être collectées sans droit.

Application Responsable de traitement

M. TCHOUA, pour l'établissement, détermine les finalités et les moyens des traitements. C'est lui que la loi oblige, et lui qui répond des sanctions des articles 54 à 71.

0.8 Cinq réflexes

1. **Lire le texte officiel.** On cite la loi telle qu'elle est écrite, pas telle qu'un résumé ou le modèle européen la décrit.
2. **Recenser avant de juger.** On ne peut pas dire si un traitement est permis tant qu'on ne sait pas qu'il existe.
3. **Demander la preuve.** Une déclaration n'établit rien ; une pièce établit quelque chose, et l'on dit quoi.
4. **Coter l'inconnu.** Ce qui n'a pas été examiné est NEK, jamais conforme par défaut.
5. **Protéger les données de l'audit.** L'auditeur manipule lui-même des données personnelles : il en prend le moins possible et les protège comme il l'exige des autres.

★ À retenir

- Depuis le 24 juin 2026, le délai de mise en conformité de l'article 73 est expiré : la loi n° 2024/017 s'applique pleinement.
- La conformité se démontre par des preuves, traitement par traitement ; une déclaration ne la démontre pas.
- La question « sommes-nous en règle » se décompose en trois : que traitons-nous, est-ce permis, pouvons-nous le prouver.
- À NYANGA CRÉDIT, l'absence de registre et de demande d'autorisation est établie dès le premier jour ; la moitié des propositions reste NEK.
- Une violation antérieure à l'échéance, couverte par une demande de silence de l'enquête pénale, pose une question d'articulation des normes que le cours traite à part.

● Note

Points de contrôle. Vous avez compris ce prologue si vous savez :

- dater l'échéance de l'article 73 et dire ce qu'elle change ;
- séparer, dans un compte rendu de réunion, les constatations des opinions ;
- coter une exigence OUI, NON ou NEK et citer la pièce qui fonde la cote.

✍ Exercice 0.1. Donnée personnelle ou non ★☆☆

Dites si chaque élément est une donnée à caractère personnel au sens de l'article 5, et pourquoi : (a) le numéro de compte de M. TAGNE ; (b) le nombre total de clients de l'agence de Dschang ; (c) l'adresse IP d'où un client se connecte à l'application mobile ; (d) l'enregistrement d'un appel au service client ; (e) le taux d'intérêt moyen des crédits de 2025.

✍ Exercice 0.2. Constatation ou opinion ★★☆

Classez chaque phrase de la réunion du 24 juin comme constatation ou opinion, et proposez une cote OUI, NON ou NEK avec la pièce qui la fonderait : (a) « tout est sécurisé depuis l'incident » ; (b) « les clients ont signé les conditions générales » ; (c) « aucune demande d'autorisation n'a été envoyée » ; (d) « le prestataire de recouvrement est sérieux ».

✍ Exercice 0.3. Répondre à M. TAGNE ★★☆

(a) Rédigez la réponse à la demande d'accès de M. TAGNE, en vous appuyant sur l'article 39.

(b) Quelles données pouvez-vous effacer, et lesquelles devez-vous garder ? Justifiez avec l'article 38.

(c) Que répondez-vous à sa troisième question sans engager imprudemment l'établissement ?

✍ Exercice 0.4. Le silence demandé ★★★

Le 20 mars 2025, l'officier de police judiciaire demande à NYANGA CRÉDIT de ne pas informer ses clients.

(a) Quelles obligations entrent en concurrence ?

(b) La loi n° 2024/017 s'appliquait-elle déjà à cette violation ? Distinguez la promulgation et l'échéance de l'article 73.

(c) Quelle trace écrite l'établissement aurait-il dû garder pour se défendre aujourd'hui ?

● Note

Pour aller plus loin.

➢ La loi n° 2024/017 [26], dans son texte officiel.

➢ D. J. Solove, *Understanding Privacy* [40], pour la diversité de ce que l'on appelle la vie privée.

Note

Transition. Avant de recenser les traitements de NYANGA CRÉDIT, il faut savoir ce qu'est exactement une donnée, un traitement, un responsable et un sous-traitant, et quand une donnée devient sensible. C'est l'objet du Chapitre 1.

partie I

Fondements : la Donnée, la Personne, le Traitement

© MaletYon

1

DONNÉES, TRAITEMENTS, ACTEURS

« On ne protège bien que ce que l'on sait nommer. »

Principe du cours

Niveau : *Fondamental* • Lecture du Chapitre 0

✦ Objectifs du chapitre

- ➢ Reconnaître une donnée à caractère personnel, directe ou indirecte, selon l'article 5 de la loi n° 2024/017.
- ➢ Distinguer anonymisation et pseudonymisation, et dire ce que chacune change pour l'application de la loi.
- ➢ Identifier les données sensibles, dont la liste camerounaise est plus large que la liste européenne.
- ➢ Qualifier les acteurs d'un traitement : personne concernée, responsable, sous-traitant, responsables conjoints, destinataire.
- ➢ Délimiter le champ d'application de la loi et ses exclusions.

Avant de commencer : « nos données personnelles, ce sont les clients »

Bafoussam, mardi 7 juillet 2026. Pour sa deuxième journée de terrain, Mme BELLO demande à chaque directeur de NYANGA CRÉDIT de lister les données personnelles que traite son service. Le directeur commercial répond aussitôt : « Nos données personnelles, ce sont les clients. » La directrice des ressources humaines n'a rien noté ; elle pensait que la question ne la concernait pas.

En fin de journée, l'auditrice a recensé onze familles de données, dont huit ne figuraient sur aucune liste : les cautions des emprunteurs, les prospects démarchés par les agents, les candidats à l'embauche, les salariés, les images des caméras des agences, les enregistrements du service client, les journaux de connexion de l'application mobile et les listes de débiteurs remises au prestataire de recouvrement.

© MaletYon

★ Attention

Violation typique. Réduire les données personnelles aux fichiers clients, et oublier les salariés, les tiers, les images, les voix et les journaux techniques.

Règle : une donnée est personnelle dès qu'elle permet d'identifier une personne, directement ou indirectement, quel que soit son support et quelle que soit la personne. Le recensement part des personnes concernées, pas des applications.

1.1 La Donnée à Caractère Personnel

L'article 5 de la loi définit la donnée à caractère personnel par sa relation à une personne identifiable, et non par sa nature.

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 5 [26] : *« Donnée à caractère personnel : information se rapportant à une personne permettant de l'identifier directement ou indirectement, notamment par référence à toute forme d'identifiant ou à un ou plusieurs éléments, propres à son identité physique, psychologique, génétique, psychique, culturelle, socio-professionnelle ou économique, notamment un nom, une photo, une empreinte, une adresse postale, une adresse mail, un numéro de téléphone, un numéro de sécurité sociale, un matricule interne, un identifiant numérique, une adresse IP, un identifiant de connexion informatique, un enregistrement vocal. »*

Portée. La liste des exemples est longue et précise : une adresse IP, un matricule interne et un enregistrement vocal sont des données personnelles par la lettre même de la loi. L'auditeur n'a pas à le démontrer.

1.1.1 Identifier directement ou indirectement

Une donnée identifie **directement** quand elle désigne la personne à elle seule : un nom complet, une photographie, une empreinte. Elle identifie **indirectement** quand il faut la rapprocher d'autres informations : un numéro de compte, rapproché du fichier des comptes ; une adresse IP, rapprochée du journal de l'opérateur ; la combinaison « femme, 34 ans, pharmacienne, quartier Tamdja » dans une petite ville. La question n'est pas de savoir si l'organisation fait ce rapprochement, mais s'il est raisonnablement possible.

1.1.2 Anonymiser n'est pas pseudonymiser

■ Définition

Anonymisation : selon l'article 5, « processus de modification ou de suppression d'informations à caractère personnel identifiables dans un ensemble de données, afin de rendre ces données non attribuables à des individus spécifiques ».

Pseudonymisation : « technique utilisée pour remplacer des données d'identification directe par des identifiants artificiels dans le but de protéger la vie privée des individus » (article 5).

La différence est décisive pour l'auditeur. Des données réellement anonymisées ne se rapportent plus à une personne identifiable : elles sortent du champ de la loi. Des données pseudonymisées restent personnelles, puisque celui qui détient la table de correspondance peut rétablir le lien. Un fichier où le nom du client est remplacé par son numéro de compte n'est pas anonyme : il est pseudonymisé, et le numéro de compte est lui-même un identifiant.

Note

L'anonymisation se prouve. Une organisation qui déclare « nos statistiques sont anonymes » doit montrer qu'aucun rapprochement raisonnable ne permet de retrouver une personne. Supprimer les noms ne suffit pas quand il reste la date de naissance, le quartier et la profession. Tant que la preuve manque, l'auditeur cote la proposition « ces données sont anonymes » NEK, et traite les données comme personnelles.

1.2 Les Données Sensibles

Certaines données exposent davantage la personne : leur divulgation peut conduire à une discrimination, une persécution ou une atteinte grave à la réputation. La loi les nomme et les encadre plus strictement.

Jurisprudence & Droit applicable

Loi n° 2024/017, article 5 [26] : *« Donnée sensible : information relative notamment aux opinions et activités religieuses, philosophiques, politiques, syndicales, aux transactions bancaires, à l'origine raciale ou ethnique, linguistique ou régionale, à la vie sexuelle, à la génétique, à la biométrie, à la santé, aux poursuites judiciaires et aux sanctions pénales. »*

Portée. Le mot « notamment » rend la liste ouverte. Elle comprend trois catégories que le droit européen ne range pas parmi les données sensibles : les transactions bancaires, l'origine linguistique ou régionale, et les poursuites judiciaires.

La présence des **transactions bancaires** dans la liste change tout pour un établissement financier : la plupart des données de NYANGA CRÉDIT et de NOUN PAY est sensible. L'article 48, alinéa 2, en tire la conséquence : le traitement des données dans le cadre des transactions bancaires est interdit « sans autorisation préalable des administrations et structures compétentes ». L'origine **linguistique ou régionale** répond à une préoccupation propre au Cameroun ; un formulaire qui demande la région d'origine ou la langue maternelle collecte une donnée sensible.

L'article 48, alinéa 1, interdit le traitement des données relatives aux opinions, à l'origine, à la vie sexuelle, « à la génétique et à la biométrie en matière de santé ». La lecture de cette fin de phrase n'est pas tranchée : la biométrie est-elle interdite seulement en matière de santé, ou dans tous les cas ? L'auditeur ne tranche pas à la place du juge ; il signale la difficulté et cote NEK la licéité d'un pointage biométrique tant qu'aucune

autorisation ni aucun texte d'application ne l'éclaire (Chapitre 17).

1.3 Le Traitement et le Fichier

Définition

Traitement : selon l'article 5, « opération ou ensemble d'opérations effectuées ou non à l'aide de procédés entièrement ou partiellement automatisés ou non automatisés et appliqués à des données à caractère personnel, notamment la collecte, l'enregistrement, l'organisation, la conservation, l'adaptation ou la modification, l'extraction, la consultation, l'utilisation, la communication par transmission, diffusion ou toute autre forme de mise à disposition, le rapprochement, ainsi que le verrouillage, l'effacement ou la destruction ».

Fichier : « ensemble de données structurées et à caractère personnel accessibles selon des critères déterminés, que cet ensemble soit centralisé, décentralisé ou réparti de manière fonctionnelle ou géographique » (article 5).

Deux conséquences pratiques en découlent. D'abord, le papier compte : la loi vise aussi les procédés « non automatisés », et les dossiers de crédit rangés dans les armoires des agences sont des fichiers. Ensuite, une simple consultation est un traitement : l'agent qui ouvre le dossier d'un client sans raison de service traite des données, et c'est précisément ce que le CENTRE MÉDICAL MBOLO découvrira dans ses journaux (Chapitre 12).

Un traitement se définit par sa **finalité** : l'ensemble des opérations faites dans un même but. « Gérer les comptes des clients » est un traitement ; « tenir la base de données Oracle » n'en est pas un, c'est un moyen technique qui sert plusieurs traitements. Cette distinction organise tout le recensement du Chapitre 9.

Traitement · Gestion des comptes des clients, NYANGA CRÉDIT

Finalité : ouvrir, tenir et clôturer les comptes d'épargne et de crédit. **Personnes concernées :** clients, mandataires, cautions. **Données :** identité, pièce d'identité, adresse, téléphone, profession, revenus déclarés, mouvements des comptes (données sensibles, article 5). **Destinataires :** agences, service crédit, éditeur du logiciel bancaire, prestataire de recouvrement pour les impayés. **Ce que l'audit établit au 7 juillet :** le traitement existe (OUI) ; son autorisation n'a pas été demandée (NON) ; sa durée de conservation n'est fixée nulle part (NON) ; le fondement du traitement des cautions reste à examiner (NEK).

1.4 Les Acteurs du Traitement

Définition

Personne concernée : « toute personne dont les données à caractère personnel font l'objet d'un traitement » (article 5).

Responsable du traitement : « personne physique ou morale qui, seule ou conjointement, collecte et traite des données à caractère personnel et en détermine les moyens et les finalités » (article 5).

Sous-traitant : « toute personne physique ou morale qui traite des données à caractère personnel pour le compte du responsable du traitement et sous ses instructions » (article 5).

Destinataire : « toute personne physique ou morale, habilitée à recevoir une communication des données à caractère personnel » (article 5).

La qualification se fait **opération par opération**, pas acteur par acteur. L'éditeur du logiciel bancaire de NYANGA CRÉDIT est sous-traitant quand il héberge les comptes selon les instructions de l'établissement ; il deviendrait responsable s'il utilisait ces données pour améliorer ses propres produits sans instruction. Un même acteur peut donc porter deux qualités pour deux opérations différentes ; le Chapitre 19 montre que cette règle pose des questions difficiles dans la chaîne pénale.

Jurisprudence & Droit applicable

Loi n° 2024/017, article 20 [26] : *« Le responsable du traitement et le sous-traitant sont assujettis aux mêmes obligations au titre de l'activité de traitement des données à caractère personnel. »*

Portée. Le texte camerounais va plus loin que le droit européen, qui distingue nettement les obligations des deux acteurs. Pour l'auditeur, le prestataire de recouvrement et l'éditeur du logiciel bancaire répondent des mêmes obligations que NYANGA CRÉDIT pour les traitements qu'ils réalisent.

L'article 31 ajoute les **responsables conjoints** : lorsque deux organisations déterminent ensemble les finalités et les moyens, elles sont « solidairement responsables » et doivent fixer leurs obligations dans une convention « rendue publique » (Chapitre 13).

Loi n° 2024/017	ISO/IEC 29100	RGPD (UE)	NIST Privacy Framework
Personne concernée	Personne à qui se rapportent les données (*PII principal*)	Personne concernée	Individu (*individual*)
Responsable du traitement	*PII controller*	Responsable du traitement	Organisation, décrite par son rôle dans l'écosystème de traitement
Sous-traitant	*PII processor*	Sous-traitant	Organisation, même remarque
Destinataire, tiers	Tiers (*third party*)	Destinataire, tiers	Autres acteurs de l'écosystème
Autorité de protection	Autorité de contrôle (hors norme)	Autorité de contrôle	Hors cadre

Tableau 1.1. Les acteurs dans quatre vocabulaires

Le cadre du NIST [30] est volontaire. Il ne fixe aucune qualité juridique et parle d'une organisation et de son rôle là où la loi distingue le responsable du sous-traitant. Ces quatre vocabulaires ont une histoire commune que le Chapitre 3 retrace. Le Chapitre 4 dit quand le règlement européen s'applique à une organisation camerounaise. Le Chapitre 5 présente le cadre du NIST et la famille des normes ISO.

La norme ISO/IEC 29100 [23] fournit un vocabulaire et des principes communs à toutes les normes de la famille, en particulier l'ISO/IEC 27701 (Chapitre 5). Le RGPD [35] sert de point de comparaison : beaucoup d'organisations camerounaises, comme NOUN PAY, y sont exposées parce que leurs prestataires sont européens.

1.5 Le Champ d'Application

L'article 2 soumet à la loi tout traitement effectué par l'État, les collectivités territoriales décentralisées ou toute personne physique ou morale ; tout traitement des données de personnes établies, résidant ou en transit au Cameroun ; tout traitement réalisé par un responsable ou un sous-traitant établi au Cameroun ; et tout traitement réalisé dans un territoire où le droit camerounais s'applique. Le critère des personnes « en transit » est large : un voyageur dont les données sont traitées pendant son passage au Cameroun est protégé.

L'article 3 exclut trois catégories : les traitements d'une personne physique pour ses activités exclusivement personnelles ou domestiques, à condition que les données ne soient pas destinées à une communication systématique, à un tiers ou à la diffusion ; les copies temporaires faites pour la transmission sur un réseau ; et les traitements à des fins littéraires, artistiques, archivistiques d'intérêt public, de recherche, de statistique ou de journalisme, dans le respect des règles déontologiques de ces professions.

Deux articles renvoient enfin à des textes particuliers : l'article 4 pour les traitements des autorités de sécurité et de défense, l'article 72 pour les traitements relatifs « notamment à la sécurité, à la défense, à la santé, à la justice et à l'état civil ». La portée de cette réserve est discutée aux Chapitres 18 et 19 : tant que les textes spécifiques ne sont pas identifiés, l'auditeur applique la loi générale et signale la réserve.

1.6 L'Inventaire de NYANGA

Scénario Opérationnel · Mission NYANGA. Onze familles de données, 7 juillet 2026

Famille	Exemples de données	Sensible	Connue
Clients	Identité, revenus, mouvements	Oui	Oui
Cautions	Identité, revenus	Oui	Non
Prospects	Nom, téléphone, quartier	Non	Non
Débiteurs remis au recouvrement	Identité, montant dû	Oui	Non
Salariés	Identité, paie, santé (arrêts)	Oui	Oui
Candidats	CV, région d'origine	Oui	Non
Images des agences	Visages, heures de passage	Non	Non
Appels du service client	Voix, motif d'appel	Non	Non
Journaux de l'application	Adresse IP, identifiant	Non	Non
Utilisateurs du SI	Comptes, journaux d'accès	Non	Non
Fournisseurs (personnes physiques)	Identité, coordonnées bancaires	Oui	Oui

Constatations. Onze familles, dont huit absentes des listes de la direction. Sept contiennent des données sensibles au sens de l'article 5, dont quatre à cause des transactions bancaires et une à cause de la région d'origine demandée aux candidats. **Analyse** (confiance élevée). La vision de l'établissement était organisée par applications et par clients. Les familles oubliées sont celles dont la finalité n'est pas commerciale : elles n'ont pas de « propriétaire » évident dans l'organisation.

1.7 Ce que la Notion demande à chaque Métier

Application Auditeur de la protection des données

Recenser à partir des personnes concernées, pas des applications. Pour chaque famille, demander qui la collecte, pour quoi faire, et où elle va. Ne jamais accepter « anonyme » sans preuve.

Application Juriste conformité

Qualifier chaque acteur pour chaque opération, et relire les contrats à la lumière de l'article 20 : le prestataire porte les mêmes obligations que l'établissement.

Application Responsable de traitement

Désigner, pour chaque famille de données, un propriétaire dans l'organisation. Une famille sans propriétaire est une famille que personne ne protège.

★ À retenir

- Une donnée est personnelle dès qu'elle identifie une personne, directement ou indirectement ; la loi cite l'adresse IP, le matricule interne et la voix.
- Les données pseudonymisées restent personnelles ; seules des données dont l'anonymisation est prouvée sortent du champ de la loi.
- La liste camerounaise des données sensibles inclut les transactions bancaires, l'origine linguistique ou régionale et les poursuites judiciaires.
- Le responsable et le sous-traitant sont assujettis aux mêmes obligations (article 20) ; la qualification se fait opération par opération.
- À NYANGA CRÉDIT, onze familles de données ont été recensées, dont huit inconnues de la direction et sept sensibles.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire pourquoi un fichier pseudonymisé reste soumis à la loi ;
- citer trois données sensibles propres à la liste camerounaise ;
- qualifier un prestataire de responsable ou de sous-traitant pour une opération donnée.

✍ Exercice 1.1. Personnelle, sensible, ni l'une ni l'autre ★☆☆

Classez : (a) le relevé de compte d'un client ; (b) la langue maternelle d'un candidat ; (c) le chiffre d'affaires global d'une agence ; (d) la photographie d'un client sur sa carte d'identité ; (e) l'adresse IP d'un utilisateur de l'application ; (f) le casier

judiciaire d'un candidat.

✍ Exercice 1.2. Anonyme ou pseudonyme ★★☆

Le service marketing transmet à un cabinet d'études un fichier où chaque client est désigné par un code, avec son âge, son sexe, son agence, sa profession et son encours. Le fichier est-il anonyme ? Que faudrait-il faire pour qu'il le soit, et comment le prouver ?

✍ Exercice 1.3. Qualifier les acteurs ★★☆

Pour chaque opération, dites qui est responsable, qui est sous-traitant : (a) l'éditeur héberge les comptes et applique les sauvegardes demandées ; (b) le prestataire de recouvrement appelle les débiteurs selon un script fourni par NYANGA ; (c) le même prestataire utilise les numéros pour proposer ses propres services ; (d) un opérateur de téléphonie envoie les SMS de relance.

✍ Exercice 1.4. Le champ de la loi ★★★

(a) Un agent de NYANGA conserve sur son téléphone personnel les numéros de ses clients pour les relancer. L'exclusion des activités domestiques (article 3) s'applique-t-elle ?

(b) Un journaliste publie des extraits des fichiers exfiltrés en mars 2025. Quel régime s'applique à son traitement ?

(c) L'expert judiciaire conserve une copie du dossier `Clients` pour son rapport. Quels articles faut-il lire, et quelle difficulté signalez-vous ?

● Note

Pour aller plus loin.

- ➢ L'ISO/IEC 29100 [23], pour le vocabulaire et les onze principes de protection de la vie privée.
- ➢ H. Nissenbaum, *Privacy in Context* [33], pour l'idée qu'une donnée est protégée par le contexte dans lequel elle circule.

● Note

Transition. Savoir qu'un traitement existe ne dit pas s'il est permis. Le Chapitre 2 expose les principes que tout traitement doit respecter, et la règle du consentement, plus stricte au Cameroun qu'en Europe.

2

LES PRINCIPES DU TRAITEMENT

« Une case cochée n'est pas un consentement.
C'est, au mieux, un indice. »

Principe du cours

Niveau : *Fondamental* • Chapitre 1

✦ Objectifs du chapitre

- ➢ Énoncer les principes des articles 6 à 18 de la loi n° 2024/017 et les traduire en questions d'audit.
- ➢ Apprécier la validité d'un consentement au regard des articles 5 et 9.
- ➢ Identifier les trois cas où l'on peut se passer du consentement, et les comparer aux bases légales du droit européen.
- ➢ Vérifier la finalité, l'exactitude et la durée de conservation d'un traitement.
- ➢ Contrôler l'information fournie aux personnes selon l'article 21.

Avant de commencer : « ils ont tous signé »

Bafoussam, mardi 14 juillet 2026. Le directeur commercial de NYANGA CRÉDIT pose sur la table de Mme BELLO une liasse de formulaires d'ouverture de compte. « Ils ont tous signé. » Le formulaire, inchangé depuis 2016, tient sur une page. En bas, au-dessus de la signature, une case pré-imprimée : « J'accepte les conditions générales de NYANGA CRÉDIT. » Les conditions générales, huit pages, ne sont pas remises au client ; elles sont « disponibles en agence ».

L'auditrice note trois questions. Les clients ont-ils consenti à quelque chose de précis ? Les cautions, qui ne signent pas ce formulaire, ont-elles consenti à quoi que ce soit ? Et les prospects, dont les agents notent le nom et le téléphone sur un cahier lors des tournées de marché, savent-ils seulement qu'ils figurent dans un fichier ?

© MaletYon

★ Attention

Violation typique. Tenir une signature au bas de conditions générales pour un consentement au traitement des données.

Règle : le consentement exigé par la loi est préalable, libre, éclairé, spécifique et univoque. Il porte sur un traitement identifié, après une information claire ; il se prouve, et il peut être retiré.

2.1 Six Principes, Six Questions d'Audit

Le chapitre I du titre II de la loi pose les principes du traitement. Chacun se traduit en une question fermée que l'auditeur peut coter.

Principe	Article	Question d'audit
Respect de la vie privée	6	Le traitement porte-t-il atteinte à la vie privée au-delà de ce que sa finalité exige ?
Confidentialité	7, 15	Les données sont-elles protégées contre la divulgation, y compris en transmission ?
Consentement	9	Un consentement valable, ou l'une des trois dérogations, fonde-t-il le traitement ?
Licéité et loyauté	10	Le traitement est-il permis, et les personnes ont-elles été traitées loyalement ?
Finalité	11	La finalité est-elle déterminée, explicite et légitime, et l'usage ultérieur compatible ?
Exactitude	12	Les données sont-elles complètes, fiables, tenues à jour, et les erreurs corrigées ?
Conservation limitée	13	La durée de conservation est-elle fixée et respectée ?
Information	14, 21	Les personnes reçoivent-elles, à la collecte, les informations de l'article 21 ?
Non-discrimination	17	Le traitement est-il indifférent à la classe sociale, à l'origine, aux opinions ?
Mineurs	18	Le traitement des données de mineurs est-il adéquat, pertinent et limité ?

Tableau 2.1. Les principes de la loi et leurs questions d'audit

● Note

La minimisation n'est pas un principe général de la loi. Le mot n'apparaît qu'à l'article 36, pour l'interconnexion des fichiers, et l'idée de données « adéquates, pertinentes et limitées » n'est formulée qu'à l'article 18, pour les mineurs. L'auditeur ne peut donc pas coter un écart à un principe général de minimisation au titre de la loi. Il peut en revanche s'appuyer sur la finalité (article 11) : une donnée collectée sans lien avec la finalité annoncée n'a pas de fondement. Les normes, elles, posent la minimisation comme principe [23] ; un audit contre l'ISO/IEC 27701 peut donc la retenir comme critère, à condition de le dire.

2.2 Le Consentement

Définition

Consentement : selon l'article 5, « toute manifestation de volonté expresse, non équivoque, non contrainte, libre et éclairée par une information claire, précise et complète, par laquelle la personne concernée, ou son représentant légal, accepte que ses données à caractère personnel fassent l'objet d'un traitement ».

Jurisprudence & Droit applicable

Loi n° 2024/017, article 9 [26] : *« (1) Le traitement des données à caractère personnel est subordonné au consentement préalable, libre, éclairé, spécifique et univoque de la personne concernée. (2) Toutefois, il peut être dérogé à cette exigence du consentement préalable lorsque le traitement est nécessaire : au respect d'une obligation légale à laquelle le responsable du traitement est soumis ; à l'exécution d'une mission d'intérêt public ou relevant de l'exercice de l'Autorité de protection des données à caractère personnel, dont est investi le responsable du traitement ou le tiers auquel les données sont communiquées ; à la préservation de la santé de la personne concernée ou d'une autre personne physique. (3) Le consentement d'une personne mineure de dix-huit (18) ans n'est valable que s'il est appuyé par celui de ses père et mère, ou de son représentant légal. »*

Portée. Le consentement est la règle ; les dérogations sont trois, et elles sont étroites. L'article 50 le confirme de façon négative : « le traitement des données à caractère personnel sans le consentement préalable de la personne concernée est interdit ».

2.2.1 Les cinq qualités d'un consentement

Pour coter OUI la proposition « le traitement repose sur un consentement valable », l'auditeur vérifie cinq qualités, chacune par une pièce.

1. **Préalable** : recueilli avant le traitement. Pièce : la date du recueil, comparée à la date de la première donnée.
2. **Libre** : sans contrainte. Un consentement exigé comme condition d'un service qui n'en a pas besoin n'est pas libre.
3. **Éclairé** : après une information claire, précise et complète. Pièce : le texte remis au moment du recueil.
4. **Spécifique** : pour une finalité identifiée. Un consentement global à « toutes les opérations » ne l'est pas.
5. **Univoque** : un acte positif, sans ambiguïté. Une case pré-cochée ou un silence ne le sont pas.

À ces cinq qualités s'ajoute la **preuve** : c'est au responsable de montrer qu'il a recueilli

le consentement. Un consentement dont on ne retrouve pas la trace est, pour l'auditeur, un consentement NEK, et souvent un NON si la procédure de recueil n'existait pas.

2.2.2 Les trois dérogations, comparées au droit européen

Le droit européen connaît six bases légales : le consentement, le contrat, l'obligation légale, les intérêts vitaux, la mission d'intérêt public et l'intérêt légitime [35]. La loi camerounaise n'en retient que quatre : le consentement et trois dérogations. Elle ne connaît ni l'**exécution d'un contrat**, ni l'**intérêt légitime**. Le Chapitre 4 reprend les six bases une à une et montre ce que cet écart change pour une organisation soumise aux deux textes.

Situation à NYANGA	Fondement possible	Commentaire
Vérifier l'identité d'un client à l'ouverture	Obligation légale	Si un texte de lutte contre le blanchiment l'impose
Tenir le compte et exécuter les opérations	Consentement	Pas de base « contrat » dans la loi
Vidéosurveillance des agences	Consentement ?	Pas d'intérêt légitime : fondement fragile
Relancer un débiteur par un prestataire	Consentement	À recueillir expressément
Démarcher un prospect au marché	Consentement	Préalable à l'inscription au cahier
Transmettre les fichiers à l'expert judiciaire	Obligation légale	Réquisition judiciaire

Tableau 2.2. Fondements des traitements de NYANGA CRÉDIT

L'absence de l'intérêt légitime a des conséquences lourdes. La vidéosurveillance, la sécurité informatique ou la prévention de la fraude, qui reposent en Europe sur l'intérêt légitime, doivent trouver au Cameroun un consentement, une obligation légale ou une mission d'intérêt public. L'auditeur ne comble pas ce vide en important le droit européen : il signale le traitement dont le fondement est incertain, le cote NEK, et recommande d'obtenir l'autorisation de l'Autorité, qui en fixera les conditions (article 19).

2.3 Finalité, Exactitude, Conservation

Jurisprudence & Droit applicable

Loi n° 2024/017, article 11 [26] : *« Les données à caractère personnel doivent être collectées pour des finalités déterminées, explicites et légitimes. Elles ne peuvent pas être ultérieurement traitées de manière incompatible avec ces finalités. »*

Le détournement de finalité est l'écart le plus fréquent, et l'un des plus graves : l'article 67 en fait un délit. Le fichier des débiteurs, constitué pour le recouvrement,

devient incompatible s'il sert à démarcher les mêmes personnes pour un nouveau crédit ; les images des caméras, prises pour la sécurité, le deviennent si elles servent à contrôler les horaires des agents.

L'article 12 impose des données « complètes, fiables et tenues à jour » et oblige à corriger ou effacer les données inexactes. L'auditeur le teste par sondage : il tire des dossiers au hasard et compare les données aux pièces justificatives.

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 13 [26] : *« (1) Les données à caractère personnel doivent être conservées pendant une durée qui n'excède pas la période nécessaire à leur traitement. (2) La période de conservation des données à caractère personnel visée à l'alinéa 1 ci-dessus est précisée dans l'autorisation de traitement des données et suivant les modalités fixées par voie réglementaire. (3) Au-delà de la période visée à l'alinéa 1 ci-dessus, les données à caractère personnel ne peuvent être conservées qu'en vue de répondre spécifiquement à un traitement à des fins historiques, statistiques ou de recherche conformément aux dispositions légales en vigueur. »*

Portée. La durée se fixe dans l'autorisation ; tant que celle-ci n'existe pas, l'organisation doit fixer elle-même une durée justifiée, et l'auditeur vérifie qu'elle l'applique. L'article 28 renvoie aussi au référentiel de l'Autorité.

2.4 L'Information des Personnes

L'article 14 exige une information « claire et transparente », et l'article 21 en fixe le contenu : elle doit être fournie « au plus tard, lors de la collecte et quels que soient les moyens employés ».

Élément exigé (article 21)	Ce que l'auditeur cherche
Identité du responsable	Nom et coordonnées sur le formulaire
Finalités déterminées	Une phrase par finalité, sans formule globale
Catégories de données	La liste des données collectées
Destinataires	Les catégories de destinataires, prestataires compris
Possibilité de refuser de figurer au fichier	Une mention explicite
Droits (accès, rectification, effacement, opposition, limitation, portabilité, décision automatisée, directives post-mortem, réclamation)	La liste des droits et la manière de les exercer
Durée de conservation	Une durée ou un critère
Transfert éventuel vers un État étranger	La mention du pays ou de la région

Tableau 2.3. Le contenu de l'information (article 21)

La liste est longue, et elle se contrôle mécaniquement : l'auditeur pose le formulaire à côté du tableau et coche. L'information peut être donnée en deux niveaux, une mention courte sur le formulaire et une notice complète remise ou accessible, pourvu que la personne la reçoive vraiment au moment de la collecte. « Disponible en agence » ne suffit pas.

2.5 Les Principes à NYANGA

Scénario Opérationnel · Mission NYANGA. Le formulaire de 2016 et les autres, 14 juillet 2026

Constatations.

- Le formulaire d'ouverture de compte porte une seule case, pré-imprimée, d'acceptation des conditions générales ; aucune finalité n'y figure. Les conditions générales ne sont pas remises.
- Les cautions signent un acte de cautionnement qui ne mentionne pas le traitement de leurs données.
- Les cahiers de prospection de trois agences tirées au hasard contiennent 1 214 noms et numéros de téléphone, sans aucune mention d'information ni de consentement.
- La base des comptes contient 61 380 comptes clos, dont 22 950 clos avant 2016, conservés avec toutes leurs données.

➢ Un sondage de 40 dossiers actifs trouve 9 numéros de téléphone erronés et 6 adresses périmées.

Analyse (confiance élevée). Le consentement des clients n'est ni spécifique, ni éclairé : il ne fonde pas les traitements au sens de l'article 9. Une partie des données de compte peut relever d'une obligation légale d'identification, que l'audit n'a pas encore établie. Les cautions et les prospects n'ont consenti à rien. Les comptes clos depuis dix ans et plus n'ont plus de finalité identifiée.

Lecture auditologique · Les principes à NYANGA CRÉDIT

Proposition	Cote	Pièce
Les clients ont donné un consentement valable	NON	Formulaire 2016
Les cautions ont consenti au traitement	NON	Acte de cautionnement
Les prospects ont consenti au traitement	NON	Cahiers de prospection
Une obligation légale fonde l'identification des clients	NEK	Texte non produit
Une durée de conservation est fixée	NON	Aucune règle écrite
Les données des comptes actifs sont exactes	NON	Sondage, 15 erreurs sur 40
L'information de l'article 21 est fournie	NON	Formulaire 2016
La vidéosurveillance repose sur un fondement valable	NEK	Pas de consentement, pas d'autorisation

Décompte. Zéro OUI, six NON, deux NEK sur huit. $\mu = 0$ · $U = 0{,}25$ · $H = 0{,}81$ **bit**

Lecture. Le domaine des principes est clair : U est faible et les écarts sont établis. L'entropie est basse parce que les réponses se concentrent sur NON. Une conclusion de non-conformité peut être donnée dès maintenant, avec deux points à instruire.

2.6 Ce que les Principes demandent à chaque Métier

Application Auditeur de la protection des données

Pour chaque traitement, demander le fondement, puis la pièce qui le prouve. Tester les cinq qualités du consentement une par une, et ne jamais importer une base légale européenne que la loi ne connaît pas.

Application Juriste conformité

Réécrire les formulaires : une finalité par phrase, une case non cochée par consentement distinct, la notice de l'article 21 remise au moment de la collecte. Identifier les textes qui imposent une obligation légale.

Application Délégué à la protection des données

Tenir, pour chaque traitement fondé sur le consentement, la preuve de son recueil et la procédure de retrait.

★ À retenir

- Les principes des articles 6 à 18 se traduisent chacun en une question d'audit fermée.
- Le consentement est la règle ; il doit être préalable, libre, éclairé, spécifique et univoque, et sa preuve incombe au responsable.
- La loi ne connaît que trois dérogations au consentement ; ni le contrat ni l'intérêt légitime n'en font partie.
- La durée de conservation se fixe dans l'autorisation ; à défaut, l'organisation doit la fixer et l'appliquer.
- À NYANGA CRÉDIT, six écarts sont établis sur huit propositions : consentements, durée, exactitude, information.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- tester les cinq qualités d'un consentement sur un formulaire ;
- expliquer pourquoi la vidéosurveillance pose un problème de fondement au Cameroun ;
- contrôler une notice d'information contre l'article 21.

✍ Exercice 2.1. Valable ou non ★☆☆

Le consentement est-il valable ? (a) une case pré-cochée « J'accepte de recevoir des offres » ; (b) un client qui dicte son accord par téléphone, enregistré ; (c) un consentement exigé pour ouvrir un compte d'épargne à une utilisation de ses données pour la prospection ; (d) un élève de 16 ans qui s'inscrit seul à un service de microcrédit scolaire.

✍ Exercice 2.2. Réécrire le formulaire ★★☆

Réécrivez le formulaire d'ouverture de compte de NYANGA CRÉDIT pour qu'il respecte les articles 9 et 21. Distinguez ce qui relève d'une obligation légale et ce qui exige un consentement.

✍ Exercice 2.3. Les comptes clos ★★☆

(a) Proposez une règle de conservation pour les comptes clos, en justifiant chaque durée.

(b) Que faire des 22 950 comptes clos avant 2016 ?

(c) Que faire des données de M. TAGNE si son compte était clos ?

✍ Exercice 2.4. Sans intérêt légitime ★★★

NOUN PAY veut analyser les transactions de ses clients pour détecter la fraude. En Europe, elle invoquerait l'intérêt légitime. Quels fondements peut-elle invoquer au Cameroun ? Quelles pièces l'auditeur demandera-t-il, et comment cotez-vous la proposition « la détection de fraude repose sur un fondement valable » si aucune autorisation n'a été délivrée ?

Note

Pour aller plus loin.

- ➢ L'ISO/IEC 29100 [23], pour les principes de consentement, de limitation de la collecte et de minimisation.
- ➢ Le RGPD [35], article 6, pour comparer les bases légales.

Note

Transition. Les écarts de NYANGA commencent à se dessiner, mais une liste de défauts n'est pas un audit. Le Chapitre 8 présente la démarche qui transforme des constats en une conclusion que l'on peut défendre.

partie II

Le Contexte International

© MaletYon

3

LES SOURCES INTERNATIONALES ET AFRICAINES

« Une loi nationale de protection des données
est rarement une invention. C'est une traduction. »

Principe du cours

Niveau : *Fondamental* • Chapitres 1 et 2 ; droit du numérique (UE MSN-2S3-JUR01)

✦ Objectifs du chapitre

- ➢ Retracer la filiation des principes de protection des données, des lignes directrices de l'OCDE à la loi n° 2024/017.
- ➢ Situer le droit à la vie privée dans les textes de droits fondamentaux qui lient le Cameroun.
- ➢ Donner le statut exact, pour le Cameroun, de chaque instrument africain et international.
- ➢ Dresser la fiche du droit d'un pays où vont des données.
- ➢ Classer un instrument comme opposable, contractuel ou comparatif avant de s'en servir dans un audit.

Avant de commencer : quatre pays, quatre droits

Yaoundé, vendredi 3 juillet 2026. Dans la salle de réunion de KORO AUDIT & CONFORMITÉ, M. NGANDO punaise une carte du monde au mur. Il y plante quatre épingles pour les trois missions du cabinet. Abidjan, où l'éditeur du logiciel bancaire de NYANGA CRÉDIT héberge les comptes. Casablanca, où un centre d'appels répond la nuit aux clients de NOUN PAY. Francfort, où se trouvent les serveurs de la même NOUN PAY. La Virginie, d'où lui parviennent sa messagerie et sa mesure d'audience.

Un stagiaire demande quel droit s'applique à tout cela. « Le nôtre d'abord, répond M. NGANDO, puisque les personnes sont ici. Mais chaque épingle a aussi son droit et certains de ces droits suivent les données jusqu'à nous. » Il ajoute une cinquième épingle sur Strasbourg et une sixième sur Addis-Abeba. « Celles-là n'hébergent rien.

© MaletYon

Elles expliquent pourquoi nos lois se ressemblent. »

★ Attention

Violation typique. Citer dans un rapport d'audit un instrument international comme s'il obligeait l'organisation, sans avoir vérifié que le Cameroun l'a ratifié ni qu'il vise ce type d'acteur.

Règle : avant de s'appuyer sur un texte, l'auditeur établit son statut. Il est opposable, parce que le Cameroun y est Partie ou qu'une loi le reprend. Il est contractuel, parce qu'un partenaire l'impose par contrat. Ou il est comparatif et ne sert alors qu'à éclairer et à proposer.

3.1 La Filiation des Principes

Les principes que le Chapitre 2 a lus dans les articles 6 à 18 de la loi ont une histoire. Ils ont été formulés pour la première fois à l'échelle internationale en 1980 et n'ont guère changé de substance depuis. Les lois nationales les internalisent, chacune avec ses ajouts.

3.1.1 Les lignes directrices de l'OCDE

En 1980, l'Organisation de coopération et de développement économiques adopte des lignes directrices sur la protection de la vie privée et les flux transfrontières de données [34]. Elles ne sont pas un traité. Ce sont des recommandations, révisées en 2013, que les États membres s'engagent à suivre. Elles énoncent huit principes qui forment encore le socle de presque toutes les lois du monde.

Principe de l'OCDE (paraphrasé)	Idée	Loi n° 2024/017
Limitation de la collecte	Collecter loyalement, avec le consentement ou l'information de la personne	Art. 9, 10
Qualité des données	Des données exactes, complètes et à jour	Art. 12
Spécification des finalités	Dire pourquoi l'on collecte, au plus tard à la collecte	Art. 11, 21
Limitation de l'utilisation	Ne pas détourner les données de leur finalité	Art. 11, 67
Garanties de sécurité	Protéger contre la perte, l'accès et la divulgation	Art. 7, 15, 27
Transparence	Faire connaître l'existence et la nature des traitements	Art. 14, 29
Participation individuelle	Permettre à la personne d'accéder à ses données et de les contester	Art. 37 à 46
Responsabilité	Rendre le responsable comptable du respect des principes	Art. 20, 54 à 71

Tableau 3.1. Les huit principes de l'OCDE et leur écho dans la loi

Le Cameroun n'est pas membre de l'OCDE. Le tableau ne décrit donc pas une obligation, il décrit une parenté. Un auditeur qui la connaît lit plus vite une loi étrangère et repère plus vite ce que la sienne a de particulier.

3.1.2 Les principes directeurs des Nations Unies

L'Assemblée générale des Nations Unies a adopté en 1990 des principes directeurs pour la réglementation des fichiers informatisés contenant des données à caractère personnel [32]. Le texte reprend la licéité, la loyauté, l'exactitude, la finalité, l'accès et la sécurité. Il ajoute deux idées que l'on retrouve dans la loi camerounaise : la non-discrimination, à l'article 17 et l'existence d'une autorité de contrôle indépendante, à l'article 53. C'est une résolution, qui recommande sans lier.

3.1.3 La Convention 108 et sa version modernisée

La Convention du Conseil de l'Europe du 28 janvier 1981, dite Convention 108 [10], est le premier traité contraignant consacré à la protection des données. Elle est ouverte aux États qui ne sont pas membres du Conseil de l'Europe et plusieurs États africains y ont adhéré, parmi lesquels le Maroc, le Sénégal, la Tunisie, Maurice et le Cap-Vert. Le Cameroun n'y est pas Partie.

Un protocole de 2018 la modernise : c'est la Convention 108+ [12]. Il ajoute la notification des violations, la protection des données dès la conception et des droits face

aux décisions automatisées. Il n'entrera en vigueur qu'à la trente-huitième ratification. En 2026, le Conseil de l'Europe en comptait trente-quatre.

Note

Pourquoi un traité européen intéresse l'auditeur camerounais. Le centre d'appels de NOUN PAY est au Maroc, qui est Partie à la Convention 108. Cette adhésion est un fait vérifiable sur le site du dépositaire. Elle ne vaut pas reconnaissance par l'Autorité camerounaise, mais elle entre dans la description du pays de destination que l'auditeur joint au dossier de transfert (section 3.4).

3.2 Le Droit à la Vie Privée

La protection des données procède d'un droit plus ancien, le droit au respect de la vie privée. Quatre textes le portent pour le Cameroun.

Texte	Ce qu'il protège	Statut
Déclaration universelle des droits de l'homme (1948), article 12	Vie privée, famille, domicile, correspondance	Référence, visée par le préambule de la Constitution
Pacte international relatif aux droits civils et politiques (1966), article 17	Les mêmes, contre les immixtions arbitraires ou illégales	Traité, opposable
Constitution, préambule	Inviolabilité du domicile, secret de toute correspondance	Norme suprême
Charte africaine des droits et du bien-être de l'enfant (1990), article 10	Vie privée de l'enfant	Traité, opposable

Tableau 3.2. Le droit à la vie privée dans les textes de droits fondamentaux

La Charte africaine des droits de l'homme et des peuples de 1981 ne contient pas d'article consacré à la vie privée. Le fait est souvent ignoré. En Afrique, la protection des données s'est donc construite par des textes spécialisés plutôt que par la Charte.

Ces textes ne fournissent pas de critères d'audit : ils sont trop généraux pour être cotés. Ils servent au juge, qui peut y rattacher une atteinte que la loi spéciale ne prévoit pas et ils rappellent à l'auditeur que la personne concernée est titulaire d'un droit fondamental avant d'être une ligne dans un registre.

3.3 Le Cadre Africain

3.3.1 La Convention de Malabo

La Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel a été adoptée à Malabo le 27 juin 2014 [13]. Elle traite trois

sujets : les transactions électroniques, la protection des données et la cybersécurité. Son chapitre II demande à chaque État de se doter d'un cadre légal, d'une autorité nationale indépendante, de formalités préalables aux traitements, de principes et de droits proches de ceux du Tableau 3.1.

Elle est entrée en vigueur le 8 juin 2023, trente jours après le dépôt du quinzième instrument de ratification. Le Cameroun l'a signée et ne l'avait pas ratifiée à la date de ce cours. Elle ne l'oblige donc pas encore.

Sa lecture éclaire pourtant deux choix de la loi n° 2024/017. Le régime d'autorisation préalable de l'article 19 prolonge les formalités préalables de la Convention. La liste ouverte des données sensibles reprend l'esprit de la sienne. Le législateur camerounais a internalisé un texte qu'il n'avait pas ratifié.

3.3.2 Le cadre stratégique de l'Union africaine

En 2022, l'Union africaine a adopté un cadre stratégique en matière de données [41]. Ce n'est pas un texte normatif. Il fixe une orientation : des données qui circulent entre États africains, des autorités qui coopèrent, des règles nationales qui convergent. L'auditeur le cite quand une organisation invoque la souveraineté des données pour refuser tout hébergement hors du pays, ou au contraire le marché africain pour justifier un transfert. Dans les deux cas, le cadre donne le vocabulaire et non la règle.

3.3.3 Les textes régionaux

L'Afrique de l'Ouest a pris de l'avance. L'acte additionnel de la CEDEAO du 16 février 2010 [1] oblige ses États membres à légiférer et la plupart l'ont fait. Le Cameroun n'appartient pas à la CEDEAO ; l'acte ne lui est pas applicable.

En Afrique centrale, il n'existe pas de texte équivalent consacré aux données personnelles. La CEMAC a adopté le 19 décembre 2008 cinq directives sur les communications électroniques. L'une d'elles, la directive n° 07/08-UEAC-133-CM-18, protège les droits des utilisateurs et demande aux États de garantir la confidentialité des communications et des données de trafic [4]. La loi camerounaise n° 2010/013 l'a transposée. Le secteur bancaire et celui des paiements relèvent en outre de règlements communautaires et de la Commission bancaire de l'Afrique centrale, qui encadrent le secret et la conservation des données des clients (Chapitre 7). Pour une microfinance ou une fintech, ces textes sont opposables et s'appliquent directement dans leur domaine.

Note

Les autorités se parlent. Les autorités africaines de protection des données se sont réunies en 2016 dans un réseau, le RAPDP. Quand l'Autorité camerounaise sera organisée, c'est là qu'elle trouvera ses homologues. La loi lui donne mission de coopérer avec elles (article 53).

3.4 Le Droit des Pays où Vont les Données

L'article 32 de la loi subordonne tout transfert à la vérification que le pays de destination « offre un niveau de protection suffisant ». C'est à l'Autorité de l'apprécier et le Chapitre 14 dira comment coter tant qu'elle ne l'a pas fait. L'organisation, elle, doit préparer la description du pays. L'auditeur vérifie que cette description existe et qu'elle repose sur des sources primaires.

Démarche d'audit

Dresser la fiche d'un pays de destination.

1. La loi générale de protection des données : référence, date, champ.
2. L'autorité de contrôle : nom, indépendance, pouvoirs de sanction.
3. Les engagements internationaux : Convention 108, Convention de Malabo, autres.
4. Les reconnaissances reçues d'autres autorités, par exemple une décision d'adéquation de l'Union européenne.
5. L'accès des autorités publiques aux données et les recours ouverts aux étrangers.
6. Les sources consultées et la date de consultation.

Pays	Loi générale	Autorité	Engagements
Côte d'Ivoire	Loi n° 2013-450 du 19 juin 2013 [36]	Autorité de régulation des télécommunications (ARTCI)	Malabo ratifiée ; CEDEAO
Maroc	Loi n° 09-08 du 18 février 2009 [38]	Commission nationale (CNDP)	Convention 108
Union européenne	RGPD (Chapitre 4)	Une autorité par État, un comité européen	Convention 108
États-Unis	Pas de loi fédérale générale ; lois sectorielles et lois d'États	Pas d'autorité unique	Aucun traité de protection des données

Tableau 3.3. Les quatre destinations des données des trois missions

La dernière ligne mérite un mot. Les États-Unis n'ont pas de loi générale comparable aux trois autres. La protection y dépend du secteur (santé, finance, enfants) et de l'État (la Californie a la loi la plus connue). Les entreprises américaines s'appuient souvent sur des cadres volontaires, dont celui du NIST, que le Chapitre 5 présente. Une fiche pays honnête l'écrit sans juger : l'absence de loi générale est un fait, pas une cote.

Aucun pays d'Afrique subsaharienne ne bénéficiait en 2026 d'une décision d'adéquation de l'Union européenne. Les données qui partent d'Europe vers le Cameroun voyagent donc sous clauses contractuelles, ce qui aura des conséquences pour les sous-traitants camerounais de clients européens (Chapitre 4).

3.5 La Coopération Pénale

Les données franchissent aussi les frontières à la demande des enquêteurs. La Convention de Budapest sur la cybercriminalité de 2001 [11] organise cette coopération : conservation rapide de données stockées à l'étranger, entraide, points de contact disponibles en permanence. Le Cameroun y est Partie depuis le 15 décembre 2023 et elle est entrée en vigueur à son égard le 1er avril 2024, d'après les travaux de l'auteur et de ses coauteurs [29].

Pour l'auditeur de la protection des données, la Convention a deux effets. Elle fonde des demandes que l'organisation auditée peut recevoir et qu'elle doit savoir traiter sans violer l'article 32. Elle rencontre aussi le régime d'autorisation préalable des transferts, rencontre que le Chapitre 19 étudie comme une tension transfrontalière.

3.6 Le Statut de Chaque Instrument

Instrument	Statut pour le Cameroun	Usage dans l'audit
Pacte de 1966, article 17	Opposable	Fondement général, non coté
Convention de Budapest (2001)	Opposable depuis 2024	Demandes des autorités, coopération pénale
Textes CEMAC et COBAC	Opposables dans leur domaine	Critères sectoriels (banque, paiement, télécommunications)
Convention de Malabo (2014)	Signée, non ratifiée	Comparatif et prospectif
Convention 108 et 108+	Non Partie	Comparatif ; fiche des pays Parties
Acte additionnel CEDEAO (2010)	Non applicable	Comparatif ; fiche des pays de la CEDEAO
Lignes directrices de l'OCDE	Non membre	Comparatif
Principes directeurs de l'ONU (1990)	Recommandation	Comparatif
Cadre de l'UA sur les données (2022)	Orientation politique	Vocabulaire
RGPD (UE, 2016)	Voir Chapitre 4	Opposable à certains acteurs, contractuel pour d'autres

Tableau 3.4. Les instruments internationaux et leur statut

Trois statuts suffisent à l'auditeur.

- **Opposable.** Le texte lie l'organisation. Un écart se cote NON et se rattache à l'article.
- **Contractuel.** Le texte ne lie pas l'organisation par lui-même, mais un contrat le lui impose. L'écart est un manquement au contrat, que l'auditeur cote si le contrat figure parmi ses critères.
- **Comparatif.** Le texte n'oblige pas. Il sert à interpréter, à combler un silence par un critère de substitution déclaré, ou à proposer une bonne pratique. Il ne fonde jamais un NON à lui seul.

Un statut change. La ratification de Malabo ferait passer la Convention de comparative à opposable. L'auditeur date donc le tableau et le revoit à chaque mission.

3.7 La Carte des Trois Missions

Scénario Opérationnel · Missions NYANGA, MBOLO et NOUN PAY. La carte de M. NGANDO, 3 juillet 2026

Constatations.

- NYANGA CRÉDIT : un flux vers la Côte d'Ivoire (hébergement du logiciel bancaire). Aucune description du droit ivoirien au dossier. Établissement soumis aux textes de la COBAC.
- CENTRE MÉDICAL MBOLO : aucun flux hors du Cameroun identifié à ce stade. Prestataire à Douala.
- NOUN PAY : flux vers l'Union européenne, les États-Unis et le Maroc, un quatrième vers un pays inconnu (les selfies). Aucune fiche pays. Établissement de paiement soumis aux textes communautaires.

Analyse (confiance élevée sur les flux déclarés, faible sur leur exhaustivité). Aucune des trois organisations n'a décrit le droit des pays où vont ses données. Deux d'entre elles relèvent de textes communautaires qu'elles n'ont pas rapprochés de la loi n° 2024/017.

Lecture auditologique · Le dossier international de NOUN PAY

Proposition	Cote	Pièce
Les pays de destination sont identifiés	NON	Selfies, pays inconnu
Une fiche existe pour chaque pays de destination	NON	Aucune fiche
Les fiches reposent sur des sources primaires datées	NON	Sans objet, aucune fiche
Les textes communautaires applicables sont recensés	NON	Aucune liste
Le Maroc est Partie à la Convention 108	OUI	Liste du dépositaire
Le niveau de protection de chaque pays est reconnu suffisant	NEK	Liste de l'Autorité non publiée

Décompte. Un OUI, quatre NON, un NEK sur six. $\mu = 0{,}17$ · $U = 0{,}17$ · $H = 1{,}25$ **bit**

Lecture. Le seul OUI ne doit rien à l'entreprise : c'est un fait de droit international que l'auditeur a vérifié lui-même. Le NEK est de critère. Les quatre NON relèvent tous de la préparation du dossier, qui dépend de NOUN PAY seule.

3.8 Ce que les Sources demandent à chaque Métier

Application Juriste conformité

Tenir le tableau des instruments avec leur statut et leur date de vérification. Aller au dépositaire : l'Union africaine pour Malabo, le Conseil de l'Europe pour la Convention 108 et pour Budapest.

Application Auditeur de la protection des données

Écrire dans le plan d'audit le statut de chaque texte retenu comme critère. Ne jamais coter NON sur la seule foi d'un texte comparatif.

Application Délégué à la protection des données

Tenir une fiche par pays de destination et la joindre au registre. La mettre à jour quand un prestataire change de région d'hébergement.

★ À retenir

➢ Les principes de la loi n° 2024/017 descendent des huit principes de l'OCDE de 1980, repris par l'ONU, le Conseil de l'Europe et l'Union africaine.

- Le droit à la vie privée est garanti par le Pacte de 1966 et par le préambule de la Constitution ; la Charte africaine de 1981 ne le mentionne pas.
- La Convention de Malabo est en vigueur depuis le 8 juin 2023. Le Cameroun l'a signée sans la ratifier : elle reste comparative.
- Un instrument est opposable, contractuel ou comparatif. Seuls les deux premiers fondent une cote NON.
- L'organisation qui transfère des données tient une fiche du droit de chaque pays de destination, fondée sur des sources primaires.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- rattacher un article de la loi à un principe de l'OCDE ;
- dire pourquoi la Convention de Malabo ne fonde pas un constat d'audit au Cameroun ;
- dresser la fiche d'un pays de destination.

✍ Exercice 3.1. Quel statut ★☆☆

Donnez le statut (opposable, contractuel, comparatif) de chaque texte pour NYANGA CRÉDIT : (a) la Convention de Malabo ; (b) le Pacte de 1966 ; (c) l'acte additionnel de la CEDEAO ; (d) un règlement de la COBAC ; (e) les lignes directrices de l'OCDE.

✍ Exercice 3.2. La filiation ★★☆

Pour chacun des articles suivants de la loi n° 2024/017, nommez le principe de l'OCDE qu'il internalise, puis dites ce que la loi camerounaise y ajoute : (a) article 9 ; (b) article 13 ; (c) article 19 ; (d) article 27.

✍ Exercice 3.3. La fiche pays ★★☆

Dressez, en suivant les six rubriques de la procédure, la fiche de la Côte d'Ivoire pour le dossier de transfert de NYANGA CRÉDIT. Indiquez pour chaque rubrique la source primaire que vous consulteriez et ce que vous écrivez si vous ne la trouvez pas.

✍ Exercice 3.4. Si le Cameroun ratifiait ★★★

Supposez que le Cameroun dépose son instrument de ratification de la Convention de Malabo.

(a) À quelle date la Convention entrerait-elle en vigueur à son égard ? Quelle source

consultez-vous pour le savoir ?

(b) Quelles lignes du Tableau 3.4 changent ?

(c) Un audit en cours doit-il modifier ses critères ? Rédigez la note au commanditaire.

Note

Pour aller plus loin.

- ➢ Les lignes directrices de l'OCDE [34], pour la formulation d'origine des huit principes.
- ➢ La Convention de Malabo [13], chapitre II et sa liste d'état tenue par l'Union africaine.
- ➢ La Convention 108+ [12] et son rapport explicatif.

Note

Transition. Parmi tous ces textes, un seul suit les données au-delà de ses frontières avec assez de force pour atteindre une entreprise de Bafoussam : le règlement européen. C'est l'objet du Chapitre 4.

4

LE RGPD ET SON EFFET HORS D'EUROPE

« Le règlement européen ne s'arrête pas aux frontières de l'Europe. Il ne remplace pas pour autant la loi du pays où l'on est. »

Principe du cours

Niveau : *Fondamental* • Chapitres 2 et 3

✦ Objectifs du chapitre

- ➢ Présenter l'économie du RGPD en une quinzaine d'articles utiles à l'auditeur.
- ➢ Dire quand le RGPD oblige une organisation établie au Cameroun, en appliquant son article 3.
- ➢ Distinguer les trois voies d'exposition : directe, contractuelle, en cascade.
- ➢ Comparer la loi n° 2024/017 et le RGPD point par point, sans prêter à l'une le contenu de l'autre.
- ➢ Coter une même exigence contre les deux textes quand les deux s'appliquent.

Avant de commencer : « c'est le RGPD camerounais »

Bafoussam, lundi 3 août 2026. Le directeur général de NYANGA CRÉDIT a reçu d'un cabinet de conseil une offre de « mise en conformité RGPD camerounais » en douze semaines. Le document promet la désignation d'un délégué à la protection des données « obligatoire », une procédure de notification des violations « sous 72 heures » et la constitution d'un dossier d'« intérêt légitime » pour la vidéosurveillance.

M. NGANDO pose la proposition à côté du texte de la loi. Aucune de ces trois affirmations ne s'y trouve. La loi ne connaît pas de délégué obligatoire, elle dit « sans délai » et non 72 heures et elle ignore l'intérêt légitime. L'offre ne dit pas un mot, en revanche, de l'autorisation préalable de l'article 19.

Le même jour, à quelques rues de là, M. NJOYA pose à Mme BELLO la question inverse. NOUN PAY[1] a ouvert en mars un service de transfert d'argent pour les Came-

[1] NOUN PAY, son service NOUN DIASPORA, MEDISOFT SARL et la clinique bruxelloise citée plus bas sont fictifs.

rounais de France et de Belgique. « Eux sont en Europe. Est-ce que leur règlement nous concerne ? » La réponse est oui.

★ Attention

Violation typique. Deux erreurs symétriques. Lire la loi camerounaise à travers le RGPD et lui attribuer des obligations européennes qu'elle ne contient pas. Ou croire qu'une entreprise camerounaise échappe au RGPD parce qu'elle n'a aucun bureau en Europe.

Règle : l'auditeur détermine d'abord, traitement par traitement, quel texte s'applique. La loi n° 2024/017 s'applique à tout traitement visé par son article 2. Le RGPD s'y ajoute quand son article 3 est rempli ou qu'un contrat l'impose. Aucun des deux ne dispense de l'autre.

4.1 Le RGPD en Quinze Articles

Le règlement (UE) 2016/679 [35] est applicable depuis le 25 mai 2018 dans tous les États de l'Union européenne. Il compte quatre-vingt-dix-neuf articles. L'auditeur en retient une quinzaine.

Art.	Objet	Ce qu'il faut en retenir (paraphrasé)
3	Champ territorial	Établissement dans l'Union, ou ciblage de personnes qui s'y trouvent
5	Principes	Sept principes, dont la minimisation et la responsabilité
6	Bases légales	Six bases, dont le contrat et l'intérêt légitime
9	Catégories particulières	Liste fermée de données sensibles
12 à 22	Droits	Information, accès, rectification, effacement, limitation, portabilité, opposition ; réponse en un mois
24, 25	Responsabilité	Démontrer la conformité ; protection dès la conception
27	Représentant	Obligatoire pour l'acteur hors Union visé par l'article 3
28	Sous-traitant	Contrat écrit au contenu imposé
30	Registre	Tenu par le responsable et par le sous-traitant
32	Sécurité	Mesures adaptées au risque
33, 34	Violations	Autorité en 72 heures ; personnes si le risque est élevé
35, 36	Analyse d'impact	Obligatoire si le risque est élevé ; consultation de l'autorité
37 à 39	Délégué	Obligatoire dans trois cas
44 à 49	Transferts	Adéquation, garanties appropriées, dérogations
83	Amendes	Jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires mondial

Tableau 4.1. Quinze articles du RGPD pour l'auditeur

Le règlement repose sur une idée que la loi camerounaise n'a pas retenue : la **responsabilité**. Il a supprimé les formalités préalables auprès de l'autorité. En échange, le responsable doit pouvoir démontrer à tout moment qu'il respecte le texte. La loi n° 2024/017 fait le choix opposé, celui du contrôle préalable par l'autorisation (Chapitre 6).

4.2 Quand le RGPD Oblige une Organisation Camerounaise

L'article 3 du règlement fixe son champ territorial. Il retient deux critères, dont le second vise précisément les acteurs établis hors de l'Union.

1. **L'établissement.** Le règlement s'applique aux traitements faits dans le cadre des activités d'un établissement situé dans l'Union, que le traitement ait lieu ou non dans l'Union. Une filiale, une succursale ou un simple bureau stable suffisent.

2. **Le ciblage.** Il s'applique aussi à un responsable ou à un sous-traitant non établi dans l'Union, lorsque le traitement est lié à l'offre de biens ou de services à des personnes qui se trouvent dans l'Union, ou au suivi de leur comportement dans l'Union.

Le critère du ciblage tient à la localisation de la personne au moment du traitement, pas à sa nationalité. Un Camerounais qui vit à Lyon est protégé par le RGPD. Un Français en visite à Kribi ne l'est pas pour les traitements d'une entreprise camerounaise qui ne vise pas l'Europe ; il l'est en revanche par la loi camerounaise, dont l'article 2 protège les personnes « en transit ».

Le Comité européen de la protection des données a précisé ce qu'est une offre [6]. Un site simplement accessible depuis l'Europe ne suffit pas. Il faut des indices d'une intention de s'adresser à des personnes dans l'Union.

Indice de ciblage	À NOUN DIASPORA
Prix affichés dans une monnaie de l'Union	Frais affichés en euros
Langue ou pays cités dans l'offre	« Envoyez depuis la France et la Belgique »
Publicité achetée pour un public de l'Union	Campagnes sur les réseaux sociaux, zone France et Belgique
Moyens de paiement de l'Union acceptés	Cartes bancaires européennes
Mention de clients de l'Union	Témoignages de clients de Lyon et de Liège

Tableau 4.2. Les indices de ciblage, appliqués au service de NOUN PAY

Les cinq indices sont réunis. NOUN PAY est un responsable de traitement non établi dans l'Union qui offre un service à des personnes qui s'y trouvent. Le règlement s'applique aux traitements de NOUN DIASPORA et à eux seuls : le microcrédit proposé aux clients de Bafoussam n'en relève pas.

L'article 27 en tire une première conséquence. L'acteur ainsi visé désigne par écrit un représentant établi dans l'un des États où se trouvent les personnes. Le représentant reçoit les demandes des personnes et de l'autorité.

4.3 Trois Voies d'Exposition

Voie	Situation	Conséquence
Directe	L'organisation camerounaise cible des personnes dans l'Union (NOUN DIASPORA)	Le RGPD lui est opposable pour ces traitements ; représentant à désigner
Contractuelle	Elle est sous-traitante d'un responsable européen	Contrat de l'article 28 et clauses contractuelles types pour le transfert vers le Cameroun
En cascade	Elle confie ses données à un prestataire établi dans l'Union	Le prestataire applique ses obligations de sous-traitant et les répercute dans son contrat

Tableau 4.3. Trois manières de rencontrer le RGPD depuis le Cameroun

4.3.1 La voie contractuelle

MEDISOFT SARL, l'éditeur de Douala qui héberge le dossier patient de MBOLO, a signé en 2026 un contrat de télémaintenance avec une clinique de Bruxelles. Ses techniciens consultent depuis Douala des données de patients belges. La clinique est responsable de traitement, MEDISOFT sous-traitant.

La clinique ne peut pas transférer ces données au Cameroun sans garantie : aucune décision d'adéquation ne couvre le pays (Chapitre 3). Elle recourt donc aux clauses contractuelles types adoptées par la Commission européenne en 2021 [8]. MEDISOFT les signe telles quelles, car elles ne se négocient pas. Elles lui imposent de n'agir que sur instruction, d'assurer la sécurité, de signaler toute violation, d'accepter des audits et de dire si le droit camerounais permet à une autorité d'accéder aux données.

Le RGPD est ici **contractuel** au sens du Chapitre 3. L'auditeur de MEDISOFT cote ces engagements si le contrat figure dans ses critères.

4.3.2 La voie en cascade

L'hébergeur de NOUN PAY est établi dans l'Union. Il est soumis au RGPD pour ses propres obligations de sous-traitant, quel que soit le pays de son client. Son contrat type reprend donc les clauses de l'article 28 et NOUN PAY les a acceptées en ouvrant son compte. L'effet est favorable : NOUN PAY dispose d'un droit d'audit, d'un engagement de notification et d'une liste des sous-traitants ultérieurs qu'elle n'aurait peut-être pas obtenus seule.

Un point reste à surveiller. Quand l'hébergeur renvoie les données vers le Cameroun, par exemple pour qu'un agent de Bafoussam les consulte, il fait lui-même un transfert hors de l'Union. Il peut exiger pour cela des garanties de son client.

4.4 La Loi et le RGPD, Point par Point

Point	Loi n° 2024/017	RGPD
Champ	Personnes établies, résidant ou en transit au Cameroun ; acteurs établis au Cameroun (art. 2)	Établissement dans l'Union ; ciblage de personnes dans l'Union (art. 3)
Formalité préalable	Autorisation pour tout traitement (art. 19)	Aucune, sauf consultation préalable (art. 36)
Bases du traitement	Consentement et trois dérogations (art. 9)	Six bases, dont contrat et intérêt légitime (art. 6)
Minimisation	Pas de principe général	Principe (art. 5)
Délégué	Non prévu	Obligatoire dans trois cas (art. 37)
Registre	Responsable et sous-traitant (art. 29)	Les deux, avec une exemption limitée pour les petites structures (art. 30)
Évaluation d'impact	Si risque élevé ; modalités réglementaires (art. 33)	Si risque élevé ; critères publiés (art. 35)
Violation	« Sans délai », à l'Autorité et à la personne, pour toute violation (art. 22)	72 heures à l'autorité ; personnes si risque élevé (art. 33, 34)
Sous-traitant	Mêmes obligations que le responsable (art. 20)	Obligations propres, plus limitées (art. 28)
Responsables conjoints	Convention rendue publique (art. 31)	Grandes lignes mises à disposition (art. 26)
Transferts	Autorisation, quatre vérifications (art. 32)	Adéquation, garanties, dérogations (art. 44 à 49)
Décision automatisée	Droit d'opposition ; profilage puni (art. 44, 65)	Encadrée, non interdite (art. 22)
Données sensibles	Liste ouverte, dont transactions bancaires et origine régionale (art. 5)	Liste fermée (art. 9)
Délai de réponse aux demandes	Renvoyé à un texte réglementaire (art. 47)	Un mois, prolongeable (art. 12)
Sanction maximale	Un milliard de francs CFA, personne morale (art. 71)	4 % du chiffre d'affaires mondial (art. 83)

Tableau 4.4. Quinze points de comparaison

Trois lectures de ce tableau sont utiles.

La loi camerounaise est **plus stricte** sur six points : l'autorisation préalable, le petit nombre de fondements, la notification de toute violation, les obligations du sous-traitant, la publicité de la convention entre responsables conjoints et la liste des données sensibles. Une organisation conforme au RGPD n'est donc pas conforme à la loi.

Elle est **moins précise** sur quatre : la minimisation, les délais, les critères du risque élevé et le contenu de la notification. Là, le RGPD fournit des repères que l'auditeur peut emprunter.

Elle est **simplement différente** sur le reste. Le délégué n'existe pas dans la loi et sa désignation ne peut être qu'une bonne pratique.

4.5 Emprunter sans Confondre

Le Chapitre 8 montrera qu'un critère renvoyant à un texte non publié se remplace par un **critère de substitution** déclaré. Le droit européen est la première source de ces critères, parce qu'il est précis, publié et commenté. Trois emprunts reviennent dans ce cours.

Silence de la loi	Repère européen	Formulation dans le rapport
Délai de réponse aux demandes (art. 47)	Un mois (RGPD, art. 12)	« 30 jours (critère de l'audit) »
Critères du risque élevé (art. 33)	Liste du Comité européen, méthode de la CNIL [9]	« Critères déclarés au plan d'audit »
Contenu de la notification (art. 22)	Rubriques des articles 33 et 34	« Contenu minimal retenu par l'audit »

Tableau 4.5. Trois emprunts et leur formulation

La règle tient en une phrase. Un emprunt se déclare dans le plan d'audit, se nomme dans le rapport et ne se présente jamais comme une obligation légale camerounaise. L'emprunt ne joue que dans un sens : il précise un silence, il n'allège jamais une exigence de la loi. On n'importe pas l'intérêt légitime.

4.6 La Double Conformité

Pour NOUN DIASPORA, les deux textes s'appliquent au même traitement. Le client est à Lyon, donc protégé par le RGPD. NOUN PAY est établie au Cameroun, donc soumise à la loi par son article 2. L'auditeur cote chaque exigence deux fois.

Exigence	Critère camerounais	Critère européen	Règle
Fondement du traitement	Consentement ou dérogation (art. 9)	L'une des six bases (art. 6)	Le plus strict
Notification d'une violation	Sans délai, Autorité et personne (art. 22)	72 heures, autorité ; personne si risque élevé	Les deux
Formalité préalable	Autorisation (art. 19)	Aucune	Camerounais
Représentant	Aucun	Désignation écrite (art. 27)	Européen

Tableau 4.6. Une exigence, deux critères

Quand les deux textes demandent la même chose à des degrés différents, l'organisation satisfait le plus strict et satisfait ainsi les deux. Quand ils demandent des choses différentes, elle fait les deux. Les deux textes ne se contredisent sur aucun de ces points : aucun n'interdit ce que l'autre impose.

Scénario Opérationnel · Mission NOUN PAY. NOUN DIASPORA face au RGPD, septembre 2026

Constatations.

- 6 840 clients inscrits depuis la France et la Belgique entre mars et août 2026 ; frais en euros, publicité ciblée sur ces deux pays.
- Aucun représentant désigné dans l'Union. Aucune mention du RGPD dans la notice de l'application.
- La vérification d'identité de ces clients passe par le même prestataire de selfies, dont le pays reste inconnu.
- Le contrat de l'hébergeur contient les clauses de l'article 28.
- Aucune analyse d'impact ; aucune procédure de notification.

Analyse (confiance élevée). Le service remplit le critère du ciblage. NOUN PAY l'a lancé sans se demander quel droit protégeait ses clients. Le seul point conforme lui vient de son hébergeur.

Lecture auditologique · NOUN DIASPORA, exigences du RGPD

Exigence	Cote	Preuve
Un représentant est désigné dans l'Union (art. 27)	NON	Aucune désignation
Chaque traitement a une base légale identifiée (art. 6)	NON	Case unique
L'information de l'article 13 est fournie	NON	Notice de l'application
Un registre est tenu (art. 30)	NON	Aucun registre
Une analyse d'impact a été conduite (art. 35)	NON	Aucune
Une procédure permet de notifier en 72 heures (art. 33)	NON	Aucune
Le contrat de l'hébergeur contient les clauses de l'article 28	OUI	Contrat, annexe données
Un délégué doit être désigné (art. 37)	NEK	Suivi « à grande échelle » à apprécier

Décompte. Un OUI, six NON, un NEK sur huit.

$\mu = 0{,}125$ · $U = 0{,}125$ · $H = 1{,}06$ **bit**

Lecture. Le domaine est clair et non conforme. Ces huit cotes s'ajoutent à celles de la loi camerounaise, elles ne les remplacent pas : le même service reçoit par ailleurs un NON au titre de l'article 19.

4.7 Ce que le RGPD demande à chaque Métier

Application Auditeur de la protection des données

Poser la question de l'article 3 pour chaque traitement et consigner la réponse au plan d'audit. Tenir deux colonnes de cotes quand les deux textes s'appliquent.

Application Juriste conformité

Lire avant signature les clauses qu'un client ou un prestataire européen impose. Elles créent des obligations d'audit, de notification et de coopération que l'organisation devra tenir.

Application Responsable de traitement

Décider en connaissance de cause d'ouvrir un service à des personnes en Europe. Le marché de la diaspora emporte le RGPD avec lui.

★ À retenir

- Le RGPD repose sur la responsabilité du responsable, la loi n° 2024/017 sur l'autorisation préalable.
- Son article 3 l'applique à une organisation camerounaise qui cible des personnes se trouvant dans l'Union ; l'article 27 lui impose alors un représentant.
- Trois voies d'exposition : directe, contractuelle, en cascade.
- La loi camerounaise est plus stricte que le RGPD sur six points et moins précise sur quatre ; être conforme à l'un ne dit rien de l'autre.
- Un repère européen s'emprunte comme critère de substitution déclaré, pour préciser un silence, jamais pour alléger la loi.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- appliquer les indices de ciblage à un service en ligne ;
- citer trois points où la loi camerounaise est plus stricte que le RGPD ;
- formuler dans un rapport un critère emprunté au droit européen.

✍ Exercice 4.1. Le RGPD s'applique-t-il ★☆☆

Dites si le RGPD s'applique et par quelle voie : (a) NYANGA CRÉDIT gère les comptes de ses clients de l'Ouest ; (b) NOUN PAY propose NOUN DIASPORA ; (c) MEDISOFT assure la télémaintenance d'une clinique de Bruxelles ; (d) un touriste allemand est soigné à MBOLO ; (e) NOUN PAY héberge ses données à Francfort.

✍ Exercice 4.2. L'offre du cabinet ★★☆

Reprenez l'offre de « mise en conformité RGPD camerounais » reçue par NYANGA. Corrigez ses trois affirmations et ajoutez les trois obligations camerounaises qu'elle omet, articles à l'appui.

✍ Exercice 4.3. Deux colonnes ★★☆

NOUN PAY découvre le 2 octobre qu'un fichier de 1 200 clients de NOUN DIASPORA a été envoyé par erreur à un partenaire. Dressez le tableau des obligations de notification au titre de l'article 22 de la loi et des articles 33 et 34 du RGPD : destinataires, délais, contenu. Que fait NOUN PAY pour satisfaire les deux textes ?

✍ Exercice 4.4. Les clauses de MEDISOFT ★★★

Les clauses signées par MEDISOFT l'obligent à dire si le droit camerounais permet à une autorité publique d'accéder aux données des patients belges.

(a) Quels textes camerounais MEDISOFT doit-il examiner pour répondre ? Appuyez-vous sur le Chapitre 7.

(b) Le transfert de la Belgique vers le Cameroun est-il aussi un traitement soumis à l'article 19 de la loi n° 2024/017 ?

(c) Comment l'auditeur de MEDISOFT cote-t-il la proposition « MEDISOFT respecte ses engagements envers la clinique » ?

● Note

Pour aller plus loin.

- Le RGPD [35], articles 3, 27, 28 et 44 à 49.
- Les lignes directrices 3/2018 du Comité européen sur le champ territorial [6].
- Les recommandations 01/2020 sur les transferts [7].

● Note

Transition. Le RGPD est une loi. D'autres référentiels n'obligent personne et organisent pourtant le travail de milliers d'entreprises : le cadre du NIST et les

normes ISO. C'est l'objet du Chapitre 5.

5

LE NIST PRIVACY FRAMEWORK ET LES NORMES ISO

« Un certificat dit qu'un système de management existe.
Il ne dit pas que chaque traitement est licite. »

Principe du cours

Niveau : *Fondamental* • Chapitres 3 et 4 ; ISO/IEC 27001 (UE MSN-2S3-SEC08)

✦ Objectifs du chapitre

- ➢ Distinguer trois natures de référentiel : la loi, la norme certifiable, le cadre volontaire.
- ➢ Décrire le *Privacy Framework* du NIST : noyau, profils, niveaux de mise en œuvre.
- ➢ Situer les normes ISO/IEC 29100, 27701, 29134 et 27018 et dire ce que l'édition 2025 de l'ISO/IEC 27701 a changé.
- ➢ Distinguer la certification prévue par la loi (article 34) de la certification d'un système de management.
- ➢ Établir une correspondance entre la loi, le RGPD, le cadre du NIST et la norme et en dire les limites.

Avant de commencer : « avec le certificat, nous serons conformes »

Bafoussam, mardi 1er septembre 2026. NOUN PAY[1] prépare une levée de fonds. Un investisseur américain demande une preuve de conformité en matière de données et joint à son questionnaire une grille tirée du *Privacy Framework* du NIST. Le directeur général, M. NJOYA, a trouvé la solution : « Nous allons nous faire certifier ISO/IEC 27701. Avec le certificat, nous serons conformes. »

[1] NOUN PAY, ses dirigeants et ses clients sont fictifs. L'entreprise figure aussi dans le cours de gouvernance des SI de l'auteur.

© MaletYon

Mme BELLO, sollicitée pour un diagnostic, lui pose deux questions. Le périmètre du certificat couvrira-t-il la notation automatique des crédits, ou seulement l'application de paiement ? Et l'organisme certificateur vérifiera-t-il que chaque traitement a reçu l'autorisation de l'article 19 ? À la seconde, la réponse est non : un auditeur de certification vérifie le système de management contre la norme, il ne rend pas un avis juridique. Quant à la grille du NIST, personne à NOUN PAY ne sait ce qu'elle mesure.

★ Attention

Violation typique. Présenter un certificat de système de management comme une preuve de conformité à la loi.

Règle : un certificat ISO/IEC 27701 atteste qu'un système de management de la protection des données existe et fonctionne sur un périmètre donné. La conformité à la loi se démontre par l'audit de conformité légale, exigence par exigence. Les deux se complètent ; l'un ne remplace pas l'autre.

5.1 Trois Natures de Référentiel

Les textes rencontrés depuis le début de cette partie n'ont pas la même nature. L'auditeur les range en trois familles avant de s'en servir.

Nature	Exemples	Qui l'impose	Ce que prouve la conformité
Loi	Loi n° 2024/017, loi n° 2010/012, RGPD	L'État, sous peine de sanction	Le respect d'obligations
Norme certifiable	ISO/IEC 27701, ISO/IEC 27001	Un client, un marché, l'organisation elle-même	L'existence d'un système de management, attestée par un tiers
Cadre volontaire	*Privacy Framework* du NIST	Personne ; un partenaire peut le demander	Une maturité déclarée, sans certificat

Tableau 5.1. Trois natures de référentiel

Un cadre volontaire devient contraignant de la même manière qu'un texte étranger : par contrat. L'investisseur de NOUN PAY peut faire du profil NIST une condition de son entrée au capital. Le cadre reste alors contractuel au sens du Chapitre 3.

5.2 Le Privacy Framework du NIST

Le *National Institute of Standards and Technology* est l'institut de normalisation du département américain du commerce. Il a publié en janvier 2020 la version 1.0 de son *Privacy Framework* [30], un outil de gestion du risque d'atteinte à la vie privée. Le cadre

est volontaire, gratuit et sans certification. Il ne dépend d'aucune loi : il a été conçu dans un pays qui n'a pas de loi générale de protection des données (Chapitre 3), pour des organisations qui doivent en respecter plusieurs à la fois.

Il se compose de trois éléments, repris du cadre de cybersécurité du même institut.

5.2.1 Le noyau

Le **noyau** (*Core*) est un catalogue de résultats attendus, rangés en cinq fonctions. Chaque fonction se divise en catégories, puis en sous-catégories rédigées comme des résultats et non comme des moyens.

Fonction	Question posée (paraphrasée)	Écho dans la loi n° 2024/017
Identify-P	Quelles données traite-t-on, pour qui, avec quel risque pour les personnes ?	Registre (art. 29), évaluation du risque (art. 25, 33)
Govern-P	Qui décide, selon quelles règles et quelles obligations ?	Responsabilité des acteurs (art. 20), autorisation (art. 19)
Control-P	Sait-on gérer les données finement : accès, correction, suppression, conservation ?	Droits (art. 37 à 46), durée (art. 13)
Communicate-P	Les personnes comprennent-elles ce que l'on fait de leurs données ?	Information (art. 14, 21)
Protect-P	Les données sont-elles protégées contre les incidents ?	Sécurité (art. 27), violations (art. 22)

Tableau 5.5. Les cinq fonctions du noyau

La fonction *Protect-P* recouvre le cadre de cybersécurité du NIST, dont les fonctions de détection, de réponse et de reprise complètent le dispositif en cas de violation. Le cadre distingue ainsi deux risques que ce cours a séparés dès le Chapitre 2 : celui qui vient d'un incident de sécurité et celui qui vient du traitement lui-même, même parfaitement sécurisé. Le NIST nomme le second « action problématique sur les données ».

5.2.2 Les profils

Un **profil** est la sélection des résultats du noyau qui comptent pour une organisation. On en dresse deux. Le profil actuel décrit ce qui est atteint aujourd'hui. Le profil cible décrit ce que l'organisation veut atteindre, compte tenu de ses obligations et de ses risques. L'écart entre les deux donne le plan d'action.

Le profil actuel se prête à la cotation du cours. Chaque résultat retenu devient une proposition fermée : atteint (OUI), non atteint (NON), ou pas assez d'éléments pour le dire (NEK). Un profil que l'organisation remplit seule, sans preuve, vaut une déclaration au sens du Chapitre 8.

5.2.3 Les niveaux de mise en œuvre

Les **niveaux** (*Tiers*) décrivent la manière dont l'organisation gère le risque, de 1 à 4 : partielle, informée par le risque, reproductible, adaptative. Ce ne sont pas des niveaux de maturité à atteindre tous. Une petite structure peut viser légitimement le niveau 2.

Note

La version 1.1. Le NIST a publié en avril 2025 le projet d'une version 1.1, qui réaligne le cadre sur la version 2.0 de son cadre de cybersécurité et ajoute des éléments sur l'intelligence artificielle. À la date de ce cours, l'institut annonçait la version finale pour 2026. La structure en noyau, profils et niveaux ne change pas. L'auditeur à qui l'on présente un profil vérifie la version qu'il utilise.

5.2.4 Les autres publications utiles

Publication	Objet (paraphrasé)	Usage dans ce cours
NISTIR 8062	Ingénierie de la vie privée : prévisibilité, maîtrise, dissociabilité	Évaluer le risque (Chapitre 10)
SP 800-53, révision 5	Catalogue de mesures de sécurité et de vie privée	Détailler une mesure (Chapitre 12)
SP 800-122	Protection de la confidentialité des données d'identification	Classer les données par niveau d'impact
SP 800-61	Gestion des incidents	Violations (Chapitre 15)
AI RMF 1.0	Gestion des risques de l'intelligence artificielle	Profilage (Chapitre 17)

Tableau 5.6. Cinq publications du NIST pour l'auditeur

Les trois objectifs du NISTIR 8062 complètent utilement la triade de la sécurité. La *prévisibilité* : la personne et l'organisation peuvent anticiper ce qui sera fait des données. La *maîtrise* : on peut modifier, supprimer ou communiquer une donnée à un niveau fin. La *dissociabilité* : on peut traiter sans rattacher les données à une personne quand ce lien n'est pas nécessaire.

5.2.5 Ce que le cadre n'apporte pas

Le cadre du NIST ne dit pas ce qui est permis. Il ne connaît ni l'autorisation préalable, ni les trois dérogations au consentement, ni la liste camerounaise des données sensibles. Une organisation peut présenter un profil cible entièrement atteint et traiter des données sans fondement.

5.3 La Famille des Normes

Norme	Objet (paraphrasé)	Usage dans l'audit
ISO/IEC 29100	Cadre de la protection de la vie privée : vocabulaire, acteurs, onze principes	Référentiel de principes, comparaison avec la loi
ISO/IEC 27701	Système de management de la protection de la vie privée	Audit contre une norme, certification
ISO/IEC 29134	Lignes directrices pour l'évaluation d'impact	Méthode de l'évaluation d'impact (Chapitre 10)
ISO/IEC 27018	Protection des données personnelles dans le nuage public, pour les sous-traitants	Évaluer un hébergeur (Chapitre 14)
ISO/IEC 27001 et 27002	Système de management et mesures de sécurité de l'information	Domaine sécurité (Chapitre 12)
ISO 19011, ISO/IEC 27007	Conduite des audits	Méthode (Chapitre 8)

Tableau 5.2. Les normes utiles à l'audit de protection des données

Toutes ces normes sont publiées sous licence : ce cours les paraphrase et n'en reproduit aucun passage. L'auditeur qui fonde un constat sur une exigence normative doit disposer de l'édition en vigueur et la citer avec son année.

5.3.1 Les onze principes de l'ISO/IEC 29100

L'ISO/IEC 29100 [23] énonce onze principes : le consentement et le choix ; la légitimité et la spécification des finalités ; la limitation de la collecte ; la minimisation des données ; la limitation de l'utilisation, de la conservation et de la divulgation ; l'exactitude et la qualité ; l'ouverture, la transparence et l'information ; la participation et l'accès des personnes ; la responsabilité ; la sécurité ; et le respect des obligations de protection de la vie privée. La comparaison avec la loi camerounaise fait apparaître la minimisation, absente comme principe général de la loi (Chapitre 2).

5.3.2 L'ISO/IEC 27701

L'ISO/IEC 27701 [24] étend la logique de l'ISO/IEC 27001 aux données personnelles : contexte, leadership, planification, support, fonctionnement, évaluation et amélioration, plus des mesures propres aux responsables de traitement et aux sous-traitants. Publiée en 2019 comme extension de l'ISO/IEC 27001, elle a été révisée en octobre 2025 pour devenir une norme de système de management autonome : la certification ISO/IEC 27001 n'est plus un préalable. Les deux éditions coexistent pendant la période de transition ; l'auditeur vérifie l'édition sur laquelle porte le certificat qu'on lui présente.

Elle apporte à l'audit trois choses que la loi ne donne pas : une méthode de management (un cycle d'amélioration, des revues de direction, des audits internes), des mesures détaillées propres aux données personnelles et un vocabulaire partagé avec les partenaires étrangers. Elle n'apporte pas les obligations propres au Cameroun :

l'autorisation préalable, les trois dérogations au consentement, le rapport annuel de l'article 27, la liste camerounaise des données sensibles.

5.4 Deux Certifications

Jurisprudence & Droit applicable

Loi n° 2024/017, article 34 [26] : *« L'Autorité de protection des données à caractère personnel met en place un mécanisme de certification du traitement des données à caractère personnel conforme aux principes et exigences énoncés par la présente loi. »*

Portée. L'article 5 définit la certification comme un outil permettant de communiquer sur le niveau de protection « au regard des critères d'un référentiel approuvé au préalable par l'Autorité ». Il s'agit d'une certification de conformité à la loi, distincte des certifications ISO. L'article 59 punit le responsable qui « opère sans certification prévue dans la présente loi » : tant que le mécanisme n'existe pas, la portée de cette sanction est un NEK de critère.

	Certification de l'article 34	Certification ISO/IEC 27701
Délivrée par	L'Autorité, ou selon son mécanisme	Un organisme de certification accrédité
Référentiel	Approuvé par l'Autorité	Norme internationale
Objet	Traitement, processus, produit	Système de management sur un périmètre
Portée juridique	Prévue par la loi (articles 34, 59)	Aucune au regard de la loi
État en novembre 2026	Mécanisme non publié	Disponible

Tableau 5.3. Deux certifications à ne pas confondre

5.5 Correspondances entre les Référentiels

Une organisation exposée à plusieurs référentiels établit une table de correspondance. Elle évite de faire plusieurs fois le même travail : le registre de l'article 29 sert aussi le RGPD, le cadre du NIST et la norme.

Thème	Loi n° 2024/017	RGPD	NIST	ISO/IEC 27701
Recensement	Art. 29	Art. 30	*Identify-P*	Registre des traitements
Fondement	Art. 9	Art. 6	*Govern-P*	Base légale identifiée
Autorisation	Art. 19	Aucun	Aucun	Aucun
Information	Art. 21	Art. 13, 14	*Communicate-P*	Information des personnes
Droits	Art. 37 à 47	Art. 15 à 22	*Control-P*	Obligations envers les personnes
Risque et impact	Art. 25, 33	Art. 35	*Identify-P*	Évaluation d'impact
Sécurité	Art. 27	Art. 32	*Protect-P*	Mesures de sécurité
Sous-traitants	Art. 30	Art. 28	*Govern-P*	Mesures pour les sous-traitants
Transferts	Art. 32	Art. 44 à 49	*Govern-P*	Transferts, pays
Violations	Art. 22	Art. 33, 34	*Protect-P* et cadre de cybersécurité	Gestion des incidents
Rapport annuel	Art. 27(2)	Aucun	Aucun	Aucun

Tableau 5.4. Correspondances indicatives entre quatre référentiels (thèmes paraphrasés)

Deux lignes n'ont de contenu que dans la première colonne : l'autorisation préalable et le rapport annuel. Aucun référentiel étranger ne les porte. Une organisation qui bâtit sa conformité sur le RGPD, le NIST ou l'ISO seuls les oubliera.

Une correspondance n'est jamais une équivalence. Une ligne dit que le dispositif exigé par un référentiel peut porter l'exigence légale ; elle ne dit pas qu'il le fait. L'audit de conformité vérifie toujours l'exigence légale elle-même. Le Chapitre 7 le complétera par les règles propres à la loi n° 2010/012 et donnera la règle pour choisir ses critères.

5.6 Le Diagnostic de NOUN PAY

Scénario Opérationnel · Mission NOUN PAY. Le diagnostic du 8 septembre 2026

Constatations. Le périmètre envisagé pour la certification couvre l'application de paiement et exclut la notation automatique « NOUN SCORE », « en cours de refonte ». Aucune demande d'autorisation n'a été préparée. L'hébergeur, établi dans l'Union européenne, présente un certificat ISO/IEC 27018.

Analyse (confiance élevée). Le certificat visé laisserait hors périmètre le traitement le plus risqué de l'entreprise, celui qui décide des crédits. Il serait exact et trompeur s'il était présenté comme une preuve de conformité. Le certificat de l'hébergeur porte sur l'hébergeur : il ne dit rien des traitements de NOUN PAY ni du transfert lui-même (Chapitre 14).

Pour répondre à l'investisseur, Mme BELLO dresse avec l'équipe un profil actuel de huit résultats, deux au moins par fonction qu'elle a pu examiner.

⚖ Lecture auditologique · NOUN PAY, profil actuel coté, 8 septembre 2026

Fonction	Résultat attendu (paraphrasé)	Cote	Preuve
Identify-P	Les traitements et les flux sont inventoriés	NON	Aucun registre
Identify-P	Le risque pour les personnes est évalué	NON	Aucune évaluation
Govern-P	Les obligations légales sont recensées	NON	Aucune liste
Govern-P	Les rôles sont attribués	NON	Aucune désignation
Control-P	Les données sont supprimées à l'échéance	NEK	Non examiné
Communicate-P	Les personnes sont informées des traitements	NON	Notice de l'application
Protect-P	Les données sont chiffrées au repos et en transit	OUI	Configuration de l'hébergeur
Protect-P	Les accès sont nominatifs et tracés	OUI	Journaux de la console

Décompte. Deux OUI, cinq NON, un NEK sur huit. $\mu = 0{,}25$ · $U = 0{,}125$ · $H = 1{,}30$ **bit**

Lecture. Les deux résultats atteints sont dans la seule fonction de protection. NOUN PAY a traité la vie privée comme un problème de sécurité. Le profil montre à l'investisseur ce qu'un certificat de sécurité n'aurait pas montré.

5.7 Ce que les Référentiels demandent à chaque Métier

Application Délégué à la protection des données

Bâtir le système de management sur les obligations de la loi, puis le rapprocher des référentiels demandés par les partenaires. Tenir la table de correspondance et signaler les exigences camerounaises qu'aucun référentiel étranger ne porte.

Application Auditeur de la protection des données

Lire le périmètre et l'édition de tout certificat, la version de tout profil. Ne jamais coter OUI une exigence légale sur la seule foi d'un certificat ou d'un profil déclaré.

Application Responsable de traitement

Choisir le périmètre d'une certification en fonction des risques, pas de la facilité. Un certificat qui exclut le traitement le plus risqué expose à un reproche de présentation trompeuse.

★ À retenir

- Une loi oblige, une norme se certifie, un cadre volontaire se déclare. Les deux derniers ne deviennent contraignants que par contrat.
- Le *Privacy Framework* du NIST comprend un noyau de cinq fonctions, des profils actuel et cible et quatre niveaux de mise en œuvre. Il ne dit pas ce qui est permis.
- L'ISO/IEC 27701 est depuis 2025 une norme autonome ; l'auditeur vérifie l'édition du certificat.
- La certification de l'article 34 est une certification de conformité à la loi, distincte d'une certification ISO.
- L'autorisation préalable et le rapport annuel n'ont d'équivalent dans aucun référentiel étranger.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- nommer les cinq fonctions du noyau du NIST et la question que pose chacune ;
- dire ce qu'un certificat ISO/IEC 27701 prouve et ce qu'il ne prouve pas ;
- citer deux obligations camerounaises absentes des référentiels étrangers.

✍ Exercice 5.1. Quelle norme ★☆☆

Quelle norme consultez-vous pour : (a) conduire une évaluation d'impact ; (b) évaluer un hébergeur en nuage ; (c) mettre en place un système de management de la protection des données ; (d) définir le vocabulaire d'un contrat ?

✍ Exercice 5.2. Le périmètre de NOUN PAY ★★☆

Rédigez l'avis de Mme BELLO à M. NJOYA sur le périmètre de la certification, en séparant constatations et analyse. Proposez un périmètre et un calendrier qui tiennent compte de la notation automatique.

✍ Exercice 5.3. Compléter la correspondance ★★☆

Ajoutez au Tableau 5.4 les lignes correspondant aux articles 22 (violations), 30 (sous-traitance) et 32 (transferts), avec le thème de la norme et la couverture.

✍ Exercice 5.4. Le profil cible ★★★

L'investisseur demande à NOUN PAY un profil cible à douze mois.

(a) Pour chacun des huit résultats du profil actuel, proposez la cible et la preuve qui permettra de la coter OUI.

(b) Ajoutez deux résultats que la loi n° 2024/017 impose et que le noyau du NIST ne contient pas. Comment les présentez-vous à un investisseur qui ne connaît que le cadre du NIST ?

(c) Quel niveau de mise en œuvre NOUN PAY peut-elle viser raisonnablement ? Justifiez.

● Note

Pour aller plus loin.

- ➢ Le *Privacy Framework* du NIST [30], librement accessible et le NISTIR 8062 [2].
- ➢ L'ISO/IEC 27701 [24] et l'ISO/IEC 29100 [23].
- ➢ L'ISO/IEC 27018 [16], pour les sous-traitants en nuage.

● Note

Transition. Les sources internationales, le règlement européen et les référentiels volontaires forment le paysage. Il reste à lire de près le texte qui oblige toute organisation camerounaise et qui a internalisé une grande partie de ce paysage : la loi n° 2024/017, avec son Autorité et ses sanctions. C'est l'objet du Chapitre 6.

partie III

Le Contexte National

© MaletYon

6

LA LOI N° 2024/017 : AUTORISATION, AUTORITÉ, SANCTIONS

« On cite une loi pour ce qu'elle dit,
pas pour ce que l'on aimerait qu'elle dise. »

Principe du cours

Niveau : *Fondamental* • Chapitres 1, 2 et 3 à 5 ; droit du numérique (UE MSN-2S3-JUR01)

✦ Objectifs du chapitre

- ➢ Présenter l'architecture de la loi n° 2024/017 en sept titres.
- ➢ Expliquer le régime d'autorisation préalable et ses conséquences tant que l'Autorité n'est pas organisée.
- ➢ Décrire les missions de l'Autorité et l'échelle des sanctions administratives, civiles et pénales.
- ➢ Dire ce que la loi a internalisé des sources internationales et ce qu'elle a ajouté en propre.
- ➢ Recenser les dispositions qui attendent un texte d'application et en tirer les conséquences pour la cotation.
- ➢ Lire les dispositions transitoires et la clause d'abrogation.

Avant de commencer : « où dépose-t-on la demande ? »

Bafoussam, jeudi 25 juin 2026. Le lendemain de la lettre de M. TAGNE, Me ETOUNDI lit la loi au directeur général, article par article. À l'article 19, M. TCHOUA l'arrête : « Une autorisation pour chaque traitement. Très bien. Où dépose-t-on la demande ? »

Me ETOUNDI tourne les pages jusqu'à l'article 53. L'Autorité de protection existe dans la loi. Sa création, son organisation et son fonctionnement relèvent d'un décret qu'elle n'a pas trouvé. Les modalités de l'autorisation relèvent d'un autre texte. « Je ne sais pas, répond-elle. Mais je sais ce qu'il y aura dans le dossier le jour où le guichet

© *MaletYon*

ouvrira. »

★ Attention

Violation typique. Conclure que la loi ne s'applique pas encore parce que l'Autorité n'est pas organisée, et attendre.

Règle : la loi est en vigueur et son délai de mise en conformité est expiré. Les obligations qui ne dépendent d'aucun texte d'application s'imposent dès maintenant. Pour les autres, l'organisation prépare ce qui dépend d'elle et l'auditeur cote séparément l'exigence et la diligence.

6.1 Ce que la Loi a Internalisé

Les chapitres précédents ont décrit le paysage international. La loi n° 2024/017 en est l'héritière sans en être la copie. Le tableau ci-dessous sépare ce qu'elle reprend de ce qu'elle ajoute.

Titre de la loi	Ce qu'elle reprend	Ce qu'elle ajoute ou change
I. Définitions, champ	Vocabulaire commun à la Convention 108, à Malabo et au RGPD	Protection des personnes « en transit » ; liste ouverte de données sensibles, dont les transactions bancaires et l'origine régionale
II. Principes	Les huit principes de l'OCDE	Consentement comme règle, trois dérogations seulement ; pas de principe général de minimisation
II. Formalités	Formalités préalables de Malabo	Autorisation pour tout traitement, sans régime de déclaration
II. Obligations	Registre, évaluation d'impact, sous-traitance, transferts du RGPD	Mêmes obligations pour le sous-traitant ; convention publique ; quatre vérifications cumulées pour un transfert ; rapport annuel de sécurité
III. Droits	Droits du RGPD, portabilité comprise	Directives après le décès ; délais renvoyés au règlement
V. Autorité	Autorité indépendante des principes de l'ONU et de Malabo	Création et organisation par décret
VI. Sanctions	Amendes administratives	Délits nombreux, dont le profilage ; responsabilité pénale des personnes morales

Tableau 6.1. Ce que la loi reprend et ce qu'elle ajoute

La colonne de droite est celle que l'auditeur doit connaître par cœur. Elle contient tout ce qu'un consultant formé au seul RGPD oubliera (Chapitre 4).

6.2 L'Architecture de la Loi

Titre	Objet	Art.	Chapitres du cours
I	Dispositions générales : objet, champ, définitions	1–5	1
II	Régime juridique : principes, formalités préalables, obligations, interconnexion	6–36	2, 9, 10, 12, 13, 14, 15
III	Droits de la personne concernée	37–47	11, 17
IV	Interdictions	48–52	1, 18
V	Autorité de protection	53	ce chapitre
VI	Sanctions administratives, civiles et pénales	54–71	ce chapitre
VII	Dispositions diverses, transitoires et finales	72–75	0, 18

Tableau 6.2. Les sept titres de la loi n° 2024/017

La loi compte soixante-quinze articles. Elle « abroge toutes les dispositions antérieures contraires » (article 75) et renvoie à des textes particuliers les modalités d'application (article 74). Une quinzaine de ses dispositions dépendent d'un texte réglementaire ou d'un référentiel de l'Autorité : critères de risque, évaluation d'impact, durées de conservation, délais des droits, modalités d'autorisation et de contrôle.

6.3 Ce qui Attend un Texte d'Application

Objet	Art.	Conséquence pour l'audit
Création et organisation de l'Autorité	53	Pas de guichet, pas de contrôle administratif
Modalités de l'autorisation	19, 32	Double cote : exigence et diligence
Critères et modalités de l'évaluation du risque	25	Méthode déclarée par l'organisation
Évaluation d'impact	33	Critères de risque élevé déclarés
Durées de conservation	13, 28	Durées fixées et justifiées par l'organisation
Délais d'examen des demandes	47	Critère de substitution déclaré
Référentiel des mesures	24, 27, 57	Contenu du rapport annuel inconnu
Mécanisme de certification	34, 59	Sanction de l'article 59 sans objet pour l'instant
Modalités du contrôle	35	Sans objet pour l'instant
Liste des pays, clauses types	32, 53	Deux vérifications de l'article 32 non cotables
Textes des secteurs	4, 72	Loi générale appliquée, réserve signalée

Tableau 6.3. Les dispositions suspendues à un texte (état en novembre 2026, tableau à refaire à chaque mission)

Chaque ligne de ce tableau produira dans les chapitres suivants un NEK de critère, c'est-à-dire une incertitude qui tient au droit et non à l'organisation (Chapitre 8). L'auditeur refait le tableau au début de chaque mission. Un texte publié entre-temps transforme un NEK en exigence cotable.

6.4 Le Régime d'Autorisation Préalable

Jurisprudence & Droit applicable

Loi n° 2024/017, article 19 [26] : *« (1) Le traitement des données à caractère personnel est soumis à l'obtention préalable d'une autorisation délivrée par l'Autorité de protection des données à caractère personnel. (2) Tout processus d'interconnexion et d'interopérabilité des fichiers de données sensibles, relatives aux mineurs, est soumis à l'obtention préalable d'une autorisation délivrée par l'Autorité de protection des données à caractère personnel. (3) Les modalités de délivrance de l'autorisation visée aux alinéas 1 et 2 ci-dessus sont fixées par voie réglementaire. »*

Portée. La loi ne prévoit ni déclaration simplifiée ni dispense : tout traitement est soumis à autorisation. L'article 49 interdit le traitement sans autorisation préalable, et l'article 55 le punit d'une pénalité de 5 à 50 millions de francs CFA.

Le régime est l'inverse du modèle européen, qui a supprimé les formalités préalables au profit de la responsabilisation du responsable. Il rapproche la loi camerounaise des premières lois africaines et françaises, fondées sur un contrôle *a priori*.

Ce régime pose une difficulté pratique : l'autorisation est délivrée par une Autorité dont « la création, ainsi que l'organisation et le fonctionnement » sont fixés par décret (article 53, alinéa 2), et selon des modalités elles-mêmes réglementaires (article 19, alinéa 3). Tant que ces textes ne sont pas publiés et que l'Autorité ne reçoit pas de demandes, l'organisation ne peut pas obtenir d'autorisation. Que doit coter l'auditeur ?

- « Le traitement est autorisé » : NON, puisqu'aucune autorisation n'existe. La cote est exacte ; elle ne dit pas que l'écart est imputable à l'organisation.
- « L'organisation a fait ce qui dépendait d'elle » : OUI si elle a préparé le dossier (registre, évaluations, mesures) et peut prouver qu'elle le déposera dès que la procédure sera ouverte ; NON sinon.

Le rapport présente les deux cotes ensemble. À NYANGA, la seconde est NON : aucun dossier n'a été préparé.

6.5 L'Autorité de Protection

Jurisprudence & Droit applicable

Loi n° 2024/017, article 53, alinéa 1 (extraits) [26] : *« L'Autorité de protection des données à caractère personnel est un organisme public indépendant chargé, notamment : de veiller à l'application de la présente loi, des textes pris pour son application ainsi que des conventions internationales en la matière ; de délivrer les autorisations prévues par la présente loi, assorties des cahiers de charges conséquents ; d'élaborer, publier et mettre à jour le référentiel des mesures techniques et organisationnelles des données à caractère personnel ; [...] de traiter les réclamations, pétitions et plaintes [...] ; d'établir et publier la liste des pays reconnus comme offrant un niveau de protection des données à caractère personnel équivalent aux exigences prévues par le droit camerounais ; [...] »*

Trois instruments de l'Autorité conditionnent l'audit : le **référentiel des mesures** (articles 24, 27, 28, 57), les **cahiers des charges** attachés aux autorisations (article 61), et la **liste des pays** offrant une protection équivalente (Chapitre 14). Tant qu'ils n'existent pas, les exigences qui en dépendent sont des NEK de critère.

Note

État de l'Autorité au moment de la rédaction. À la date de ce cours (novembre 2026), l'auteur n'a pas trouvé de texte publié organisant l'Autorité, et ses coauteurs et lui relèvent dans leurs travaux en cours que ce texte était attendu après l'échéance du 23 juin 2026. Le lecteur vérifiera la situation au moment où il

lit : si l'Autorité est organisée, une partie des NEK de critère de ce livre se lève.

6.6 Contrôle et Certification

L'article 35 confie à l'Autorité le contrôle des traitements, selon des modalités réglementaires. L'article 34 lui demande en outre de mettre en place une certification.

Jurisprudence & Droit applicable

Loi n° 2024/017, article 34 [26] : *« L'Autorité de protection des données à caractère personnel met en place un mécanisme de certification du traitement des données à caractère personnel conforme aux principes et exigences énoncés par la présente loi. »*

Portée. L'article 5 définit la certification comme un outil permettant de communiquer sur le niveau de protection « au regard des critères d'un référentiel approuvé au préalable par l'Autorité ». Il s'agit d'une certification de conformité à la loi, distincte des certifications ISO. L'article 59 punit le responsable qui « opère sans certification prévue dans la présente loi » : tant que le mécanisme n'existe pas, la portée de cette sanction est un NEK de critère.

	Certification de l'article 34	Certification ISO/IEC 27701
Délivrée par	L'Autorité, ou selon son mécanisme	Un organisme de certification accrédité
Référentiel	Approuvé par l'Autorité	Norme internationale
Objet	Traitement, processus, produit	Système de management sur un périmètre
Portée juridique	Prévue par la loi (articles 34, 59)	Aucune au regard de la loi
État en novembre 2026	Mécanisme non publié	Disponible

Tableau 6.4. Deux certifications à ne pas confondre (voir aussi le Chapitre 5)

6.7 Les Sanctions

6.7.1 Sanctions administratives

Jurisprudence & Droit applicable

Loi n° 2024/017, article 54 [26] : *« (1) Lorsque l'Autorité de protection des données à caractère personnel constate le non-respect des obligations mises à la charge du responsable du traitement ou de son sous-traitant, celui-ci est mis en demeure de s'y conformer dans un délai maximum de dix (10) jours. (2) Passé le*

délai prévu à l'alinéa 1 ci-dessus, l'Autorité de protection des données à caractère personnel adresse une injonction de mise en conformité du traitement, sous astreinte dont le montant ne peut excéder cent mille (100 000) francs CFA par jour de retard. [. . .] »

Portée. À défaut de mise en conformité, l'Autorité peut suspendre l'activité, retirer l'autorisation ou interdire tout traitement (alinéa 3).

Art.	Manquement	Montant (F CFA)
55	Traitement sans autorisation préalable	5 à 50 millions
56	Refus de communiquer à la personne les informations la concernant	1 à 10 millions
57	Non-respect du référentiel	5 à 20 millions
58	Non-respect des règles d'interconnexion	1 à 5 millions
59	Traitement sans la certification prévue	5 à 15 millions
60	Transfert vers un pays tiers sans autorisation	10 à 50 millions
61	Non-respect du cahier des charges	10 à 100 millions

Tableau 6.5. Pénalités et amendes administratives (articles 55 à 61)

6.7.2 Sanctions civiles et pénales

L'article 62 ouvre à la personne concernée le référé « en cas d'atteinte grave aux droits », éventuellement sous astreinte, et l'action en réparation. Les articles 63 à 70 créent des délits ; l'article 71 rend les personnes morales pénalement responsables, avec une amende de 50 millions à un milliard de francs CFA.

Art.	Délit	Peine d'emprisonnement
63	Collecte ou accès frauduleux, déloyal ou illicite (peines doublées avec verrouillage ou cryptage)	2 à 5 ans
64	Traitement maintenu malgré l'opposition, refus de rectifier ou d'effacer	1 à 3 ans
65	Traitement à des fins de profilage	3 à 10 ans
66	Données sensibles sans consentement exprès ; récupération frauduleuse de données supprimées	6 mois à 2 ans
67	Détournement de finalité, traitement ultérieur incompatible	6 mois à 2 ans
68	Divulgation portant atteinte à la dignité ou à la vie privée (sur plainte)	6 mois à 2 ans
69	Transfert vers l'étranger en méconnaissance de la loi	3 à 10 ans
70	Entrave à l'action de l'Autorité	6 mois à 3 ans

Tableau 6.6. Les délits de la loi (amendes assorties, non reproduites)

L'article 65 mérite attention : il punit « le responsable de traitement ou le sous-traitant qui procède ou fait procéder à un traitement de données à caractère personnel à des fins de profilage », sans condition apparente. Sa portée exacte, pour une notation de crédit par exemple, est discutée au Chapitre 17.

6.8 Dispositions Transitoires et Abrogation

Trois articles ferment la loi. L'article 73 a donné dix-huit mois aux organisations pour se conformer ; ce délai a expiré le 23 juin 2026 (Chapitre 0). L'article 74 renvoie les modalités d'application à des textes particuliers. L'article 75 abroge « toutes les dispositions antérieures contraires ».

La formule de l'article 75 ne nomme aucun texte. Elle laisse donc en vigueur tout ce qui, dans les lois antérieures, n'est pas contraire à la loi nouvelle. La loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité contient une quinzaine d'articles sur la vie privée, la conservation des données et les infractions qui s'y rapportent. Lesquels subsistent ? Aucune liste officielle ne le dit. C'est à l'auditeur et au juriste de le déterminer article par article, et c'est l'objet du Chapitre 7.

6.9 Ce que la Loi demande à chaque Métier

Application Juriste conformité

Lire le texte officiel, distinguer les obligations applicables, les obligations suspendues à un texte d'application et les bonnes pratiques importées, et le dire dans chaque avis.

Application Auditeur de la protection des données

Coter séparément « l'exigence est satisfaite » et « l'organisation a fait ce qui dépendait d'elle » quand l'écart tient à l'absence de l'Autorité.

Application Responsable de traitement

Préparer dès maintenant les dossiers d'autorisation : registre, fondements, évaluations, mesures. Le jour où la procédure ouvrira, ce sont eux qui seront demandés.

★ À retenir

- La loi compte sept titres et soixante-quinze articles ; une quinzaine de dispositions attendent un texte d'application.
- Tout traitement est soumis à autorisation préalable de l'Autorité (article 19) ; tant qu'elle n'est pas organisée, l'auditeur cote aussi ce qui dépendait de l'organisation.
- Les sanctions vont de la mise en demeure à dix jours jusqu'à un milliard de francs CFA pour une personne morale.
- La loi internalise les principes internationaux et y ajoute l'autorisation préalable, un consentement de principe, une liste large de données sensibles et de nombreux délits.
- L'article 75 n'abroge que les dispositions contraires : la loi n° 2010/012 subsiste pour le reste.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer trois ajouts de la loi par rapport à ses sources ;
- expliquer comment coter l'absence d'autorisation quand l'Autorité n'est pas organisée ;
- rattacher un écart à l'article qui le sanctionne.

✍ Exercice 6.1. Quel article ★☆☆

Indiquez l'article qui sanctionne : (a) un transfert vers un hébergeur étranger sans autorisation ; (b) un agent qui récupère des fichiers effacés de la corbeille d'un collègue ; (c) un établissement qui refuse de communiquer à un client ses données ; (d) une entreprise qui refuse de recevoir les agents de l'Autorité.

✍ Exercice 6.2. Sans Autorité ★★★

Un client de MBOLO dépose plainte auprès de l'Autorité en septembre 2026. L'Autorité n'est pas encore organisée. (a) Quelles autres voies s'offrent à lui ? (b) Quel est l'intérêt, pour MBOLO, d'avoir préparé ses dossiers d'autorisation ? (c) Comment l'auditeur rend-il compte de cette situation dans son rapport ?

✍ Exercice 6.3. Reprise ou ajout ★★☆

Pour chaque disposition, dites si la loi reprend une source internationale (laquelle) ou innove : (a) la portabilité de l'article 43 ; (b) les transactions bancaires parmi les données sensibles ; (c) l'autorisation préalable de l'article 19 ; (d) la convention publique de l'article 31 ; (e) le droit d'accès de l'article 39.

✍ Exercice 6.4. Le tableau des textes attendus ★★★

Un décret organisant l'Autorité paraît pendant votre mission.

(a) Quelles lignes du Tableau 6.3 changent, et lesquelles ne changent pas ?

(b) Quelles cotes NEK de vos papiers de travail devez-vous reprendre ?

(c) Rédigez le paragraphe du rapport qui explique au commanditaire pourquoi des cotes ont changé sans que l'organisation ait rien fait.

● Note

Pour aller plus loin.

➢ La loi n° 2024/017 [26], dans son texte officiel, titres V à VII.

➢ La Convention de Malabo [13], chapitre II, pour mesurer ce que la loi en a repris.

● Note

Transition. La loi de 2024 n'est pas seule. Une loi de 2010, écrite pour la sécurité des réseaux, impose encore de conserver, de protéger et de ne pas intercepter. C'est l'objet du Chapitre 7.

7

LA LOI N° 2010/012 ET LES TEXTES CONNEXES

« Une loi nouvelle n'efface pas les anciennes.
Elle oblige à les relire. »

Principe du cours

Niveau : *Fondamental* • Chapitre 6 ; droit du numérique (UE MSN-2S3-JUR01)

✦ Objectifs du chapitre

- ➢ Présenter ce que la loi n° 2010/012 impose en matière de sécurité, de conservation et de vie privée.
- ➢ Confronter la conservation décennale de la loi de 2010 à la durée limitée de la loi de 2024.
- ➢ Rapprocher les délits de l'article 74 de ceux de la loi de 2024.
- ➢ Recenser les textes connexes applicables à une organisation, avec leur référence exacte.
- ➢ Choisir les critères d'un audit et dresser la carte d'applicabilité d'une organisation.

Avant de commencer : « dix ans, c'est la loi »

Bafoussam, mercredi 5 août 2026. Mme BELLO demande à M. KAMGA combien de temps NYANGA CRÉDIT garde les journaux de connexion de son application mobile. « Dix ans. C'est la loi de 2010. » Il sort le texte et montre l'article 29.

Me ETOUNDI, qui assiste à l'entretien, ouvre l'autre loi. L'article 13 de la loi de 2024 limite la conservation à « la période nécessaire » au traitement. Les journaux contiennent l'adresse IP et l'identifiant de chaque client à chaque connexion. Dix ans de ces données sont-ils nécessaires ?

Les deux ont un texte en main. L'auditrice note que la question n'est pas de savoir qui a raison, mais de savoir si l'article 29 vise bien un établissement de microfinance et ce que l'établissement a écrit pour justifier son choix. Il n'a rien écrit.

© MaletYon

★ Attention

Violation typique. Auditer la protection des données contre la seule loi n° 2024/017, comme si elle avait remplacé tout ce qui la précédait.

Règle : l'article 75 de la loi de 2024 n'abroge que les dispositions contraires. L'auditeur recense les textes antérieurs encore applicables, les inscrit parmi ses critères et signale les points où deux textes se rencontrent sans qu'une règle dise lequel l'emporte.

7.1 Une Loi de Sécurité qui Parle de Données

La loi n° 2010/012 du 21 décembre 2010 [25] régit la sécurité des réseaux de communications électroniques et des systèmes d'information, et réprime la cybercriminalité. Elle n'est pas une loi de protection des données. Elle en a pourtant tenu lieu pendant quatorze ans, par quelques articles dispersés.

Titre	Objet	Art.	Intérêt pour ce cours
I	Dispositions générales, définitions	1–5	Vocabulaire : données de connexion, données de trafic
II	Cybersécurité : régulation, audit, certification électronique, protection des réseaux, des systèmes et de la vie privée	6–51	Sécurité obligatoire, conservation, vie privée, interception
III	Cybercriminalité : procédure, infractions	52–89	Enquête, délits sur les données (art. 74)
IV	Coopération et entraide judiciaire internationales	90–94	Demandes venues de l'étranger
V	Dispositions transitoires et finales	95 et s.	Textes d'application

Tableau 7.1. La loi n° 2010/012 en cinq titres

La loi confie la régulation de la sécurité électronique à l'Agence nationale des technologies de l'information et de la communication (article 7). Tant que l'Autorité de protection des données n'est pas organisée, l'Agence est le seul régulateur en place dont les compétences touchent aux données personnelles, par le biais de la sécurité.

7.2 La Sécurité Obligatoire

Trois obligations de la loi de 2010 s'ajoutent à l'article 27 de la loi de 2024.

L'article 26 demande aux exploitants des systèmes d'information de se doter « de systèmes normalisés leur permettant d'identifier, d'évaluer, de traiter et de gérer continûment les risques liés à la sécurité ». C'est une obligation de gestion des risques, que l'ISO/IEC 27001 permet de satisfaire.

L'article 30 leur demande d'évaluer et de réviser leurs mesures « en fonction de l'évolution des technologies ».

Les articles 13 et 32 instituent un audit de sécurité obligatoire. Il vise les réseaux et les systèmes d'information des opérateurs, des autorités de certification et des fournisseurs de services de communications électroniques. Il est périodique, conduit par l'Agence ou sous son contrôle et ses rapports sont confidentiels (article 32). Le décret n° 2012/1643/PM du 14 juin 2012 en fixe les conditions et les modalités [37]. L'Agence s'en est servie pour auditer les systèmes d'information d'établissements de microfinance, aux frais de ceux-ci. Elle indique aussi que ce décret oblige tout organisme, public ou privé, à lui notifier les incidents de sécurité qui touchent son réseau. Cette notification s'ajoute à l'information que l'article 22 de la loi de 2024 réserve à l'Autorité de protection et aux personnes.

Note

Ce que l'auditeur de protection des données en fait. Il ne refait pas l'audit de sécurité. Il demande si l'organisation y est assujettie, la date du dernier audit et la suite donnée à ses recommandations. Le rapport est confidentiel : l'auditeur peut ne recevoir qu'une attestation. Il cote alors l'existence de l'audit, pas son contenu. Le cours d'audit de cybersécurité (UE MSN-2S3-SEC08) traite l'audit lui-même.

7.3 La Conservation Décennale

Quatre articles de la loi de 2010 imposent de conserver des données pendant dix ans.

Art.	Qui	Quoi
25	Opérateurs de réseaux, fournisseurs de services de communications électroniques	Données de connexion et de trafic
29	Exploitants des systèmes d'information	Données de connexion et de trafic de leurs systèmes
35	Fournisseurs d'accès et hébergeurs	Données d'identification des auteurs de contenus
46	Fournisseurs de contenus	Contenus et données stockées

Tableau 7.2. Les quatre obligations de conservation pendant dix ans

Jurisprudence & Droit applicable

Loi n° 2010/012, article 29, alinéa 1 [25] : *« Les exploitants des systèmes d'information ont l'obligation de conserver les données de connexion et de trafic de leurs systèmes d'information pendant une période de dix (10) ans. »*

Portée. L'alinéa 2 ajoute que ces données « peuvent être accessibles lors des investigations judiciaires ». La finalité est donc la preuve pénale. La loi ne définit

pas l'exploitant de système d'information ; on ne sait pas avec certitude si une microfinance ou une clinique en est un au sens de ce texte.

Une adresse IP et un identifiant de connexion sont des données personnelles par la lettre de l'article 5 de la loi de 2024 (Chapitre 1). Les journaux visés par l'article 29 sont donc des données personnelles, que l'article 13 de la loi de 2024 demande de ne pas garder au-delà du nécessaire.

Les deux textes ne sont pas incompatibles. L'article 9 de la loi de 2024 admet le traitement « nécessaire au respect d'une obligation légale », et l'article 38 réserve « les exigences de conservation » prévues par d'autres textes. Une obligation de conserver dix ans, si elle s'applique, fonde la conservation. La difficulté est en amont : savoir à qui elle s'applique.

L'auditeur procède en trois temps.

1. Il demande à l'organisation si elle se considère comme opérateur, fournisseur, hébergeur ou exploitant au sens de la loi de 2010 et sur quel fondement.
2. Si elle répond oui, il vérifie que seules les données visées (connexion et trafic) sont gardées dix ans, que leur accès est restreint et que leur finalité reste la preuve.
3. Si elle répond non ou ne sait pas, il cote NEK de critère l'application de l'article 29 et vérifie que la durée retenue est écrite et justifiée au regard de l'article 13.

Dans les trois cas, des journaux gardés dix ans et consultés pour surveiller les clients ou le personnel sont détournés de leur finalité. Cet écart-là ne dépend d'aucune interprétation.

7.4 La Vie Privée dans les Communications

La section IV du chapitre IX (articles 41 à 48) protège la vie privée. Elle reste applicable en ce qu'elle n'est pas contraire à la loi de 2024 et elle contient des règles que celle-ci n'a pas reprises.

Art.	Règle (paraphrasée)	Traitement concerné
41	Droit au respect de la vie privée ; mesures conservatoires du juge	Tous
42	Confidentialité des communications et des données de trafic	Messagerie, application, téléphonie
44	Interdiction d'écouter, d'intercepter ou de stocker les communications sans consentement, sauf autorisation légale	Enregistrement des appels, supervision de la messagerie
45	Enregistrement autorisé dans le cadre professionnel pour fournir la preuve d'une communication	Service client, ordres par téléphone
46 (2)	Filtres contre les atteintes aux données personnelles	Sites et applications ouverts au public
47	Consentement préalable pour lire ou écrire dans l'équipement terminal	Traceurs, kits de mesure d'audience
48	Prospection électronique : émetteur identifié, adresse valide pour demander l'arrêt	SMS et courriels commerciaux

Tableau 7.3. La vie privée dans la loi n° 2010/012

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 47 [25] : *« L'utilisation des réseaux de communications électroniques et des systèmes d'information aux fins de stocker les informations ou d'accéder à des informations stockées dans un équipement terminal d'une personne physique ou morale, ne peut se faire qu'avec son consentement préalable. »*

Portée. Un kit de mesure d'audience intégré à une application mobile, qui lit l'identifiant du téléphone, accède à des informations stockées dans l'équipement terminal. Il exige un consentement préalable, distinct de celui que la loi de 2024 demande pour le traitement lui-même. C'est le cas du traitement que l'audit découvrira dans l'application de NYANGA (Chapitre 9).

L'article 45 autorise l'enregistrement des communications « effectué dans le cadre professionnel en vue de fournir la preuve numérique d'une communication électronique ». L'enregistrement des appels du service client de NYANGA peut s'appuyer sur ce texte s'il sert à prouver les opérations convenues par téléphone. Il ne le peut pas s'il sert à évaluer les agents ou à entraîner un logiciel. La finalité décide, comme à l'article 11 de la loi de 2024.

7.5 Interception, Réquisitions et Entraide

L'organisation auditée détient des données que les enquêteurs peuvent demander. La loi de 2010 fixe le cadre de ces demandes. Les officiers de police judiciaire et les agents assermentés de l'Agence conduisent les enquêtes selon le Code de procédure pénale (article 52). En cas de crime ou de délit prévu par la loi, l'officier de police judiciaire peut intercepter et enregistrer des communications (article 49) et les personnels des opérateurs sont tenus au secret sur les réquisitions reçues (article 51). Les demandes venues de l'étranger passent par le ministère chargé des relations extérieures, sauf convention contraire (article 91) ; la Convention de Budapest en est une (Chapitre 3).

L'auditeur ne juge pas la régularité d'une enquête. Il vérifie que l'organisation sait recevoir une demande : qui la reçoit, comment son auteur et son fondement sont vérifiés, quelles données sont remises, quelle trace en est gardée. Une remise de données sur simple appel téléphonique d'un prétendu enquêteur est une violation de données (Chapitre 15).

7.6 Deux Lois, des Délits Voisins

L'article 74 de la loi de 2010 punit plusieurs atteintes aux données personnelles. Il a été écrit à une époque où aucune formalité préalable n'existait encore au Cameroun et il en parle pourtant.

Jurisprudence & Droit applicable

Loi n° 2010/012, article 74, alinéas 3 et 7 [25] : *« (3) Est puni d'un emprisonnement d'un (01) à trois (03) ans et d'une amende de 1.000.000 (un million) à 5.000.000 (cinq millions) F CFA ou de l'une de ces deux peines seulement, quiconque procède ou fait procéder, même par négligence au traitement des données à caractère personnel en violation des formalités préalables à leur mise en œuvre. [. . .] (7) Est puni d'un emprisonnement de six (06) mois à deux (02) ans et d'une amende de 5.000.000 (cinq millions) à 50.000.000 (cinquante millions) F CFA, ou de l'une de ces deux peines seulement, celui qui conserve des informations sous une forme nominative ou chiffrée au-delà de la durée légale indiquée dans la demande d'avis ou la déclaration préalable à la mise en œuvre du traitement automatisé. »*

Portée. L'alinéa 3 punit le traitement fait sans formalité préalable, « même par négligence ». Depuis 2024, cette formalité existe : c'est l'autorisation de l'article 19. L'alinéa 7 punit la conservation au-delà de la durée déclarée, délit que la loi de 2024 ne reprend pas en ces termes.

Comportement	2010	Loi n° 2024/017	2024
Traitement sans formalité préalable	74 (3)	Traitement sans autorisation (pénalité administrative)	55
Collecte par des moyens illicites	74 (4)	Collecte frauduleuse, déloyale ou illicite	63
Données révélant l'origine tribale, les opinions, les mœurs, sans accord exprès	74 (5)	Données sensibles sans consentement exprès	66
Détournement des informations	74 (6)	Détournement de finalité	67
Conservation au-delà de la durée déclarée	74 (7)	Pas de délit identique ; durée limitée	13
Divulgation portant atteinte à la considération	74 (8)	Divulgation portant atteinte à la dignité ou à la vie privée	68
Interception de données personnelles en transmission	74 (2)	Accès frauduleux	63

Tableau 7.4. Concordance indicative des délits des deux lois

Les peines diffèrent d'une colonne à l'autre. Quand deux textes punissent le même fait de peines différentes, lequel s'applique ? L'article 75 de la loi de 2024 abroge les dispositions « contraires », sans dire si une peine différente pour le même fait est une contrariété. La réponse appartient au juge pénal.

L'auditeur n'a pas à la donner. Il rattache l'écart aux deux articles, signale la concurrence et classe l'incertitude sur la peine parmi les NEK de critère. L'écart lui-même reste un NON : les deux lois le réprouvent.

7.7 Les Textes Connexes

D'autres textes touchent aux données personnelles d'une organisation camerounaise. Le tableau en donne la liste de travail du cours.

Texte	Ce qu'il apporte
Loi n° 2010/013 du 21 décembre 2010 sur les communications électroniques, modifiée par la loi n° 2015/006 du 20 avril 2015	Secret des correspondances, obligations des opérateurs envers les abonnés
Décret n° 2015/3759 du 3 septembre 2015	Identification des abonnés et des terminaux
Décret n° 2012/1643/PM du 14 juin 2012	Audit de sécurité obligatoire, notification des incidents à l'Agence
Loi-cadre n° 2011/012 du 6 mai 2011	Information et loyauté envers le consommateur
Loi n° 2023/009 du 25 juillet 2023, charte de protection des enfants en ligne	Obligations envers les moins de dix-huit ans
Code pénal (loi n° 2016/007 du 12 juillet 2016), articles 300 et 310	Secret de la correspondance, secret professionnel
Code de procédure pénale (loi n° 2005/007 du 27 juillet 2005), articles 102 et 154	Secret de l'enquête et de l'information judiciaire
Loi n° 2022/006 du 27 avril 2022 sur le secret bancaire, qui remplace la loi n° 2003/004 du 21 avril 2003	Confidentialité des informations des clients des établissements assujettis
Règlement n° 02/24/CEMAC/UMAC/CM du 20 décembre 2024, qui remplace celui du 11 avril 2016	Prévention du blanchiment : identification des clients, conservation des pièces
Règlement COBAC R-2023/01 du 19 décembre 2023	Diligences des établissements assujettis en matière de blanchiment
Règlement n° 03/16/CEMAC/UMAC/CM du 21 décembre 2016	Systèmes, moyens et incidents de paiement
Directive CEMAC n° 07/08-UEAC-133-CM-18 du 19 décembre 2008	Confidentialité des communications et des données de trafic, transposée par la loi n° 2010/013
Décret n° 83-166 du 12 avril 1983, code de déontologie des médecins	Secret médical

Tableau 7.5. Les textes connexes (références relevées en novembre 2026)

Une référence ne suffit pas à faire un critère. Avant d'inscrire l'un de ces textes au plan d'audit, l'auditeur le lit dans sa version officielle, relève les articles qui visent l'organisation et vérifie qu'il n'a pas été modifié depuis. La loi sur le secret bancaire en donne l'exemple : un audit conduit en 2026 sur la loi de 2003 appliquerait un texte remplacé depuis quatre ans. Le Chapitre 18 reprend ces textes secteur par secteur.

7.8 Choisir ses Critères

Cinq chapitres ont présenté des textes de nature et de portée différentes. Avant d'ouvrir une mission, l'auditeur décide lesquels serviront de critères. La règle tient en quatre lignes.

Démarche d'audit

Choisir les critères d'un audit de protection des données.

1. **L'obligatoire d'abord.** La loi n° 2024/017, la loi n° 2010/012 pour ce qui subsiste, les textes sectoriels et communautaires applicables à l'organisation. Ils entrent toujours dans les critères.
2. **L'étranger opposable ensuite.** Le RGPD pour les seuls traitements qui remplissent son article 3.
3. **Le contractuel.** Les clauses imposées par un client, un prestataire ou un investisseur, si le commanditaire veut qu'elles soient auditées.
4. **Le volontaire déclaré.** Une norme, un cadre ou un repère étranger, retenu comme référentiel ou comme critère de substitution et nommé comme tel.

Le résultat se présente dans une **carte d'applicabilité** : un tableau qui dit, pour chaque texte, son statut à l'égard de l'organisation.

Texte	NYANGA	MBOLO	NOUN PAY
Loi n° 2024/017	Obligatoire	Obligatoire	Obligatoire
Loi n° 2010/012, art. 41 à 48 et 74	Obligatoire	Obligatoire	Obligatoire
Loi n° 2010/012, art. 29	À qualifier	À qualifier	À qualifier
Textes CEMAC et COBAC	Obligatoires	Sans objet	Obligatoires
Secret médical	Sans objet	Obligatoire	Sans objet
RGPD	Sans objet	Sans objet	Obligatoire pour NOUN DIASPORA ; contractuel avec l'hébergeur
Cadre du NIST	Sans objet	Sans objet	Contractuel (investisseur)
ISO/IEC 27701	Sans objet	Sans objet	Volontaire (projet de certification)
Convention de Malabo	Comparatif	Comparatif	Comparatif

Tableau 7.6. La carte d'applicabilité des trois missions

La carte se joint au plan d'audit (Chapitre 8). Elle protège l'auditeur contre deux

reproches : avoir oublié un texte applicable, ou avoir reproché à l'organisation de ne pas respecter un texte qui ne la lie pas.

7.9 La Loi de 2010 à NYANGA

Scénario Opérationnel · Mission NYANGA. Les exigences de la loi n° 2010/012, août 2026

Constatations.

- L'application mobile intègre un kit de mesure d'audience qui lit l'identifiant du téléphone dès le premier lancement, avant tout écran d'information.
- Tous les appels au service client sont enregistrés et gardés deux ans. Le chef du service en écoute un échantillon chaque mois pour noter les agents.
- Les SMS de prospection n'indiquent aucun moyen de demander leur arrêt.
- Des relevés de compte sont envoyés aux clients depuis la messagerie personnelle des agents.
- Une analyse des risques de sécurité a été refaite après l'incident de 2025 et mise à jour en mars 2026.
- Les journaux de connexion de l'application sont gardés dix ans. Aucune note ne dit pourquoi.
- L'établissement n'a jamais fait l'objet d'un audit de sécurité de l'Agence, qui audite pourtant des établissements de microfinance. L'incident de mars 2025 ne lui a pas été notifié.

Analyse (confiance élevée sur les faits, moyenne sur la conservation). Cinq écarts ne dépendent d'aucune interprétation. Les deux points incertains tiennent à la même question : NYANGA CRÉDIT est-elle un exploitant de système d'information au sens de l'article 29 ?

Lecture auditologique · NYANGA CRÉDIT, exigences de la loi n° 2010/012

Exigence	Cote	Preuve
Le kit de mesure d'audience recueille un consentement préalable (art. 47)	NON	Analyse de l'application
L'enregistrement des appels sert la seule preuve (art. 45)	NON	Entretien, grille de notation
Les messages de prospection permettent de demander l'arrêt (art. 48)	NON	Échantillon de 20 SMS
Les communications avec les clients sont confidentielles (art. 42)	NON	Messageries personnelles
Les risques de sécurité sont gérés de façon continue (art. 26)	OUI	Analyse de mars 2026
L'audit de sécurité obligatoire a été réalisé (art. 32)	NON	Aucun audit, aucune démarche
L'obligation de conserver dix ans s'applique (art. 29)	NEK	Qualité d'exploitant non établie
La durée de dix ans est justifiée au regard de l'article 13 de la loi de 2024	NEK	Dépend de la ligne précédente

Décompte. Un OUI, cinq NON, deux NEK sur huit. $\mu = 0{,}125$ · $U = 0{,}25$ · $H = 1{,}30$ **bit**

Lecture. Domaine opaque. Les deux NEK sont de critère et se lèveraient ensemble si la notion d'exploitant était précisée. Les cinq NON appellent des mesures immédiates, dont le retrait du kit de mesure d'audience et une prise de contact avec l'Agence.

7.10 Ce que les Textes demandent à chaque Métier

Application Juriste conformité

Tenir la liste des textes applicables avec leur référence et la date de leur dernière lecture. Écrire, pour chaque point où deux textes se rencontrent, la lecture retenue par l'organisation et sa justification.

Application RSSI

Séparer les journaux gardés pour la preuve de ceux qui servent l'exploitation. Restreindre l'accès aux premiers et documenter leur durée.

Application Auditeur de la protection des données

Joindre la carte d'applicabilité au plan d'audit. Rattacher chaque écart à tous les articles qui le visent, dans les deux lois.

★ À retenir

- La loi n° 2010/012 reste applicable pour tout ce qui n'est pas contraire à la loi de 2024 : sécurité, conservation, vie privée dans les communications, délits.
- Elle impose une gestion continue des risques de sécurité (article 26) et un audit de sécurité obligatoire pour certains acteurs (articles 13 et 32).
- Quatre articles imposent de conserver des données dix ans. Ils fondent la conservation s'ils s'appliquent ; il faut d'abord établir à qui.
- L'article 47 exige un consentement préalable pour tout accès à l'équipement terminal ; l'article 45 limite l'enregistrement des communications à la preuve.
- L'auditeur choisit ses critères dans l'ordre : obligatoire, étranger opposable, contractuel, volontaire déclaré. Il les présente dans une carte d'applicabilité.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer trois règles de la loi de 2010 absentes de la loi de 2024 ;
- expliquer comment coter la conservation de journaux pendant dix ans ;
- dresser la carte d'applicabilité d'une organisation.

✍ Exercice 7.1. Quel article ★☆☆

Indiquez l'article de la loi n° 2010/012 qui s'applique : (a) une application installe un traceur sans rien demander ; (b) un établissement envoie des SMS publicitaires sans numéro pour se désinscrire ; (c) un responsable écoute les appels de ses agents à leur insu ; (d) une entreprise garde les enregistrements d'appels comme preuve des ordres reçus.

✍ Exercice 7.2. Les appels enregistrés ★★☆

Le service client de NYANGA enregistre tous les appels, les conserve deux ans et les écoute pour évaluer les agents. Analysez ce traitement au regard des articles 44 et 45 de la loi n° 2010/012 et des articles 9 et 11 de la loi n° 2024/017. Proposez une règle conforme.

✍ Exercice 7.3. La carte de MBOLO ★★☆

Le CENTRE MÉDICAL MBOLO envisage d'accueillir des patients envoyés par une organisation humanitaire établie à Genève, qui lui impose par contrat ses propres règles de protection des données. Refaites la colonne MBOLO du Tableau 7.6. Quels textes changent de statut et lesquels devez-vous lire avant de les retenir comme critères ?

✍ Exercice 7.4. Dix ans ou le nécessaire ★★★

M. KAMGA vous demande une réponse écrite : NYANGA doit-elle garder ses journaux de connexion dix ans ?

(a) Rédigez la note, en séparant ce qui est établi par les textes de ce qui relève d'une interprétation.

(b) Proposez une politique de conservation des journaux qui soit défendable dans les deux lectures de l'article 29.

(c) Dites quelles cotes de l'encadré de lecture changeraient si l'Agence confirmait par écrit que l'établissement est un exploitant au sens de la loi.

● Note

Pour aller plus loin.

➢ La loi n° 2010/012 [25], articles 24 à 51 et 74, dans son texte officiel.

➢ T. E. Minka Mi Nguidjoï, R. T. Massoussi Songo et D. Bialo [29], pour l'articulation des deux lois dans la chaîne pénale.

● Note

Transition. Le contexte est posé : ses sources, le règlement européen, les référentiels volontaires, les deux lois camerounaises et la manière de choisir entre eux. Il reste à s'en servir. La Partie IV ouvre la mission et commence par la manière de conduire un audit. C'est l'objet du Chapitre 8.

partie IV

Méthode : Auditer la Protection des Données

© MaletYon

8

CONDUIRE UN AUDIT DE PROTECTION DES DONNÉES

« Un audit ne dit pas si l'organisation est bonne.
Il dit ce qui est établi, et sur quelle preuve. »

Principe du cours

Niveau : *Fondamental* • Chapitres 1 et 2 ; méthode générale de l'audit (UE MSN-2S3-SEC08)

✦ Objectifs du chapitre

- ➢ Distinguer audit de conformité légale, audit contre une norme et audit de préparation.
- ➢ Rédiger le mandat, les critères et le périmètre d'une mission.
- ➢ Choisir des preuves selon leur force et documenter chaque constat dans un papier de travail.
- ➢ Décomposer la conformité en domaines et en exigences cotées OUI, NON ou NEK.
- ➢ Lire les mesures μ, U et H et appliquer une règle de décision écrite à l'avance.
- ➢ Protéger les données personnelles que l'audit lui-même manipule.

Avant de commencer : « montrez-nous la sécurité »

Yaoundé, jeudi 2 juillet 2026. Dans les bureaux de KORO AUDIT & CONFORMITÉ, Mme BELLO prépare la mission de NYANGA CRÉDIT avec son associé juriste, M. NGANDO. Le DSI de l'établissement a envoyé la veille un dossier de quarante pages : schémas du réseau, règles du pare-feu, rapport du test d'intrusion de 2025. « Voilà notre conformité », écrit-il.

M. NGANDO le parcourt et le referme. Le dossier ne dit rien des consentements, des durées, des droits des personnes, des contrats des prestataires ni des transferts. Il répond à une question que personne n'a posée. Mme BELLO commence par écrire ce que la

© MaletYon

mission doit établir, avec quels critères, sur quel périmètre, et ce qu'elle ne couvrira pas.

★ Attention

Violation typique. Confondre l'audit de protection des données avec un audit de sécurité informatique, et conclure à la conformité parce que les systèmes sont bien protégés.

Règle : les critères de l'audit sont les obligations de la loi et, le cas échéant, d'une norme désignée. La sécurité n'en est qu'un domaine parmi six ; des données bien gardées peuvent avoir été collectées sans droit.

8.1 Trois Sortes d'Audit

Audit	Critères	Usage
De conformité légale	Loi n° 2024/017, textes d'application, autres lois applicables	Dire si l'organisation respecte ses obligations ; préparer un contrôle ou un contentieux
Contre une norme	ISO/IEC 27701, ISO/IEC 27001	Préparer ou maintenir une certification (Chapitre 5)
De préparation	Loi et bonnes pratiques	Mesurer l'écart avant une échéance ; prioriser les chantiers

Tableau 8.1. Trois audits, trois jeux de critères

Ces audits peuvent être conduits par l'organisation elle-même (audit interne), par un cabinet qu'elle mandate (NYANGA, MBOLO), ou par un tiers qui certifie. Le contrôle de l'Autorité de protection, prévu par la loi (article 53) et dont les modalités relèvent de textes réglementaires (article 35), n'est pas un audit au sens de ce chapitre : c'est un contrôle administratif, qui peut conduire à des sanctions (Chapitre 6).

8.2 Les Principes de l'Auditeur

La norme ISO 19011 [14] pose sept principes pour tout audit de système de management. Ils s'appliquent sans changement à l'audit de protection des données ; on les résume ici en paraphrase.

1. **Intégrité** : honnêteté, diligence, respect des lois.
2. **Présentation impartiale** : rendre compte avec exactitude, y compris des difficultés rencontrées.
3. **Conscience professionnelle** : le soin et le jugement proportionnés à l'importance de la mission.
4. **Confidentialité** : la protection des informations obtenues, et ici des données personnelles consultées.

5. **Indépendance** : l'absence de conflit d'intérêts, fondement de l'objectivité des conclusions.
6. **Approche fondée sur la preuve** : des conclusions vérifiables, tirées d'un échantillon défini.
7. **Approche par les risques** : concentrer l'effort là où l'écart serait le plus grave pour les personnes.

Le quatrième principe prend ici un relief particulier. Pour vérifier un consentement, l'auditeur ouvre un dossier client ; pour tester les droits, il lit des réponses adressées à des personnes ; pour contrôler les journaux, il voit qui a consulté quoi. L'audit est lui-même un traitement : il a une finalité (la mission), une durée (celle de la conservation des papiers de travail) et des destinataires (le commanditaire). L'auditeur consulte sur place, copie le moins possible, masque les identités dans ses papiers et détruit les copies à l'échéance prévue au mandat (section 8.3).

8.3 La Déontologie de l'Auditeur

L'auditeur de la protection des données est soumis aux principes communs de l'audit de la section précédente. Son objet ajoute trois exigences.

8.3.1 Minimiser les données de l'audit

L'auditeur ne collecte que les données nécessaires à la preuve. Il consulte sur place plutôt que de copier, relève des indicateurs plutôt que des contenus, masque les identités dans ses papiers de travail (« client A, dossier 2018-0412 »), conserve les copies indispensables dans un espace chiffré et les détruit à la date prévue au mandat. Un auditeur qui emporterait un extrait du fichier clients sur une clé non chiffrée commettrait l'écart même qu'il est chargé de relever.

8.3.2 L'indépendance

L'indépendance interdit d'auditer son propre travail. KORO AUDIT a proposé au CENTRE MÉDICAL MBOLO, en juin, de rédiger ses procédures de protection des données ; s'il accepte, il ne pourra pas, en octobre, auditer ces mêmes procédures sans menacer son objectivité. Mme BELLO a refusé la mission de rédaction et conservé la mission d'audit.

8.3.3 Ce que l'auditeur découvre

L'auditeur peut découvrir des faits graves : un agent qui vend des fichiers, un traitement manifestement délictueux. Il en rend compte au commanditaire, par écrit et sans délai, comme son mandat doit le prévoir. Il ne mène pas d'enquête qui excéderait sa mission, et il ne saisit pas lui-même la justice, sauf obligation légale qui lui serait propre. Le Chapitre 15 montre comment un tel fait devient une violation à traiter, et le cours de forensique comment il devient une enquête.

8.4 Mandat, Critères, Périmètre

Démarche d'audit

Préparer une mission d'audit de protection des données.

1. Obtenir un mandat écrit : commanditaire, objectif, accès accordés, destinataires du rapport, date de remise.
2. Fixer les critères : articles de la loi retenus, textes d'application publiés, norme éventuelle, politiques internes.
3. Délimiter le périmètre : entités, sites, traitements, période ; écrire ce qui est exclu, et pourquoi.
4. Décomposer en domaines et en exigences, chacune formulée en question fermée.
5. Choisir, pour chaque exigence, le test et la preuve attendue.
6. Prévoir le traitement des données de l'audit : consultation sur place, masquage, durée de conservation des papiers.
7. Fixer à l'avance la règle de décision qui permettra de conclure à partir des cotes.

Les critères doivent être **publiés et applicables**. Un critère qui renvoie à un texte réglementaire non publié, comme la durée de conservation fixée « suivant les modalités fixées par voie réglementaire » (article 13), ne peut pas être appliqué tel quel : l'auditeur le remplace par un critère de substitution déclaré (« une durée fixée, justifiée et appliquée par l'organisation »), ou il cote NEK en précisant que l'incertitude tient au critère et non à la preuve. Les deux sources d'incertitude se distinguent dans le rapport : un NEK *de preuve* se lève en cherchant une pièce, un NEK *de critère* ne se lève qu'avec un texte.

8.5 Les Preuves et leur Force

Rang	Type de preuve	Exemple	Limite
1	Réexécution, test	Demande d'accès test suivie jusqu'à la réponse	Coûteuse, à encadrer
2	Trace produite par le système	Journal d'accès, horodatage de consentement	Dépend de la configuration
3	Document signé et daté	Contrat de sous-traitance, autorisation	Prouve l'engagement, pas son exécution
4	Observation	Affichage en agence, armoire ouverte	Instantanée
5	Déclaration	Entretien, questionnaire	À corroborer

Tableau 8.2. Hiérarchie indicative des preuves

Une déclaration seule ne permet jamais de coter OUI ; elle oriente la recherche d'une preuve de rang supérieur. Un document de rang 3 établit l'existence d'une règle, pas son application : un contrat qui impose des mesures de sécurité au prestataire ne prouve pas que le prestataire les applique.

Chaque constat se documente dans un **papier de travail** : l'exigence, le critère, le test, l'échantillon, la preuve (référence de la pièce), la cote, la date, l'auteur et le réviseur. Le papier de travail permet à un autre auditeur de refaire le raisonnement, et à l'audité de contester un constat précis plutôt qu'une impression.

● Note

La demande test. Pour vérifier le traitement des demandes de droits, l'auditeur peut adresser, avec l'accord écrit du commanditaire, une demande d'accès au nom d'un membre de l'équipe qui est réellement client. Une demande au nom d'une personne fictive, ou d'un client à son insu, serait une collecte déloyale. Le mandat doit prévoir ce test.

8.6 Décomposer et Coter

La conformité à une loi de soixante-quinze articles ne se cote pas d'un bloc. On la décompose en **domaines**, puis en **exigences**, chacune posée comme une question fermée à laquelle une preuve peut répondre OUI, NON ou NEK.

Code	Domaine	Articles	Exemple d'exigence
D1	Recensement et fondements	9–14, 19, 29	Le registre existe-t-il ?
D2	Droits des personnes	21, 37–47	Les demandes reçoivent-elles une réponse ?
D3	Sécurité et confidentialité	15, 24, 25, 27	Les accès sont-ils tracés ?
D4	Sous-traitants et transferts	16, 26, 30–32	Chaque prestataire a-t-il un contrat conforme ?
D5	Violations	22	Les violations sont-elles notifiées ?
D6	Gouvernance	27(2), 33, 35	L'évaluation d'impact est-elle faite quand le risque est élevé ?

Tableau 8.3. Les six domaines d'un audit de protection des données

Une exigence formulée avec « et » ou « ou » se scinde : « le registre existe et il est à jour » contient deux questions, qui peuvent recevoir deux cotes différentes. La règle d'atomicité évite qu'un NON ne désigne deux défauts à la fois.

8.7 Lire les Mesures, Conclure

Définition

Pour un ensemble de n exigences cotées, avec n_O réponses OUI, n_N NON et n_K NEK : **Taux de conformité** : $\mu = n_O/n$. **Taux d'incertitude** : $U = n_K/n$. **Entropie** : $H = -\sum p \log_2 p$, sur les trois cotes, en bits, entre 0 et $\log_2 3 \approx 1{,}585$.

Démarche d'audit

La règle de décision du cours.

1. U **d'abord.** Si $U \geq 0{,}20$, le domaine est opaque : aucune conclusion de conformité. On recherche les preuves, ou l'on conclut sur l'opacité elle-même.
2. μ **ensuite.** Si $U < 0{,}20$, le domaine est clair : conforme si $\mu \geq 0{,}5$ et sans NON sur une exigence pénalement sanctionnée ; non conforme sinon.
3. H **pour contrôler.** Une entropie élevée avec U faible signale un désaccord entre OUI et NON : on décompose avant de conclure.
4. **Les cotes prévalent.** Un seul NON grave (collecte déloyale, transfert illicite, données sensibles sans consentement) suffit à motiver une recommandation prioritaire, quelles que soient les mesures.

Les seuils sont ceux du cours ; chaque mission peut en fixer d'autres, à condition de les écrire dans le plan d'audit avant de coter. La quatrième règle est propre à la protection des données : la loi sanctionne pénalement certains écarts (articles 63 à 71), et un taux de conformité élevé ne compense pas une infraction.

8.8 Le Plan d'Audit de NYANGA

Scénario Opérationnel · Mission NYANGA. Le plan d'audit de KORO AUDIT, 2 juillet 2026

Mandat. Conseil d'administration de NYANGA CRÉDIT, 30 juin 2026 : « dire si l'établissement respecte la loi n° 2024/017 et recommander les mesures nécessaires ». Rapport au conseil le 25 septembre.
Critères. Les articles 2 à 52 de la loi n° 2024/017 ; les articles 26, 41 à 48 et 74 de la loi n° 2010/012 ; les textes d'application publiés à la date de la mission (aucun identifié) ; la politique de sécurité interne de 2025. La carte d'applicabilité du Chapitre 7 est jointe au plan.
Périmètre. Siège et trois agences tirées au sort (Dschang, Mbouda, Foumban) ; les onze familles de données du Chapitre 1 ; période du 1er janvier 2025 au 31 août 2026.
Exclusions déclarées : l'enquête pénale sur l'incident de mars 2025 et le contrôle de l'éditeur du logiciel bancaire dans ses propres locaux, à Abidjan.

Données de l'audit. Consultation dans les locaux de NYANGA ; papiers de travail avec identités masquées ; conservation trois ans, puis destruction attestée.
Règle de décision. Celle du cours, seuils inchangés.

Lecture auditologique · Le domaine D1 après la première semaine

Exigence	Cote	Preuve
Les familles de données sont recensées	OUI	Inventaire du 7 juillet
Un registre des activités de traitement est tenu	NON	Aucun registre
Chaque traitement a un fondement valable	NON	Formulaires, cahiers
L'autorisation de l'Autorité est demandée	NON	Attestation
Une durée de conservation est fixée	NON	Aucune règle
L'information de l'article 21 est fournie	NON	Formulaire 2016
L'identification des clients repose sur une obligation légale	NEK	Texte non produit
La vidéosurveillance repose sur un fondement valable	NEK	Fondement incertain

Décompte. Un OUI, cinq NON, deux NEK sur huit. $\mu = 0{,}125$ · $U = 0{,}25$ · $H = 1{,}30$ **bit**

Lecture. $U = 0{,}25 \geq 0{,}20$: selon la première règle, le domaine est opaque et ne permet aucune conclusion de conformité. Mais la quatrième règle s'applique déjà : cinq écarts sont établis, dont l'absence d'autorisation, sanctionnée par l'article 55. La conclusion provisoire est une non-conformité établie sur cinq exigences, avec deux exigences à instruire.

8.9 Ce que la Méthode demande à chaque Métier

Application Auditeur de la protection des données

Écrire le mandat, les critères, le périmètre et la règle de décision avant le premier entretien. Distinguer dans le rapport les NEK de preuve et les NEK de critère.

Application Responsable de traitement

Donner à l'auditeur un accès réel aux pièces, et nommer un interlocuteur par domaine. L'entrave à un contrôle de l'Autorité est un délit (article 70) ; l'entrave à un audit interne prive surtout l'organisation de sa propre information.

Application RSSI

Préparer les preuves de sécurité sous une forme exploitable : journaux exportés et datés, listes d'accès, rapports de sauvegarde. Un schéma de réseau ne prouve aucune mesure de protection des données.

★ À retenir

- L'audit de protection des données a pour critères la loi et, le cas échéant, une norme ; la sécurité n'en est qu'un domaine.
- Les sept principes de l'ISO 19011 s'appliquent ; la confidentialité impose de protéger les données que l'audit manipule.
- Un critère renvoyant à un texte non publié produit un NEK de critère, distinct d'un NEK de preuve.
- La conformité se décompose en six domaines et en exigences atomiques cotées OUI, NON ou NEK.
- La règle de décision lit U d'abord, μ ensuite, et un seul écart grave suffit à motiver une recommandation prioritaire.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- rédiger le mandat et le périmètre d'une mission ;
- classer des preuves selon leur force ;
- appliquer la règle de décision à un domaine coté.

✍ Exercice 8.1. Quelle preuve ★☆☆

Pour chaque exigence, proposez la preuve la plus forte possible : (a) les salariés ont été informés du traitement de leurs données ; (b) le prestataire de recouvrement efface les dossiers soldés ; (c) les accès aux dossiers clients sont limités aux agents de l'agence ; (d) les demandes d'accès reçoivent une réponse.

✍ Exercice 8.2. Rendre atomique ★★☆

Réécrivez en exigences atomiques : (a) « le registre existe et il est tenu à jour par un responsable désigné » ; (b) « les données sont chiffrées ou pseudonymisées » ; (c) « les contrats des prestataires prévoient la sécurité, la confidentialité et la restitution des données ».

✍ Exercice 8.3. Conclure sur D2 ★★☆

Le domaine D2 de NYANGA compte dix exigences : 2 OUI, 5 NON, 3 NEK. Calculez μ, U et H, appliquez la règle de décision et rédigez la phrase de conclusion du domaine.

✍ Exercice 8.4. L'audit comme traitement ★★★

Rédigez la clause du mandat qui encadre les données personnelles consultées par l'auditeur : finalité, accès, copies, masquage, conservation, destruction. Dites comment l'auditeur prouvera lui-même qu'il l'a respectée.

✍ Exercice 8.5. Une découverte ★★★

Pendant l'audit de MBOLO, un auditeur junior découvre qu'un agent exporte chaque semaine la liste des patientes de la maternité vers une adresse de messagerie personnelle. Rédigez la note au commanditaire, et dites ce que l'auditeur doit faire et ne pas faire.

● Note

Pour aller plus loin.

- ➢ L'ISO 19011 [14] et l'ISO/IEC 27007 [17], pour la conduite des audits.
- ➢ T. E. Minka Mi Nguidjoï, « Vers l'auditologie » [28], pour la décomposition et les mesures d'incertitude.

● Note

Transition. La première exigence de D1 est le registre. Comment recenser tous les traitements d'une organisation, y compris ceux que la direction ignore ? C'est l'objet du Chapitre 9.

9

CARTOGRAPHIER LES TRAITEMENTS

« Le registre dit ce que l'organisation croit faire.
La découverte dit ce qu'elle fait. »

Principe du cours

Niveau : *Fondamental* • Chapitres 1 et 8

✦ Objectifs du chapitre

- ➢ Énoncer le contenu obligatoire du registre des activités de traitement (article 29).
- ➢ Construire un registre à partir des processus, et non des applications.
- ➢ Confronter le registre déclaré à une découverte des données réellement stockées.
- ➢ Cartographier les flux de données, y compris vers les prestataires et l'étranger.
- ➢ Mesurer la complétude d'un registre et coter ce qui reste inconnu.

Avant de commencer : la liste noire de Foumban

Foumban, mardi 21 juillet 2026. Dans l'agence, l'équipe de KORO AUDIT examine avec l'accord du chef d'agence le contenu du partage réseau commun. Elle y trouve un classeur intitulé `mauvais_payeurs.xlsx` : 2 140 noms, numéros de téléphone, quartiers, montants impayés, et une colonne « remarques » où figurent des mentions comme « famille du chef de quartier, ne pas relancer » ou « commerçant bamoun, fiable malgré retard ». Le fichier est partagé entre six agences par messagerie. Il ne figure dans aucune liste de l'établissement.

Ce classeur est un traitement à part entière : il a une finalité (décider à qui prêter), des personnes concernées, des destinataires. Il contient des données sensibles (une origine régionale et des informations bancaires), et il sert à décider sans que les personnes le sachent.

© MaletYon

★ Attention

Violation typique. Établir le registre par questionnaire auprès des directions, puis le tenir pour complet.

Règle : un registre déclaratif se confronte à une découverte des données réellement stockées et des flux réellement observés. Ce que la découverte trouve et que le registre ignore mesure l'incomplétude du registre.

9.1 Le Registre de l'Article 29

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 29 [26] : *« (1) Le responsable du traitement ou le sous-traitant tient un registre physique ou numérique des activités de traitement effectuées sous leur responsabilité. (2) Le registre visé à l'alinéa 1 ci-dessus comporte les informations ci-après : le nom et les coordonnées du responsable du traitement et, le cas échéant, le nom du sous-traitant ; les finalités du traitement ; la description des catégories de personnes concernées et des catégories des données à caractère personnel ; les catégories de destinataires auxquels les données à caractère personnel ont été ou seront communiquées ; les documents attestant de l'existence de garanties appropriées ou le numéro de l'autorisation de l'Autorité de protection des données à caractère personnel. »*

Portée. L'obligation pèse sur le responsable *et* sur le sous-traitant. Le registre peut être papier ou numérique. Son dernier champ relie le registre aux autorisations : un traitement sans numéro d'autorisation ni garanties documentées est, par construction, un écart.

Le contenu légal est un minimum. Un registre utile à l'audit et à la gestion ajoute la base du traitement (consentement ou dérogation de l'article 9), la durée de conservation, les transferts hors du Cameroun, les mesures de sécurité, la date de la dernière revue et le propriétaire du traitement dans l'organisation.

Champ	Obligatoire	Ce que l'auditeur vérifie
Responsable, sous-traitant	Oui	Coordonnées exactes ; sous-traitants cohérents avec les contrats
Finalités	Oui	Une finalité par traitement, déterminée et explicite
Personnes et données	Oui	Catégories complètes, données sensibles signalées
Destinataires	Oui	Comparés aux flux observés
Garanties ou autorisation	Oui	Numéro d'autorisation ou pièces justificatives
Fondement	Recommandé	Cohérent avec l'article 9
Durée de conservation	Recommandé	Cohérente avec l'article 13
Transferts	Recommandé	Pays, garanties (Chapitre 14)
Mesures de sécurité	Recommandé	Renvoi aux mesures de l'article 27
Propriétaire, date de revue	Recommandé	Une personne, une date récente

Tableau 9.1. Les champs du registre

9.2 Recenser par les Processus

L'erreur la plus courante consiste à partir de l'inventaire des applications. Une application sert souvent plusieurs traitements (le logiciel bancaire sert la tenue des comptes, le crédit, le recouvrement et la lutte contre le blanchiment) ; à l'inverse, un traitement peut ne reposer sur aucune application (un cahier, un classeur partagé, un groupe de messagerie).

On part donc des **processus** de l'organisation : pour chaque direction, quelles activités, quelles personnes concernées, quelles décisions prises sur ces personnes. Le Chapitre 1 a fourni les familles de données ; on les croise ici avec les processus pour obtenir les traitements, puis on rattache à chacun les applications et les supports qui le portent.

Démarche d'audit

Établir le registre d'une organisation.

1. Lister les processus de chaque direction, avec un interlocuteur.
2. Pour chaque processus, identifier les personnes concernées et les décisions prises sur elles.
3. En déduire les traitements, un par finalité.
4. Rattacher à chaque traitement ses supports : applications, fichiers bureautiques, papier, messagerie.
5. Renseigner les champs du registre, avec la pièce qui fonde chaque champ.
6. Confronter le registre à la découverte et aux flux (sections 9.3 et 9.4).
7. Faire valider chaque fiche par son propriétaire, et dater la revue.

9.3 La Découverte des Données

La **découverte des données** consiste à chercher, dans les supports réels, des données personnelles que le registre ne mentionne pas. Elle se pratique sur quatre types de supports.

- **Les partages de fichiers et les postes** : recherche de motifs (numéros de téléphone, numéros de compte, numéros de carte nationale d'identité) dans les documents bureautiques.
- **Les bases de données** : lecture des schémas, à la recherche de colonnes nommées `nom`, `tel`, `cni`, `date_naissance`.
- **La messagerie et les outils de collaboration** : groupes, pièces jointes récurrentes, formulaires en ligne.
- **Le papier** : armoires, cahiers, archives d'agence.

La découverte est elle-même un traitement de données personnelles. Elle se fait avec l'accord écrit du commanditaire, sur les seuls supports de l'organisation, en ne relevant que des indicateurs (nom du fichier, emplacement, nombre d'occurrences, types de données) et jamais le contenu lui-même, sauf échantillon nécessaire à la qualification.

Note

Les faux positifs. Une recherche de motifs trouve des numéros qui n'en sont pas : un numéro de facture peut ressembler à un numéro de téléphone. On qualifie donc chaque fichier signalé par un examen rapide d'un échantillon, et l'on cote la proposition « ce fichier contient des données personnelles » OUI, NON ou NEK. Le laboratoire APDC-LAB-02 exerce cette qualification.

9.4 Cartographier les Flux

Un registre décrit des traitements ; une **cartographie des flux** décrit le chemin des données entre les traitements, les systèmes, les prestataires et les pays. Elle répond à trois questions que le registre laisse ouvertes : par où les données entrent-elles, où sont-elles stockées, et vers qui sortent-elles.

On l'établit à partir de trois sources indépendantes : les entretiens (ce que les équipes décrivent), les configurations (connecteurs, exportations planifiées, interfaces de programmation) et les traces réseau ou les factures (ce qui sort réellement, et vers qui l'organisation paie un service). Une facture mensuelle d'un service de formulaires en ligne révèle souvent un flux que personne n'avait déclaré.

L'article 36 encadre l'**interconnexion des fichiers**, définie à l'article 5 comme la mise en relation de données traitées pour une finalité avec d'autres données. Elle n'est licite que si elle est « nécessaire au respect d'une obligation légale », et ne doit entraîner ni discrimination ni réduction des droits. Le classeur des mauvais payeurs, alimenté par

six agences et rapproché du fichier des clients, est une interconnexion ; l'auditeur en cherche l'obligation légale, et n'en trouve pas.

9.5 Le Registre de NYANGA

Scénario Opérationnel · Mission NYANGA. Quarante-sept traitements, 20 au 24 juillet 2026

Constatations.

- Les entretiens avec les huit directions produisent un registre déclaratif de 38 traitements.
- La découverte sur les partages du siège et des trois agences signale 1 312 fichiers contenant des motifs de données personnelles ; l'examen d'un échantillon de 120 fichiers en confirme 97.
- Neuf traitements apparaissent que personne n'a déclarés : le classeur des mauvais payeurs ; deux groupes de messagerie où les agents échangent des photos de pièces d'identité ; un questionnaire de satisfaction hébergé par un service de formulaires étranger ; un kit de mesure d'audience intégré à l'application mobile, qui envoie les identifiants des téléphones à un tiers ; l'enregistrement des appels du service client ; le fichier des clients « privilégiés » du service marketing ; les badges d'accès du siège ; les CV reçus par messagerie.
- Les factures de 2025 révèlent trois prestataires absents de la liste des sous-traitants.

Analyse (confiance élevée). Le registre complet compte 47 traitements. Le registre déclaratif en couvrait 38, soit 81 % ; les neuf manquants sont ceux qui transfèrent des données à des tiers ou qui prennent des décisions sans procédure, c'est-à-dire les plus risqués.

Traitement · Liste des mauvais payeurs, agences de l'Ouest

Finalité réelle : décider de l'octroi de crédit et de la relance. **Personnes :** 2 140 débiteurs, dont des clients d'autres établissements cités par des tiers. **Données :** identité, téléphone, quartier, montant impayé, remarques incluant l'origine régionale (donnée sensible). **Destinataires :** six agences, par messagerie. **Ce que l'audit établit :** aucun fondement (NON), interconnexion sans obligation légale (NON), aucune information des personnes (NON) ; usage pour des décisions de crédit (OUI, entretiens et échantillon de 12 refus).

Lecture auditologique · Le registre de NYANGA, 24 juillet 2026

Exigence	Cote	Preuve
Un registre existe	OUI	Établi par l'audit
Le registre est complet	NON	9 traitements découverts
Chaque fiche comporte les champs de l'article 29	NON	Garanties absentes
Chaque traitement a un propriétaire	NON	14 sans propriétaire
Les interconnexions sont fondées sur une obligation légale	NON	Classeur des mauvais payeurs
Les flux vers les tiers sont tous connus	NEK	Trois prestataires découverts, recherche inachevée
Les fichiers papier des agences non visitées sont recensés	NEK	19 agences hors échantillon

Décompte. Un OUI, quatre NON, deux NEK sur sept.

$\mu = 0{,}14$ · $U = 0{,}29$ · $H = 1{,}38$ **bit**

Lecture. Le registre existe désormais, mais c'est l'audit qui l'a établi : le OUI ne crédite pas l'établissement. Avec $U = 0{,}29$, la complétude reste opaque ; l'incertitude se localise dans les flux et dans les dix-neuf agences non visitées.

9.6 Ce que la Cartographie demande à chaque Métier

Application Auditeur de la protection des données

Mesurer la complétude du registre par la découverte et les flux, et rapporter le taux de couverture. Un registre à 81 % n'est pas un registre « presque complet » : les traitements manquants sont rarement les moins risqués.

Application Délégué à la protection des données

Tenir le registre comme un outil vivant : une fiche par traitement, un propriétaire, une date de revue, et une procédure qui oblige tout nouveau projet à créer sa fiche avant de collecter.

Application RSSI

Fournir les sources de la découverte : exports des schémas de bases, journaux de flux sortants, inventaire des services en ligne payés. Bloquer les outils de partage qui contournent les traitements déclarés.

★ À retenir

- L'article 29 impose un registre au responsable et au sous-traitant, avec cinq catégories d'informations au minimum.
- On recense par les processus et les personnes concernées, puis on rattache les applications et les supports.
- Le registre déclaratif se confronte à la découverte des données et aux flux réels ; l'écart mesure son incomplétude.
- L'interconnexion de fichiers n'est licite que si une obligation légale l'impose (article 36).
- À NYANGA, 47 traitements, dont 9 inconnus de la direction et parmi eux un fichier de mauvais payeurs mentionnant l'origine régionale.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer les champs obligatoires du registre ;
- expliquer pourquoi un inventaire d'applications n'est pas un registre ;
- mesurer la complétude d'un registre à partir d'une découverte.

✍ Exercice 9.1. Traitement ou application ★☆☆

Dans la liste suivante, distinguez les traitements des moyens techniques : (a) la paie ; (b) le serveur de messagerie ; (c) le recrutement ; (d) la base Oracle ; (e) la vidéosurveillance des agences ; (f) le logiciel bancaire.

✍ Exercice 9.2. Une fiche de registre ★★☆

Rédigez la fiche de registre du traitement « enregistrement des appels du service client », avec les champs obligatoires et recommandés. Signalez les champs que vous ne pouvez pas remplir sans pièce supplémentaire.

✍ Exercice 9.3. Mesurer la complétude ★★☆

La découverte d'une autre organisation signale 800 fichiers, dont un échantillon de 50 donne 35 confirmations. Le registre déclaratif compte 20 traitements ; la découverte en ajoute 6. (a) Quel est le taux de couverture du registre déclaratif ? (b) Combien de fichiers contiennent probablement des données personnelles, et avec quelle réserve ?

✍ Exercice 9.4. La liste noire ★★★

Le directeur des crédits défend le classeur des mauvais payeurs : « Sans lui, nous prêterions à des fraudeurs. » Analysez sa licéité au regard des articles 5, 9, 11, 17, 36 et 48. Proposez une solution qui réponde au besoin de l'établissement dans le respect de la loi.

Note

Pour aller plus loin.

➢ L'ISO/IEC 27701 [24], pour la tenue des inventaires et des registres dans un système de management de la vie privée.

Note

Transition. Quarante-sept traitements ne présentent pas le même danger pour les personnes. Lesquels examiner d'abord, et lesquels exigent une évaluation d'impact ? C'est l'objet du Chapitre 10.

10

ÉVALUER LE RISQUE POUR LES PERSONNES

« Le risque que mesure la protection des données
est celui que court la personne, pas l'entreprise. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 2 et 9 ; notions de gestion des risques (UE MSN-2S3-SEC08)

✦ Objectifs du chapitre

- ➢ Distinguer le risque pour les personnes du risque pour l'organisation.
- ➢ Appliquer les articles 25 et 33 : évaluation du risque pour tout traitement, évaluation d'impact pour les traitements à risque élevé.
- ➢ Repérer les traitements à risque élevé à l'aide de critères déclarés.
- ➢ Conduire une évaluation d'impact selon les étapes de l'ISO/IEC 29134 : description, nécessité, risques, mesures, décision.
- ➢ Auditer une évaluation d'impact existante.

Avant de commencer : « le risque, c'est la panne »

Bertoua, lundi 6 avril 2026. Le CENTRE MÉDICAL MBOLO[1] prépare un service de téléconsultation pour les villages de la Kadey : un infirmier équipé d'une tablette examine le patient au centre de santé du village, et un médecin de Bertoua pose le diagnostic par visioconférence. La directrice, le Dr ABENA, a demandé au responsable informatique, M. YOUSSOUFA, une analyse des risques. Il revient avec un tableau de quinze lignes : coupure du réseau, panne de la tablette, vol du matériel, perte de recettes, retard du prestataire.

Aucune ligne ne parle des patients : de la consultation filmée qu'un tiers pourrait voir, du diagnostic d'une maladie stigmatisante transmis par un réseau partagé, de l'enfant

[1] Le CENTRE MÉDICAL MBOLO, sa directrice, son personnel, ses patients et son prestataire MEDISOFT SARL sont fictifs.

© MaletYon

examiné hors de la présence de ses parents. Le tableau mesure ce que l'établissement peut perdre. La loi demande ce que les personnes peuvent subir.

★ Attention

Violation typique. Présenter une analyse des risques pour l'organisation (pannes, pertes financières) comme l'évaluation exigée par la loi.

Règle : l'évaluation d'impact apprécie « la probabilité et la gravité des risques encourus par les droits et libertés des individus » (article 5). Ses événements redoutés concernent les personnes : la divulgation, la modification, la disparition de leurs données, et leurs conséquences sur leur vie.

10.1 Deux Obligations

La loi impose deux évaluations distinctes.

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 25, alinéa 1 [26] : *« Le responsable du traitement et le sous-traitant effectuent l'évaluation du risque présenté par le traitement des données à caractère personnel, suivant les critères d'évaluation, ainsi que les modalités d'examen et de validation fixées par voie règlementaire. »*

Loi n° 2024/017, article 33 [26] : *« (1) Tout type de traitement susceptible d'engendrer un risque élevé pour les droits et libertés des personnes physiques est subordonné à la réalisation préalable d'une évaluation d'impact des opérations de traitement envisagées sur la protection des données à caractère personnel. (2) Les conditions et les modalités de la réalisation de l'évaluation d'impact visées à l'alinéa 1 ci-dessus sont fixées par voie règlementaire. »*

Portée. Tout traitement doit être évalué (article 25) ; seuls ceux qui présentent un risque élevé exigent une évaluation d'impact préalable (article 33). Dans les deux cas, critères et modalités relèvent de textes d'application. En leur absence, l'auditeur vérifie que l'organisation a déclaré et appliqué une méthode reconnue ; il cote NEK de critère la conformité aux modalités réglementaires elles-mêmes.

■ Définition

Évaluation d'impact sur la protection des données : selon l'article 5, « procédure visant à analyser la probabilité et la gravité des risques encourus par les droits et libertés des individus résultant du traitement de données à caractère personnel ».

10.2 Repérer le Risque Élevé

La loi ne définit pas le « risque élevé ». En attendant le texte d'application, le cours retient une liste de critères déclarés, inspirée des pratiques internationales. Un traitement

qui en réunit deux ou plus est présumé à risque élevé et soumis à évaluation d'impact.

1. Des données sensibles au sens de l'article 5 (santé, biométrie, transactions bancaires, origine régionale…).
2. Des personnes vulnérables : mineurs, patients, salariés face à leur employeur, personnes en difficulté financière.
3. Une décision automatisée ou un profilage produisant des effets sur la personne (Chapitre 17).
4. Une surveillance systématique : vidéosurveillance, géolocalisation, contrôle des communications.
5. Un traitement à grande échelle, au regard du nombre de personnes ou de la durée.
6. Le croisement ou l'interconnexion de fichiers (article 36).
7. Une technologie nouvelle ou un usage nouveau d'une technologie.
8. Un transfert hors du Cameroun (Chapitre 14).

Ces critères sont une convention du cours, déclarée comme telle dans le plan d'audit ; ils ne remplacent pas le texte d'application quand il sera publié. La téléconsultation de MBOLO en réunit cinq : données de santé, patients vulnérables dont des mineurs, technologie nouvelle pour l'établissement, transmission par un réseau d'opérateur, hébergement chez un prestataire.

● Note

Le risque de vie privée selon le NIST et l'ISO/IEC 27557. Deux référentiels volontaires aident à décrire ce risque sans le confondre avec le risque de sécurité.

Le NIST part des *actions problématiques sur les données* : une opération peut nuire à une personne alors même que le système fonctionne comme prévu et qu'aucune attaque n'a eu lieu [2]. Le dossier d'une patiente lu par une secrétaire qui en avait le droit technique en est un exemple. Le NIST en tire trois objectifs d'ingénierie qui complètent confidentialité, intégrité et disponibilité : la prévisibilité (la personne peut s'attendre à ce qui est fait de ses données), la maîtrise (les données peuvent être corrigées, effacées, communiquées de façon sélective) et la dissociabilité (le traitement n'associe les données à une personne que si c'est nécessaire).

L'ISO/IEC 27557:2022 [20] applique à la vie privée la démarche de gestion du risque de l'ISO 31000. Elle demande de tenir ensemble deux lectures : la conséquence pour la personne et la conséquence qui en découle pour l'organisation.

Usage dans l'audit. Ni l'un ni l'autre n'est un critère de conformité au Cameroun. L'auditeur peut s'en servir pour vérifier qu'une évaluation n'a oublié aucune famille de risques, à condition de le déclarer dans son plan (Chapitre 5).

10.3 Les Étapes d'une Évaluation d'Impact

L'ISO/IEC 29134 [22] décrit le déroulement d'une évaluation d'impact ; la méthode publiée par l'autorité française [9] en donne une version outillée. On les résume ici en cinq étapes.

Démarche d'audit

Conduire une évaluation d'impact.

1. **Décrire** le traitement : finalités, données, personnes, flux, supports, durées, acteurs.
2. **Apprécier la nécessité et la proportionnalité** : fondement, finalités, données strictement utiles, information, droits.
3. **Apprécier les risques** pour les personnes : sources de risque, événements redoutés, gravité, vraisemblance.
4. **Choisir les mesures** qui ramènent chaque risque à un niveau acceptable, et évaluer le risque résiduel.
5. **Décider et documenter** : validation par le responsable, avis du délégué s'il existe, consultation des personnes ou de leurs représentants si possible, date de revue.

10.3.1 Trois événements redoutés

Les événements redoutés se rangent en trois familles, qui correspondent aux trois propriétés de la sécurité vues du côté de la personne :

- l'**accès illégitime** à ses données (confidentialité) : un voisin apprend un diagnostic ;
- la **modification non désirée** (intégrité) : un résultat d'analyse attribué au mauvais patient ;
- la **disparition** (disponibilité) : le dossier introuvable le jour d'une urgence.

10.3.2 Gravité et vraisemblance

Niveau	Gravité	Effet sur la personne
1	Négligeable	Désagrément surmonté sans difficulté
2	Limitée	Désagréments significatifs, surmontables avec quelques efforts
3	Importante	Conséquences importantes, surmontables avec de sérieuses difficultés (exclusion, perte d'emploi, préjudice financier)
4	Maximale	Conséquences irrémédiables (atteinte à la santé, à la sécurité physique, stigmatisation durable)

Tableau 10.1. Échelle de gravité (d'après la méthode de la CNIL, paraphrasée)

La vraisemblance se cote de même sur quatre niveaux (négligeable, limitée, importante, maximale), d'après les sources de risque et les vulnérabilités des supports. On reporte chaque risque sur une grille gravité × vraisemblance ; un risque dont la gravité ou la vraisemblance reste à 3 ou 4 après mesures n'est pas acceptable sans décision motivée.

Note

Coter l'inconnu dans une évaluation d'impact. Une vraisemblance qu'on ne sait pas apprécier (par exemple, la sécurité réelle d'un prestataire jamais audité) ne se cote pas « limitée » par défaut. On la note NEK, et l'on traite le risque comme s'il était au niveau le plus élevé plausible tant que la preuve manque.

10.4 La Téléconsultation de MBOLO

Scénario Opérationnel · Mission MBOLO. L'évaluation d'impact, avril 2026

Description. Patients des villages de la Kadey, dont des enfants ; données d'identité, symptômes, images de l'examen, diagnostic, prescription ; flux tablette, réseau mobile, serveur de MEDISOFT à Douala, poste du médecin à Bertoua ; enregistrement des séances envisagé « pour la formation ».
Nécessité. Le fondement est la préservation de la santé (article 9(2)) pour la consultation elle-même. L'enregistrement des séances pour la formation n'a pas ce fondement : il exige un consentement spécifique, et des parents pour les mineurs (article 9(3)).
Risques. Trois risques prioritaires :

- R1 : un tiers présent dans la salle du centre de santé voit ou entend la consultation (gravité 3, vraisemblance 3) ;
- R2 : interception ou accès indu aux images stockées chez le prestataire (gravité 4, vraisemblance NEK, prestataire jamais audité) ;
- R3 : erreur d'attribution d'une image au mauvais patient (gravité 4, vraisemblance 2).

Mesures. Salle fermée et procédure d'accueil ; chiffrement de bout en bout et contrat avec MEDISOFT révisé (Chapitre 13) ; double identification du patient ; abandon de l'enregistrement des séances.
Décision (8 mai 2026). R1 et R3 ramenés à un niveau acceptable. R2 reste NEK tant que MEDISOFT n'a pas été audité : le Dr ABENA lance le service sur deux villages seulement, en attendant l'audit du prestataire.

⚖ Lecture auditologique · L'évaluation d'impact de MBOLO, auditée en octobre 2026

Exigence	Cote	Preuve
L'évaluation a précédé la mise en service	OUI	Datée du 8 mai
Le traitement est décrit avec ses flux	OUI	Schéma, liste des données
Le fondement de chaque finalité est apprécié	OUI	Section nécessité
Les risques sont appréciés du point de vue des patients	OUI	Trois risques, échelles
Les mesures décidées sont en place	NON	Chiffrement de bout en bout non activé
Le risque lié au prestataire est apprécié	NEK	Audit de MEDISOFT non fait
La conformité aux modalités réglementaires est établie	NEK	Texte d'application non publié

Décompte. Quatre OUI, un NON, deux NEK sur sept. $\mu = 0{,}57$ · $U = 0{,}29$ · $H = 1{,}38$ **bit**

Lecture. L'évaluation est bien faite sur le papier, mais $U = 0{,}29$: le domaine reste opaque. Les deux NEK sont de nature différente : l'un est de preuve (l'audit du prestataire le lèvera), l'autre de critère (seul le texte d'application le lèvera). Le NON est un écart entre la décision et l'exécution, le plus fréquent dans les évaluations d'impact.

10.5 Auditer une Évaluation d'Impact

L'auditeur ne refait pas l'évaluation ; il vérifie qu'elle existe quand elle est exigée, qu'elle a été faite *avant* le traitement, qu'elle porte sur les personnes, que ses cotes sont justifiées, et surtout que les mesures décidées sont en place. Ce dernier point est le plus souvent en défaut : une évaluation d'impact décrit un traitement idéal, et le traitement réel s'en écarte.

Pour les traitements qui n'en ont pas, l'auditeur applique les critères de la section 10.2 aux fiches du registre. À NYANGA CRÉDIT, douze des quarante-sept traitements réunissent au moins deux critères ; aucun n'a fait l'objet d'une évaluation d'impact. Le classeur des mauvais payeurs en réunit quatre.

10.6 Ce que le Risque demande à chaque Métier

Application Responsable de traitement

Décider, au vu de l'évaluation, de lancer, d'adapter ou de renoncer, et signer cette décision. Le Dr ABENA a limité le service à deux villages : c'est une décision proportionnée à un risque encore inconnu.

Application Délégué à la protection des données

Conduire ou animer l'évaluation d'impact, rendre un avis écrit, et suivre la mise en place des mesures jusqu'à la preuve.

Application RSSI

Apporter l'appréciation de la vraisemblance : vulnérabilités des supports, menaces réelles, état des mesures. Signaler quand une mesure décidée n'est pas activée.

★ À retenir

- La loi exige une évaluation du risque pour tout traitement (article 25) et une évaluation d'impact préalable pour les traitements à risque élevé (article 33).
- Le risque évalué est celui des personnes : accès illégitime, modification non désirée, disparition de leurs données.
- En l'absence de texte d'application, le risque élevé se repère à l'aide de critères déclarés, au moins deux réunis.
- Une évaluation d'impact se juge surtout à la mise en place effective des mesures qu'elle décide.
- À MBOLO, l'évaluation est sérieuse mais une mesure n'est pas activée et le risque lié au prestataire reste NEK.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- distinguer les articles 25 et 33 ;
- dire si un traitement exige une évaluation d'impact, critères à l'appui ;
- coter la gravité et la vraisemblance d'un risque pour une personne.

✍ Exercice 10.1. Évaluation d'impact ou non ★☆☆

Dites si ces traitements exigent une évaluation d'impact, critères à l'appui : (a) la paie de 210 salariés ; (b) le pointage biométrique du personnel ; (c) la liste des fournisseurs ; (d) la notation automatique du crédit chez NOUN PAY ; (e) la vidéosurveillance d'une salle d'attente de pédiatrie.

✍ Exercice 10.2. Réécrire le tableau ★★☆

Reprenez le tableau de M. YOUSSOUFA. Pour trois de ses lignes, écrivez l'événement redouté du point de vue du patient, sa gravité et sa vraisemblance.

✍ Exercice 10.3. Le classeur des mauvais payeurs ★★☆

Conduisez les trois premières étapes de l'évaluation d'impact du classeur des mauvais payeurs de NYANGA. Quelle conclusion tirez-vous de l'étape de nécessité ?

✍ Exercice 10.4. Un risque inconnu ★★★

Le Dr ABENA vous demande s'il peut étendre la téléconsultation à vingt villages avant l'audit de MEDISOFT. Rédigez votre avis, en séparant les constatations de l'analyse, et en indiquant ce qui ferait passer R2 de NEK à une cote établie.

Note

Pour aller plus loin.

- L'ISO/IEC 29134 [22], pour les étapes de l'évaluation d'impact.
- La méthode PIA de la CNIL [9], librement accessible, pour ses échelles et ses modèles.

Note

Transition. Parmi les risques pour les personnes, l'un tient à leur capacité d'agir sur leurs propres données. Peuvent-elles savoir ce que l'on sait d'elles, le corriger, s'y opposer ? C'est l'objet du Chapitre 11.

11

AUDITER LES DROITS DES PERSONNES

« Un droit qu'on ne peut pas exercer
n'est qu'une phrase dans une loi. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 2 et 8

✦ Objectifs du chapitre

- ➢ Énoncer les droits des articles 37 à 46 et leurs limites.
- ➢ Vérifier qu'un canal de demande existe, qu'il est connu et que l'identité du demandeur est contrôlée sans excès.
- ➢ Mesurer les délais de réponse en l'absence de délai réglementaire, avec un critère de substitution déclaré.
- ➢ Tester le traitement d'une demande de bout en bout.
- ➢ Relier les défaillances aux sanctions administratives et pénales encourues.

Avant de commencer : trente et une lettres

Bafoussam, lundi 27 juillet 2026. La lettre de M. TAGNE n'est pas restée seule. L'audience de février a été relayée par la radio locale, et d'autres clients ont écrit. Me ETOUNDI a ouvert un classeur : entre le 23 juin et le 27 juillet, vingt-deux lettres, courriels et messages vocaux laissés au standard. Certaines demandent l'accès, d'autres l'effacement, deux s'opposent aux appels de prospection, une demande la rectification d'un nom mal orthographié qui bloque un virement.

Il n'existe ni procédure, ni délai, ni modèle de réponse. Les demandes arrivent par six canaux différents ; trois ont été perdues entre l'agence et le siège. La seule qui ait reçu une réponse complète est celle d'un client qui connaissait personnellement le directeur général.

© *MaletYon*

★ Attention

Violation typique. Considérer que l'organisation respecte les droits des personnes parce qu'elle n'a « jamais refusé » une demande.

Règle : le respect des droits se prouve par une procédure écrite, un registre des demandes, des réponses datées et un délai mesuré. Une demande perdue est un refus de fait ; une demande traitée par faveur n'est pas un droit exercé.

11.1 Les Droits de la Personne Concernée

Le titre III de la loi (articles 37 à 47) organise les droits. L'article 21 impose d'en informer la personne dès la collecte ; l'auditeur vérifie donc à la fois l'information et l'exercice.

Droit	Article	Contenu et limites
Accès	39	Confirmation du traitement, communication des données et de leur origine, finalités, destinataires ; copie contre paiement limité au coût de reproduction
Rectification	42	Rectifier, compléter, mettre à jour, verrouiller ou supprimer les données inexactes ou incomplètes, sur justification de l'identité
Effacement	37, 38	Cessation de la diffusion et effacement si les données ne sont plus nécessaires, si le consentement est vicié, retiré ou expiré, ou sans base légale ; sous réserve des obligations de conservation
Opposition	40	À tout moment, pour les catégories particulières de données, pour la prospection, et pour tout motif prévu par la loi ; droit propre des parents d'un mineur
Prospection	41	Communication à des tiers pour la prospection soumise à consentement préalable
Portabilité	43	Recevoir gratuitement ses données dans un format structuré, et les faire transmettre à un autre responsable ; exclue pour les missions d'intérêt public
Décision automatisée	44	S'opposer à une décision fondée exclusivement sur un traitement automatisé (Chapitre 17)
Décès	45	Fin du traitement au décès, sauf exceptions ; directives post-mortem ; mise à jour par les ayants droit
Limitation	46	Geler le traitement quand l'exactitude ou la finalité est contestée

Tableau 11.1. Les droits de la personne concernée

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 43 [26] : *« (1) La personne concernée a le droit de recevoir gratuitement les données à caractère personnel la concernant qu'elle a fournies à un responsable du traitement, dans un format structuré, couramment utilisé et lisible par machine. (2) La personne concernée a le droit à la portabilité de ses données. (3) Lorsque la personne concernée exerce son droit à la portabilité des données en application de l'alinéa 1 ci-dessus, elle a le droit d'obtenir que les données à caractère personnel soient transmises directement d'un responsable du traitement à un autre, si cela est techniquement possible. […] »*

Portée. L'accès peut être facturé au coût de reproduction (article 39) ; la portabilité est gratuite. Pour une microfinance, la portabilité permet à un client de faire transmettre son historique à un autre établissement : l'organisation doit être capable de l'exporter.

L'article 45 contient une disposition originale : le traitement des données d'une personne « cesse dès constatation de son décès », sauf obligation légale, défense en justice ou directives que la personne a laissées, et les ayants droit peuvent demander la mise à jour des informations du défunt. Pour un établissement financier, cela suppose une procédure de succession qui distingue ce que la loi impose de garder et ce qui doit cesser.

11.2 Le Délai, un Critère à Déclarer

L'article 47 renvoie à la voie réglementaire « les délais et les modalités d'examen des demandes ». Tant que ce texte n'est pas publié, la loi ne fixe aucun délai. L'auditeur a deux possibilités, à choisir dans le plan d'audit :

- coter NEK de critère toute exigence de délai réglementaire, ce qui est exact mais ne dit rien de la qualité du service ;
- déclarer un **critère de substitution**, par exemple « réponse complète dans les 30 jours calendaires », en précisant qu'il s'agit d'une référence de bonne pratique et non d'une obligation légale, et mesurer les délais contre ce critère.

KORO AUDIT a retenu la seconde, en la déclarant dans le plan d'audit. Le rapport dira donc « 30 jours (critère de l'audit) », jamais « 30 jours (délai légal) ».

D'où vient ce chiffre. Le plan d'audit doit donner la source du critère de substitution. Celui-ci s'inspire du RGPD, dont l'article 12, paragraphe 3, demande une réponse « dans un délai d'un mois à compter de la réception de la demande », délai qui peut être prolongé de deux mois pour les demandes complexes ou nombreuses [35]. KORO AUDIT l'a converti en trente jours calendaires pour le mesurer sans ambiguïté. Le règlement européen ne s'applique pas à NYANGA CRÉDIT. Il est emprunté ici comme référence et déclaré comme tel, selon la méthode du Chapitre 4 (section 4.5).

Pour un traitement soumis aux deux textes, comme ceux de NOUN DIASPORA, le délai d'un mois redevient une obligation.

11.3 Auditer le Traitement des Demandes

Démarche d'audit

Auditer l'exercice des droits.

1. Vérifier l'information : les droits et la manière de les exercer figurent-ils sur les formulaires et la notice (article 21) ?
2. Recenser les canaux réels : courrier, courriel, agence, téléphone, application, réseaux sociaux.
3. Obtenir le registre des demandes, ou le reconstituer à partir des canaux.
4. Pour chaque demande, relever la date de réception, le type, la vérification d'identité, la date et le contenu de la réponse.
5. Calculer les délais, la part des demandes traitées et la part traitées dans le délai retenu.
6. Réaliser une demande test, prévue au mandat, et la suivre jusqu'à la réponse.
7. Vérifier que les effacements et les oppositions ont été exécutés dans les systèmes, et pas seulement acceptés par lettre.

La vérification d'identité mérite attention. L'article 42 vise la personne « justifiant de son identité » : l'organisation doit s'assurer qu'elle ne communique pas les données d'un client à un imposteur, sans exiger plus que nécessaire. Demander une copie de la carte nationale d'identité pour une simple opposition aux SMS est excessif ; la demander pour communiquer un relevé de compte est justifié.

Le dernier point de la procédure est le plus souvent oublié. Une lettre « nous avons bien pris en compte votre demande d'effacement » ne prouve pas l'effacement : l'auditeur cherche le client dans la base, dans les sauvegardes de moins d'un mois, dans le fichier du prestataire.

11.4 Les Demandes de NYANGA

Scénario Opérationnel · Mission NYANGA. Le registre reconstitué, 31 août 2026

Constatations.

- 31 demandes reçues entre le 23 juin et le 31 août : 14 d'accès, 8 d'effacement, 5 d'opposition à la prospection, 3 de rectification, 1 de portabilité.
- 12 ont reçu une réponse complète, 7 une réponse d'attente, 12 aucune réponse.

Délai médian des réponses complètes : 26 jours ; 4 au-delà de 30 jours.

- ➢ Les 5 oppositions ont été acceptées par lettre ; 3 des 5 numéros figurent encore dans la liste d'appels de prospection du 28 août.
- ➢ La demande de portabilité a été refusée au motif que « le logiciel ne permet pas l'export ».
- ➢ La demande test de KORO AUDIT, envoyée le 27 juillet par courriel à l'adresse du service client, a reçu un accusé de réception automatique et aucune réponse au 31 août.

Analyse (confiance élevée). L'organisation n'a pas de procédure ; les réponses dépendent de la personne qui reçoit la demande. Les oppositions non exécutées exposent l'établissement à l'article 64, qui punit le traitement maintenu malgré l'opposition à la prospection.

Lecture auditologique · Le domaine D2, droits des personnes

Exigence	Cote	Preuve
Les personnes sont informées de leurs droits	NON	Formulaire 2016
Une procédure de traitement des demandes existe	NON	Aucune
Un registre des demandes est tenu	NON	Reconstitué par l'audit
Les demandes d'accès reçoivent une réponse	NON	12 sur 31
Les réponses respectent le critère de 30 jours	NON	8 sur 12
Les oppositions sont exécutées dans les systèmes	NON	3 numéros encore appelés
La portabilité est possible	NON	Refus du 14 août
L'identité est vérifiée de façon proportionnée	NEK	Pratiques variables, non documentées
Les effacements acceptés sont exécutés	NEK	Sauvegardes non examinées
La procédure de succession respecte l'article 45	OUI	Note de 2025, appliquée sur 3 dossiers

Décompte. Un OUI, sept NON, deux NEK sur dix.

$\mu = 0{,}10$ · $U = 0{,}20$ · $H = 1{,}16$ **bit**

Lecture. $U = 0{,}20$ atteint juste le seuil : le domaine est opaque selon la règle, mais de peu. La non-conformité est établie sur sept exigences, dont une, l'opposition non exécutée, relève d'une sanction pénale. La recommandation prioritaire ne dépend pas des deux NEK.

Jurisprudence & Droit applicable

Loi n° 2024/017, article 56 [26] : *« Est passible d'une amende d'un million (1 000 000) à dix millions (10 000 000) de francs CFA, tout responsable de traitement ou sous-traitant qui refuse de mettre à la disposition de la personne concernée, les informations sollicitées la concernant. »*

Portée. Une demande d'accès laissée sans réponse peut être qualifiée de refus. L'article 62 ouvre en outre à la personne la voie du référé « en cas d'atteinte grave aux droits », et la réparation devant la juridiction compétente : c'est la voie qu'annonçait M. TAGNE.

11.5 Ce que les Droits demandent à chaque Métier

Application Délégué à la protection des données

Centraliser les demandes sur un canal connu, tenir le registre, fixer un délai cible, vérifier l'exécution dans les systèmes, et rendre compte chaque mois du nombre de demandes et des délais.

Application Juriste conformité

Préparer des modèles de réponse par type de droit, et une grille des données à conserver malgré une demande d'effacement (comptabilité, procédure judiciaire, lutte contre le blanchiment).

Application Auditeur de la protection des données

Toujours vérifier l'exécution, pas seulement l'acceptation ; et déclarer dans le plan d'audit tout critère de délai qui n'est pas légal.

★ À retenir

- La loi reconnaît l'accès, la rectification, l'effacement, l'opposition, la portabilité gratuite, la limitation, des droits face aux décisions automatisées et des règles en cas de décès.
- Les délais de réponse relèvent d'un texte d'application ; en son absence, l'auditeur déclare un critère de substitution.
- Un droit exercé se prouve par un registre, une réponse datée et l'exécution dans les systèmes.
- Le refus de communiquer les informations (article 56) et le traitement maintenu malgré l'opposition (article 64) sont sanctionnés.
- À NYANGA, 12 demandes sur 31 ont reçu une réponse complète, et des oppositions acceptées n'ont pas été exécutées.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer les limites du droit à l'effacement ;
- expliquer pourquoi un délai de 30 jours ne peut pas être présenté comme légal ;
- vérifier l'exécution d'une opposition dans les systèmes.

✍ Exercice 11.1. Quel droit ★☆☆

Quel droit chaque demande exerce-t-elle ? (a) « Donnez-moi la liste des personnes à qui vous avez transmis mon numéro. » ; (b) « Je ne veux plus de vos SMS. » ; (c) « Transmettez mon historique de crédit à ma nouvelle banque. » ; (d) « Mon père est décédé ; supprimez son compte de vos campagnes. » ; (e) « Mon salaire est faux dans votre dossier. »

✍ Exercice 11.2. Mesurer les délais ★★☆

Voici les délais de réponse complète, en jours, de dix demandes : 5, 12, 18, 21, 26, 26, 31, 38, 44, 60. Calculez le délai médian et la part des réponses dans le critère de 30 jours. Rédigez la phrase du rapport.

✍ Exercice 11.3. L'effacement de M. TAGNE ★★☆

Dressez la liste des données de M. TAGNE que NYANGA peut effacer et de celles qu'elle doit conserver, avec pour chacune le texte qui le justifie ou la mention NEK si vous ne connaissez pas le texte.

✍ Exercice 11.4. La demande test ★★★

Rédigez la clause du mandat qui autorise la demande test, puis le papier de travail qui en rend compte. Quelles précautions prenez-vous pour que le test ne soit pas lui-même un traitement déloyal ?

Note

Pour aller plus loin.

- L'ISO/IEC 27701 [24], pour l'organisation du traitement des demandes des personnes.

Note

Transition. Les droits protègent la personne contre l'organisation. La sécurité la protège contre tous les autres : intrus, agents curieux, prestataires négligents. C'est l'objet du Chapitre 12.

12

AUDITER LA SÉCURITÉ DES DONNÉES

« La menace la plus fréquente sur un dossier médical n'est pas le pirate. C'est le collègue curieux. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 8 et 10 ; bases de la sécurité des systèmes

✦ Objectifs du chapitre

- Énoncer les obligations de sécurité des articles 22, 24, 25 et 27 de la loi.
- Traduire les dix exigences de l'article 27 en contrôles vérifiables.
- Exploiter des journaux d'accès pour établir des consultations sans lien avec la finalité.
- Distinguer la sécurité des systèmes de la protection des données contre les usages internes illégitimes.
- Auditer le rapport annuel de l'article 27, alinéa 2.

Avant de commencer : quatorze consultations en quarante-huit heures

Bertoua, mercredi 13 mai 2026. Une chanteuse connue de la région, admise deux jours plus tôt au CENTRE MÉDICAL MBOLO pour une intervention, apprend par un message vocal qui circule en ville le nom de son affection. Elle appelle la directrice. Le Dr ABENA demande à M. YOUSSOUFA d'extraire du dossier patient informatisé la liste des consultations de ce dossier.

L'extraction tient sur une page : quatorze consultations en quarante-huit heures, par six comptes. Deux sont ceux du chirurgien et de l'infirmière du service. Les quatre autres sont ceux d'une secrétaire de la maternité, d'un agent de la facturation, d'un brancardier dont le compte est partagé par l'équipe de nuit, et d'un stagiaire dont le stage s'est terminé en mars.

© MaletYon

★ Attention

Violation typique. Auditer la sécurité des données comme la sécurité d'un réseau : pare-feu, antivirus, mots de passe, sans regarder qui, à l'intérieur, consulte quoi.

Règle : la loi exige que les personnes autorisées n'accèdent « qu'aux données relevant de leur autorisation » et que l'on puisse vérifier « a posteriori » qui a consulté quoi (article 27). L'audit teste les droits d'accès et exploite les journaux.

12.1 Les Obligations de Sécurité

Les obligations de sécurité sont dispersées dans la loi. Les articles 7 et 15 posent la confidentialité ; l'article 24 réserve le traitement aux personnes « qui agissent sous l'autorité du responsable du traitement et seulement sur ses instructions », et renvoie au référentiel de mesures de l'Autorité ; l'article 25, alinéa 2, impose d'empêcher que les données soient « déformées, endommagées, indisponibles » ou que des tiers non autorisés y aient accès ; l'article 22, alinéa 2, cite le chiffrement et « l'instauration des autorisations restrictives d'accès aux données » ; l'article 27 en donne la liste la plus complète.

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 27, alinéa 1 (extraits) [26] : *« Le responsable du traitement et le sous-traitant des données à caractère personnel sont tenus : de garantir la disponibilité des données à caractère personnel notamment grâce à la mise en œuvre des mesures visant à garantir la résilience des systèmes d'information contenant les données à caractère personnel ; de garantir que lors de l'utilisation d'un système de traitement automatisé de données, les personnes autorisées ne puissent accéder qu'aux données relevant de leur autorisation ; [...] de garantir que puisse être vérifiée et constatée a posteriori l'identité des personnes ayant accès au système d'information contenant des données à caractère personnel, la nature des données qui ont été introduites, modifiées, altérées, copiées, effacées ou lues dans le système, ainsi que la période de manipulation de ces données ; [...] de sauvegarder les données par la constitution de copies de sécurité protégées ; [...] »*

Portée. L'article énumère dix obligations. La plus exigeante pour l'audit est la traçabilité : la loi vise les modifications, et aussi les données « lues ». Un système qui ne journalise pas les consultations ne permet pas de satisfaire l'article.

L'alinéa 2 du même article ajoute une obligation de compte rendu : le responsable « adresse à l'Autorité de protection des données à caractère personnel un rapport annuel sur l'état de mise en œuvre des mesures de sécurité contenues dans le référentiel des mesures techniques et organisationnelles ». Tant que le référentiel n'est pas publié, le contenu du rapport est un NEK de critère ; l'existence d'un état annuel des mesures, elle, peut être vérifiée.

12.2 Dix Obligations, Dix Contrôles

Obligation (article 27)	ISO/IEC 27002	NIST, *Protect-P*	Test d'audit
Disponibilité et résilience	5.30, 8.14	PR.PT-P	Plan de reprise exercé, durée d'indisponibilité mesurée
Accès limité à l'autorisation	5.15, 5.18, 8.3	PR.AC-P	Comparer droits et fonctions sur échantillon
Identité des destinataires vérifiée	5.14	PR.AC-P	Procédure de transmission, échantillon d'envois
Traçabilité a posteriori	8.15	PR.PT-P	Journal des consultations, test de reconstitution
Accès physique aux installations	7.1, 7.2	PR.AC-P	Visite, registre des accès
Supports protégés	7.10	PR.PT-P, PR.DS-P	Inventaire, chiffrement des supports amovibles
Introduction et modification non autorisées	8.2, 8.5	PR.DS-P	Comptes privilégiés, validation des saisies
Transmission protégée	5.14, 8.24	PR.DS-P	Chiffrement des flux, configuration
Sauvegardes protégées	8.13	PR.PO-P	Test de restauration, sauvegarde hors ligne
Autres mesures réglementaires	Non fixées	Sans objet	NEK de critère

Tableau 12.1. L'article 27, les mesures de l'ISO/IEC 27002:2022 et les catégories Protect-P du NIST (correspondances indicatives)

Les numéros de mesures renvoient à l'ISO/IEC 27002:2022 [19] et les catégories à la fonction *Protect-P* du cadre du NIST [30]. Les deux sont donnés à titre indicatif ; la correspondance n'est pas fixée par la loi. L'ISO/IEC 27701 [24] complète ces mesures par des exigences propres aux données personnelles (Chapitre 5).

Un second texte obligatoire. La loi n° 2010/012 s'ajoute à l'article 27. Son article 26 demande aux exploitants des systèmes d'information de protéger leurs systèmes, et ses articles 41 à 48 protègent la vie privée dans les communications (Chapitre 7). L'auditeur de la sécurité des données déclare donc les deux lois parmi ses critères. Une même constatation, par exemple un compte partagé, peut fonder un écart à l'article 27 de la loi de 2024 et à l'article 26 de la loi de 2010.

12.2.1 Les droits d'accès

L'audit des droits d'accès compare, pour un échantillon de comptes, les droits accordés aux besoins de la fonction. Trois anomalies reviennent partout : les comptes de personnes parties (stagiaires, intérimaires, salariés licenciés), les comptes partagés par une équipe, qui rendent la traçabilité impossible, et les droits trop larges accordés « pour dépanner » et jamais retirés.

12.2.2 Les journaux de consultation

Exploiter un journal de consultation, c'est répondre à une question précise : « Qui a consulté ce dossier, et chaque consultation avait-elle un lien avec la finalité ? » On rapproche chaque ligne du journal d'une pièce qui la justifie : le planning du service, l'affectation du patient, l'acte facturé. Une consultation sans pièce justificative n'est pas encore une faute ; c'est une consultation à expliquer.

Note

Un journal se lit avec ses limites. Un compte partagé ne désigne pas une personne ; une consultation par un compte ne prouve pas qui était au clavier ; un journal qui ne garde que trente jours ne permet pas de remonter plus loin. L'auditeur écrit ce que le journal établit (« le compte X a ouvert le dossier à telle heure ») et ce qu'il n'établit pas (« la personne derrière le compte »).

Combien de temps garder un journal de consultation. L'article 27 exige que l'on puisse vérifier « a posteriori » qui a lu quoi. Il ne dit pas pendant combien de temps. L'article 29 de la loi n° 2010/012 parle de dix ans, mais pour les données de connexion et de trafic que conservent certains exploitants, et le Chapitre 7 a montré que son application à un journal applicatif interne reste à qualifier. Aucun texte ne fixe donc la durée de conservation du journal des consultations d'un dossier médical ou d'un compte client. L'auditeur procède comme pour le délai de réponse aux demandes : il déclare un critère de substitution dans son plan. Le cours retient **un an au moins**, parce qu'une plainte ou une revue annuelle doit pouvoir remonter sur douze mois. Le rapport écrit « un an (critère de l'audit) » et non « un an (durée légale) ». Une organisation peut justifier une durée plus longue. Elle doit alors protéger le journal lui-même, qui est un fichier de données personnelles.

12.3 Le Dossier de la Patiente

Scénario Opérationnel · Mission MBOLO. Les quatorze consultations, 11 et 12 mai 2026

Compte	Consult.	Fonction	Pièce justificative
Chirurgien	4	Bloc opératoire	Programme opératoire
Infirmière du service	4	Chirurgie	Planning, soins notés
Secrétaire maternité	2	Maternité	Aucune
Agent de facturation	1	Facturation	Facture émise le 12 mai
Compte « nuit_brancard »	2	Partagé, 5 brancardiers	Aucune
Stagiaire	1	Stage terminé en mars	Aucune

Constatations. Quatorze consultations. Neuf sont justifiées par une pièce (chirurgien, infirmière, facturation). Cinq ne le sont pas : deux par la secrétaire de la maternité, deux par un compte partagé entre cinq personnes, une par le compte d'un stagiaire parti depuis deux mois.

Analyse (confiance élevée sur les comptes, faible sur les personnes). Cinq consultations sont sans lien établi avec la prise en charge. Le journal ne permet pas de savoir lequel des cinq brancardiers a utilisé le compte partagé, ni qui a utilisé le compte du stagiaire. La proposition « la fuite vient d'une consultation du dossier » reste NEK : le diagnostic a pu circuler oralement.

Le Dr ABENA a désactivé le compte du stagiaire et le compte partagé le jour même, et ouvert une procédure disciplinaire pour la secrétaire, qui a reconnu la consultation. Elle a aussi posé à KORO AUDIT, mandaté en octobre, une question plus large : combien d'autres dossiers ont été consultés de la même façon sans que personne ne s'en plaigne ?

Lecture auditologique · Le domaine D3 à MBOLO, octobre 2026

Exigence	Cote	Preuve
Les consultations sont journalisées	OUI	Journal MEDIKA
Les journaux sont conservés au moins un an	NON	90 jours
Chaque compte désigne une seule personne	NON	3 comptes partagés
Les comptes des personnes parties sont désactivés	NON	7 comptes actifs sur 31 départs
Les droits correspondent aux fonctions	NON	Facturation voit les diagnostics
Les journaux sont revus	NON	Aucune revue avant mai
Les sauvegardes sont restaurables	OUI	Test de restauration du 22 octobre
Les flux de téléconsultation sont chiffrés de bout en bout	NON	Option non activée
Le prestataire applique les mesures convenues	NEK	MEDISOFT non audité
Le rapport annuel de l'article 27(2) est conforme	NEK	Référentiel non publié

Décompte. Deux OUI, six NON, deux NEK sur dix.

$\mu = 0{,}20$ · $U = 0{,}20$ · $H = 1{,}37$ **bit**

Lecture. Domaine opaque au seuil ($U = 0{,}20$), mais six écarts établis qui touchent tous la traçabilité et les droits d'accès. La journalisation existe ; c'est son usage qui manque.

12.4 La Sécurité à NYANGA, après l'Incident

À NYANGA CRÉDIT, la sécurité s'est renforcée depuis mars 2025 : la passerelle a été remplacée, l'inventaire des équipements est tenu, les journaux sont centralisés. L'audit le constate et cote OUI les exigences correspondantes. Il relève aussi ce que l'incident n'a pas changé : les agents des agences voient les comptes de tous les clients du réseau, et non de leur seule agence ; les relevés de compte partent encore par messagerie personnelle quand un client le demande. La sécurité technique a progressé ; la limitation des accès à la finalité, non.

Lecture auditologique · Le domaine D3, sécurité et confidentialité, à NYANGA

Exigence	Cote	Preuve
L'équipement à l'origine de l'incident est remplacé et tenu à jour	OUI	Bon de livraison, état des correctifs
Un inventaire des équipements est tenu	OUI	Inventaire de mars 2026
Les journaux sont centralisés et conservés	OUI	Console, treize mois en ligne
Les sauvegardes sont restaurables	OUI	Test de restauration du 3 septembre
Chaque agent n'accède qu'aux clients de son agence	NON	Test sur six comptes d'agence
Les relevés sont transmis par un canal maîtrisé	NON	Envois par messagerie personnelle
Les habilitations sont revues	NON	Aucune revue depuis 2023
Les mesures suivent le référentiel de l'Autorité (art. 24)	NEK	Référentiel non publié

Décompte. Quatre OUI, trois NON, un NEK sur huit. $\mu = 0{,}50$ · $U = 0{,}125$ · $H = 1{,}41$ **bit**

Lecture. C'est le seul domaine clair de la mission ($U = 0{,}125 < 0{,}20$) et le seul où μ atteint le seuil. Il n'est pas conforme pour autant : les trois NON portent sur la limitation des accès, que l'article 27 exige et que l'article 26 de la loi n° 2010/012 recoupe. La règle demande l'absence d'écart grave. Le NEK est de critère et ne se lèvera qu'avec le référentiel.

12.5 Ce que la Sécurité demande à chaque Métier

Application RSSI

Supprimer les comptes partagés, désactiver les comptes à la date de départ, conserver les journaux de consultation assez longtemps pour enquêter, et les revoir régulièrement sur les dossiers sensibles.

Application Auditeur de la protection des données

Tester les droits d'accès contre les fonctions et rapprocher les journaux de pièces justificatives. Écrire ce que le journal établit sur un compte, et ce qu'il n'établit pas sur une personne.

Application Responsable de traitement

Tirer les conséquences disciplinaires d'une consultation injustifiée, et faire savoir au personnel que les consultations sont tracées et revues : la dissuasion fait partie de la mesure.

★ À retenir

- Les obligations de sécurité figurent aux articles 7, 15, 22, 24, 25 et 27 ; l'article 27 en donne dix, dont la traçabilité des données lues.
- Le responsable adresse un rapport annuel sur les mesures à l'Autorité (article 27, alinéa 2).
- Les menaces internes se contrôlent par les droits d'accès et l'exploitation des journaux de consultation.
- Un journal établit ce qu'un compte a fait, pas ce qu'une personne a fait ; les comptes partagés détruisent la traçabilité.
- À MBOLO, cinq consultations d'un dossier sensible sont sans lien établi avec la prise en charge ; six écarts sont établis dans le domaine de la sécurité.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- traduire une obligation de l'article 27 en test d'audit ;
- rapprocher un journal de consultation de pièces justificatives ;
- dire pourquoi un compte partagé est un écart à l'article 27.

✍ Exercice 12.1. Quel contrôle ★☆☆

Proposez un test d'audit pour chaque obligation : (a) les sauvegardes sont protégées ; (b) les supports amovibles ne sont pas lisibles par un tiers ; (c) l'identité des destinataires est vérifiée avant transmission ; (d) les données sont disponibles en cas de panne.

✍ Exercice 12.2. Lire un journal ★★☆

Le compte de l'agent de facturation a consulté le dossier une fois, le 12 mai à 16 h 04 ; la facture a été émise à 16 h 11. Le compte a aussi accès à l'onglet « diagnostic ». Quelles cotes donnez-vous aux propositions « cette consultation était justifiée » et « les droits de ce compte sont limités à sa fonction » ?

✍ Exercice 12.3. Combien d'autres dossiers ★★☆

Proposez une méthode pour répondre à la question du Dr ABENA : combien d'autres dossiers ont été consultés sans lien avec la prise en charge ? Précisez les données à extraire, les règles de rapprochement, l'échantillon, et la manière de protéger les données des patients pendant l'analyse.

✍ Exercice 12.4. Sécurisé mais non conforme ★★★

Le DSI de NYANGA affirme : « Depuis l'incident, notre sécurité est au niveau des meilleures banques. » Montrez, à partir des constats de la section 12.4, en quoi cette affirmation peut être vraie et l'établissement non conforme à l'article 27. Rédigez la recommandation.

● Note

Pour aller plus loin.

- ➢ L'ISO/IEC 27002:2022 [19], mesures de contrôle d'accès et de journalisation.
- ➢ L'ISO/IEC 27701 [24], pour les mesures propres aux données personnelles.

● Note

Transition. La Partie II a montré comment auditer. Il faut maintenant lire de près le cadre qui fournit les critères : la loi n° 2024/017 elle-même, son Autorité, ses sanctions, et le cadre africain dans lequel elle s'inscrit. C'est l'objet du Chapitre 6.

partie V

Pratique : de l'Écart à la Conformité

© *MaletYon*

13

SOUS-TRAITANTS ET RESPONSABLES CONJOINTS

« Confier ses données à un prestataire,
ce n'est pas lui confier sa responsabilité. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 1 et 9

✦ Objectifs du chapitre

- ➢ Appliquer les obligations des articles 16, 26 et 30 à un contrat de sous-traitance.
- ➢ Contrôler les clauses d'un contrat contre une liste de vérification déclarée.
- ➢ Vérifier que le sous-traitant applique ce que le contrat prévoit.
- ➢ Reconnaître une situation de responsables conjoints et vérifier la convention de l'article 31.
- ➢ Tirer les conséquences de l'article 20 : mêmes obligations pour le responsable et le sous-traitant.

Avant de commencer : un contrat de deux pages

Douala, lundi 17 août 2026. Mme BELLO rencontre le gérant de SOREC, le prestataire de recouvrement de NYANGA CRÉDIT. Chaque mois, SOREC reçoit par messagerie un classeur des débiteurs en retard : noms, téléphones, adresses, employeurs, montants. Ses agents appellent, se déplacent, parfois chez l'employeur.

Le contrat, signé en 2019, tient sur deux pages : objet, rémunération au pourcentage des sommes recouvrées, durée. Il ne dit rien des données : ni leur usage, ni leur sécurité, ni leur sort à la fin du dossier. Le gérant reconnaît sans difficulté que les classeurs des cinq dernières années sont conservés « au cas où », et que ses agents ont accès à tous les dossiers de tous les clients de SOREC.

© MaletYon

★ Attention

Violation typique. Tenir le prestataire pour seul responsable de ce qu'il fait des données, ou tenir le contrat pour une preuve que le prestataire protège les données.

Règle : le responsable « veille au respect » des mesures par son sous-traitant (article 16) et doit s'assurer qu'il offre des garanties suffisantes (article 30). Le contrat fixe les obligations ; l'audit vérifie qu'elles sont tenues.

13.1 Les Obligations de la Loi

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 30 [26] : *« (1) Lorsque le responsable du traitement recourt à un sous-traitant, il s'assure que celui-ci dispose des garanties suffisantes quant à la mise en œuvre des mesures techniques et organisationnelles appropriées de manière à ce que le traitement respecte les exigences de la présente loi. (2) Le traitement par un sous-traitant est régi par un contrat qui lie le sous-traitant au responsable du traitement. (3) Le contrat visé à l'alinéa 2 ci-dessus définit, notamment, le type de données à caractère personnel et les catégories de personnes concernées, les obligations et les droits du responsable du traitement, ainsi que du sous-traitant. »*

Portée. Le contrat est obligatoire ; son contenu minimal est court. Le mot « notamment » laisse au responsable le soin de le compléter pour satisfaire l'alinéa 1.

Trois autres articles complètent le régime. L'article 16 oblige le sous-traitant à « apporter des garanties suffisantes au respect des mesures de sécurité » et le responsable à veiller à leur application ; l'article 26 répète l'obligation de garanties pour la sécurité technique et organisationnelle ; l'article 20 assujettit le responsable et le sous-traitant « aux mêmes obligations ». L'article 23, alinéa 3, les rend enfin « solidairement responsables de toute publication de données à caractère personnel effectuée en l'absence du consentement de la personne concernée ».

Le sous-traitant doit aussi tenir son propre registre (article 29) et informer l'Autorité et les personnes d'une violation (article 22). Un prestataire qui ignore ces obligations n'est pas seulement un risque pour son client : il est lui-même en infraction.

13.2 Le Contrat de Sous-traitance

La loi ne fixe que trois éléments du contrat. Pour satisfaire l'obligation de garanties suffisantes, le cours retient une liste de vérification de douze clauses, déclarée comme critère d'audit et inspirée des normes ISO/IEC 27701 et 27018.

N°	Clause	Fondement
1	Types de données et catégories de personnes	Article 30(3)
2	Obligations et droits des deux parties	Article 30(3)
3	Objet, finalité et durée du traitement	Article 11
4	Traitement sur instructions documentées seulement	Article 24(2)
5	Confidentialité des personnes autorisées	Articles 24 et 25(3)
6	Mesures de sécurité, renvoi à l'article 27	Articles 16, 26, 27
7	Sous-traitance ultérieure soumise à accord	Article 30(1)
8	Assistance pour les droits des personnes	Articles 37 à 47
9	Information sans délai en cas de violation	Article 22
10	Restitution ou destruction en fin de contrat	Article 13
11	Droit d'audit du responsable	Article 16(2)
12	Lieu du traitement, transferts éventuels	Article 32

Tableau 13.1. Les douze clauses du cours (critère déclaré)

Les clauses 1 et 2 sont exigées par la lettre de la loi : leur absence est un NON sans discussion. Les dix autres traduisent l'obligation de garanties : leur absence est un NON au regard du critère déclaré, et le rapport le précise. Le laboratoire APDC-LAB-06 exerce cette lecture sur cinq contrats.

Note

Le droit d'audit. La clause 11 est la condition de toutes les autres. Sans droit d'audit, le responsable ne peut pas vérifier les garanties qu'il doit s'assurer d'obtenir ; il ne peut que croire le prestataire. Un prestataire qui refuse tout audit oblige l'auditeur à coter NEK chaque exigence qui dépend de lui, et le responsable à en tirer les conséquences.

Note

Quand le sous-traitant est européen. L'hébergeur de NOUN PAY est établi dans l'Union européenne. Il est donc soumis au RGPD pour ses propres traitements, quel que soit le pays de son client. L'article 28 du règlement lui impose de ne traiter les données que sur instruction documentée du responsable, de garantir la confidentialité, de n'engager un autre sous-traitant qu'avec autorisation, d'aider son

client à répondre aux demandes des personnes et de se prêter aux audits [35]. Son contrat type reprend ces clauses.

Trois conséquences pour l'auditeur camerounais. Le contrat de l'hébergeur contient déjà la plupart des douze clauses du cours, ce que l'on vérifie clause par clause sans le supposer. Ce contrat est écrit pour le droit européen : il ne cite ni l'article 30 de la loi n° 2024/017 ni l'Autorité camerounaise, et l'écart se note. Enfin le client reste responsable au titre de l'article 20, même face à un prestataire mieux armé que lui. Le Chapitre 4 traite le cas où le règlement s'applique aussi au client.

13.3 Vérifier l'Exécution

Un contrat parfait ne prouve rien de ce que fait le prestataire. L'audit des sous-traitants procède en trois cercles, du moins coûteux au plus probant :

1. **Les documents du prestataire** : registre, politique de sécurité, certificats, rapports d'audit indépendants. Un certificat ISO/IEC 27001 ou 27018 couvre un périmètre ; on vérifie qu'il inclut le service fourni.
2. **Le questionnaire et l'entretien**, recoupés par des pièces : liste des personnes ayant accès, journal des accès aux données du client, preuve des destructions.
3. **L'audit sur place**, exercé au titre de la clause 11, pour les prestataires qui portent les traitements les plus risqués.

Le choix du cercle suit le risque. Un fournisseur de papeterie qui ne reçoit qu'une adresse de livraison ne justifie qu'un contrôle documentaire ; un hébergeur de dossiers médicaux justifie un audit sur place.

13.4 Les Responsables Conjoints

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 31 [26] : *« (1) En cas de traitement conjoint, les responsables déterminent les finalités, ainsi que les moyens du traitement et en sont solidairement responsables. (2) Les responsables conjoints du traitement définissent de manière transparente, par une convention rendue publique, leurs obligations respectives aux fins d'assurer le respect des exigences de la présente loi, notamment en ce qui concerne leurs rôles respectifs, leurs relations vis-à-vis de la personne concernée, l'exercice des droits de la personne concernée, ainsi que leurs obligations respectives quant à la communication des informations visées à l'article 21 ci-dessus. (3) Nonobstant les termes de la convention visée à l'alinéa 2 ci-dessus, la personne concernée exerce les droits que lui confère la présente loi à l'égard des responsables du traitement. »*

Portée. La convention doit être *rendue publique* : c'est une exigence plus forte que celle du droit européen, qui n'impose que de mettre « les grandes lignes » à

disposition. La personne peut s'adresser à l'un ou l'autre responsable, quelle que soit la répartition convenue.

Il y a responsabilité conjointe quand deux organisations décident ensemble de la finalité et des moyens, et pas quand l'une exécute les instructions de l'autre. NYANGA CRÉDIT et SAWA ASSURANCES[1] proposent ensemble une assurance des emprunteurs : NYANGA collecte le questionnaire de santé à l'agence, SAWA ASSURANCES décide de l'acceptation du risque, et les deux ont conçu ensemble le formulaire et le circuit. Ce sont des responsables conjoints, et le questionnaire de santé est une donnée sensible.

13.5 Les Contrats de NYANGA et de MBOLO

Scénario Opérationnel · Missions NYANGA et MBOLO. Cinq contrats, 17 au 21 août 2026

Contrat	Cl. 1–2	Cl. 3–12	Audit	Observation
SOREC (recouvrement)	0/2	0/10	Non	Classeurs de cinq ans conservés
Éditeur du logiciel bancaire	2/2	6/10	Non	Hébergement à Abidjan, pas de clause de transfert
Opérateur de SMS	1/2	3/10	Non	Contrat type de l'opérateur
MEDISOFT (avenant 2026)	2/2	10/10	Oui	Avenant du 20 mai, audit prévu en octobre
SAWA ASSURANCES (conjoint)	sans objet	sans objet	sans objet	Convention non rédigée

Constatations. Sur quatre contrats de sous-traitance, un seul contient les douze clauses (MEDISOFT, depuis l'avenant de mai). SOREC n'a aucune clause. L'éditeur du logiciel bancaire n'accepte pas d'audit et ne mentionne pas le pays d'hébergement. Aucune convention de responsabilité conjointe n'existe avec SAWA ASSURANCES. **Analyse** (confiance élevée sur les contrats, faible sur l'exécution). Les écarts contractuels sont établis. Pour l'exécution, seul SOREC a été vu : la conservation de cinq ans de classeurs est un écart à l'article 13, dont NYANGA répond aussi (article 20).

[1] SAWA ASSURANCES est fictive.

Lecture auditologique · Le domaine D4, sous-traitants, à NYANGA

Exigence	Cote	Preuve
Chaque sous-traitant est lié par un contrat	OUI	Trois contrats
Les contrats définissent données et personnes (art. 30(3))	NON	SOREC, opérateur
Les contrats contiennent les douze clauses	NON	Un sur trois au mieux
Le droit d'audit est prévu	NON	Aucun contrat
SOREC détruit les données des dossiers clos	NON	Classeurs conservés
L'éditeur applique les mesures de sécurité convenues	NEK	Pas d'audit, pas de rapport
L'opérateur de SMS limite l'usage des numéros	NEK	Aucune pièce
La convention avec SAWA ASSURANCES est publique	NON	Inexistante

Décompte. Un OUI, cinq NON, deux NEK sur huit. $\mu = 0{,}125$ · $U = 0{,}25$ · $H = 1{,}30$ **bit**

Lecture. Domaine opaque ($U = 0{,}25$) : on ne sait pas ce que font deux des trois prestataires. Le manque de droit d'audit explique les deux NEK : corriger les contrats est la condition pour lever l'incertitude.

13.6 Ce que la Sous-traitance demande à chaque Métier

Application Juriste conformité

Rédiger un avenant type aux douze clauses, le négocier en commençant par les prestataires les plus exposés, et tenir à jour la liste des sous-traitants avec leur contrat.

Application Responsable de traitement

Refuser ou quitter un prestataire qui refuse le droit d'audit pour un traitement sensible. La responsabilité solidaire et l'article 20 font que ses manquements sont aussi les vôtres.

Application Auditeur de la protection des données

Distinguer dans le rapport les écarts contractuels (établis sur pièces) et les écarts d'exécution (établis seulement là où l'on a pu vérifier), et coter NEK l'exécution des prestataires non vus.

★ À retenir

- Tout recours à un sous-traitant exige un contrat qui définit au moins les données, les personnes, les obligations et les droits des parties (article 30).
- Le responsable s'assure des garanties du sous-traitant et veille à leur application (articles 16 et 30) ; les deux ont les mêmes obligations (article 20).
- Le cours déclare un critère de douze clauses, dont le droit d'audit, condition de toutes les autres.
- Les responsables conjoints fixent leurs obligations dans une convention rendue publique (article 31).
- À NYANGA, aucun contrat ne prévoit d'audit, et SOREC conserve cinq ans de données de débiteurs.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- contrôler un contrat contre les douze clauses ;
- distinguer sous-traitant et responsable conjoint ;
- choisir le cercle de vérification adapté au risque d'un prestataire.

✍ Exercice 13.1. Sous-traitant ou conjoint ★☆☆

Qualifiez la relation : (a) un cabinet comptable qui établit la paie de MBOLO ; (b) un laboratoire d'analyses qui reçoit les prélèvements et envoie les résultats au médecin ; (c) l'hébergeur de NOUN PAY ; (d) NYANGA et SAWA ASSURANCES pour l'assurance des emprunteurs.

✍ Exercice 13.2. Lire un contrat ★★☆

Le contrat de l'opérateur de SMS prévoit que « l'opérateur pourra utiliser les données d'acheminement pour améliorer ses services et proposer des offres à ses abonnés ». Qualifiez l'opérateur pour cette utilisation, et dites quelles clauses vous ajoutez.

✍ Exercice 13.3. La convention publique ★★☆

Rédigez les rubriques de la convention entre NYANGA et SAWA ASSURANCES exigée par l'article 31. Qui recueille le consentement au questionnaire de santé, et sur quel fondement ?

✍ Exercice 13.4. Le refus d'audit ★★★

L'éditeur du logiciel bancaire refuse tout audit, invoquant la sécurité de ses autres clients. Proposez trois solutions qui permettraient à NYANGA de s'assurer des

garanties exigées par l'article 30, et dites comment vous coterez la proposition « l'éditeur applique les mesures convenues » dans chaque cas.

Note

Pour aller plus loin.

- L'ISO/IEC 27701 [24], pour les obligations des sous-traitants.
- L'ISO/IEC 27018 [16], pour l'hébergement en nuage.

Note

Transition. L'éditeur du logiciel bancaire héberge les comptes à Abidjan, et l'hébergeur de NOUN PAY en Europe. Les données quittent le Cameroun : c'est un transfert, soumis à autorisation. C'est l'objet du Chapitre 14.

14

LES TRANSFERTS INTERNATIONAUX

> « Une donnée hébergée à l'étranger a quitté le Cameroun, même si on la consulte depuis Bafoussam. »
>
> Principe du cours

Niveau : *Intermédiaire* • Chapitres 9, 6 et 13

✦ Objectifs du chapitre

- ➢ Reconnaître un transfert international au sens de l'article 5, y compris l'hébergement et l'accès à distance.
- ➢ Appliquer les quatre vérifications de l'article 32.
- ➢ Cartographier les flux sortants d'une organisation à partir de sources indépendantes.
- ➢ Coter les transferts quand l'Autorité n'a publié ni liste de pays ni clauses types.
- ➢ Situer la tension entre transferts et coopération pénale.

Avant de commencer : « nos serveurs, c'est le nuage »

Bafoussam, lundi 21 septembre 2026. Mme KENFACK, responsable produit de NOUN PAY, présente l'architecture de l'application à KORO AUDIT : « Tout est dans le nuage. » Où, exactement ? Elle cherche. L'hébergeur principal est établi dans l'Union européenne ; la vérification d'identité par selfie est confiée à un prestataire dont elle ne connaît pas le pays ; l'outil de mesure d'audience et la messagerie d'entreprise sont américains ; le support client de nuit est assuré par un centre d'appels au Maroc, qui consulte les comptes à distance.

Aucun de ces flux n'a été autorisé. Mme KENFACK pensait qu'un transfert supposait d'« envoyer des fichiers à l'étranger » ; l'hébergement et la consultation à distance ne lui semblaient pas en être.

© MaletYon

★ Attention

Violation typique. Réduire le transfert à l'envoi de fichiers, et oublier l'hébergement étranger, les services en ligne et la consultation à distance depuis l'étranger.

Règle : tout acheminement de données au-delà des frontières est un transfert, quel qu'en soit le moyen. Il exige une autorisation préalable de l'Autorité, après les vérifications de l'article 32.

14.1 Qu'est-ce qu'un Transfert

■ Définition

Transfert international de données : selon l'article 5, « acheminement des données à caractère personnel au-delà des frontières d'un pays vers un autre, que ce soit vers un État tiers ou une organisation internationale ».

La définition vise l'*acheminement*, pas le moyen. Sont des transferts : l'envoi d'un fichier à un partenaire étranger ; l'hébergement d'une base chez un prestataire étranger ; l'utilisation d'un service en ligne dont les serveurs sont à l'étranger (messagerie, formulaires, mesure d'audience) ; la consultation à distance de données stockées au Cameroun par une personne située à l'étranger, puisque les données traversent la frontière pour s'afficher sur son écran. L'auditeur qui hésite sur un cas le cote comme transfert et le signale : la qualification restrictive exposerait l'organisation aux articles 60 et 69.

14.2 L'Article 32

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 32 [26] : *« (1) Le transfert de données à caractère personnel vers un Etat étranger, ou à une organisation internationale, est subordonné à l'obtention d'une autorisation préalable délivrée par l'Autorité de protection des données à caractère personnel dans les conditions permettant de garantir l'exercice des droits de la personne concernée. (2) A l'occasion de la délivrance de ladite autorisation, l'Autorité de protection des données à caractère personnel doit préalablement s'assurer : que le pays de destination des données à caractère personnel offre un niveau de protection suffisant ; de l'entrée en vigueur préalable d'un instrument juridique signé avec le pays de destination des données à caractère personnel transférées, en liaison avec les administrations et organismes compétents ; de l'assujettissement de l'entité sollicitant l'importation des données à caractère personnel aux règles contraignantes de sécurité en matière de protection desdites données ; de la souscription préalable, par les entités importatrices et exportatrices concernées, de clauses contractuelles types en matière de transfert à l'international des données à caractère personnel, édictées et publiées par l'Autorité de protection des données à caractère personnel. (3) Les modalités de délivrance de l'autorisation*

prévue à l'alinéa 1 ci-dessus sont fixées par voie réglementaire. »

Portée. Les quatre vérifications sont énumérées sans « ou » : la lecture littérale les rend cumulatives. Le deuxième point, un instrument juridique « signé avec le pays de destination », est particulièrement exigeant ; il suppose un accord d'État à État.

L'article 53 charge l'Autorité d'établir la liste des pays « reconnus comme offrant un niveau de protection [...] équivalent » et l'article 5 définit les **clauses contractuelles types** comme celles que l'Autorité élabore et publie pour encadrer les transferts. Ni la liste ni les clauses n'étaient publiées en novembre 2026.

14.2.1 Coter sans liste ni clauses

L'auditeur se trouve devant quatre conditions dont trois dépendent d'instruments publics inexistants. Il décompose :

- « Le transfert est autorisé » : NON s'il n'existe pas d'autorisation, comme pour tout traitement.
- « Le pays de destination offre un niveau suffisant » : NEK de critère tant que la liste n'existe pas ; l'auditeur peut décrire, à titre d'information, le cadre du pays (une loi de protection, une autorité), sans en tirer de cote.
- « L'importateur est soumis à des règles contraignantes de sécurité » : cotable sur pièces (contrat, certificat ISO/IEC 27018, rapport d'audit).
- « Les clauses contractuelles types sont souscrites » : NEK de critère tant qu'elles ne sont pas publiées.
- « L'organisation a documenté chaque transfert et préparé sa demande » : cotable sur pièces.

Note

Le modèle européen, en comparaison. Le droit européen admet des transferts fondés sur une décision d'adéquation, des clauses contractuelles types adoptées par la Commission, des règles d'entreprise contraignantes, ou des dérogations ; il demande d'évaluer, au cas par cas, la législation du pays de destination [7]. La loi camerounaise ajoute à cet arsenal l'autorisation de l'Autorité et l'instrument signé d'État à État. Les outils européens peuvent servir de bonne pratique documentaire ; ils ne valent pas autorisation.

14.3 Cartographier les Flux Sortants

On établit la liste des transferts à partir de trois sources indépendantes :

1. **Les contrats et factures** : chaque service payé à un prestataire étranger est un transfert probable ; le contrat dit parfois où sont les serveurs.

2. **Les configurations et le code** : adresses des services appelés par l'application, bibliothèques intégrées (mesure d'audience, vérification d'identité, notifications).
3. **Les traces réseau** : noms de domaine résolus et volumes échangés vers l'extérieur, rapprochés d'une base de localisation des adresses.

La localisation d'une adresse IP est approximative : un réseau de diffusion de contenu répond depuis le point le plus proche, et un prestataire peut stocker ailleurs qu'il ne répond. L'auditeur ne déduit pas le lieu de stockage d'une adresse ; il le cherche dans le contrat ou la documentation du prestataire, et cote NEK quand il ne le trouve pas. Le laboratoire APDC-LAB-07 exerce ce rapprochement.

14.4 Les Flux de NOUN PAY

Scénario Opérationnel · Mission NOUN PAY. Six flux sortants, 21 au 25 septembre 2026

Flux	Données	Pays	Source de la preuve
Hébergement principal	Toutes	Union européenne	Contrat, console
Vérification d'identité	Selfies, pièces d'identité	NEK	Code de l'application ; contrat muet
Mesure d'audience	Identifiants, parcours	États-Unis	Code, trafic
Messagerie d'entreprise	Échanges avec les clients	États-Unis	Facture, documentation
Support de nuit	Consultation des comptes	Maroc	Contrat, journaux d'accès
SMS	Numéros, messages	Cameroun	Contrat (pas un transfert)

Constatations. Cinq transferts sur six flux sortants. Aucun n'est autorisé, aucun n'est mentionné dans l'information des clients (article 21). Le pays de traitement des selfies, données biométriques, n'est établi par aucune pièce.
Analyse (confiance élevée). Le modèle d'entreprise de NOUN PAY repose sur des services étrangers : le rapatriement complet n'est pas réaliste à court terme. La priorité est de documenter chaque transfert, de préparer les demandes d'autorisation, d'informer les clients, et de lever l'inconnu sur la biométrie.

Lecture auditologique · Les transferts de NOUN PAY

Exigence	Cote	Preuve
Les transferts sont recensés	OUI	Cartographie de l'audit
Les transferts sont autorisés	NON	Aucune autorisation
Les clients sont informés des transferts	NON	Notice de l'application
Le pays de chaque transfert est connu	NEK	Selfies, pays inconnu
Les importateurs sont soumis à des règles de sécurité	OUI	Certificat ISO/IEC 27018 de l'hébergeur
Le niveau de protection des pays est suffisant	NEK	Liste non publiée
Les clauses contractuelles types sont souscrites	NEK	Clauses non publiées
Les demandes d'autorisation sont préparées	NON	Aucun dossier

Décompte. Deux OUI, trois NON, trois NEK sur huit. $\mu = 0{,}25$ · $U = 0{,}375$ · $H = 1{,}56$ **bit**

Lecture. $U = 0{,}375$: le domaine est fortement opaque. Mais deux des trois NEK sont de critère et ne se lèveront qu'avec des textes ; un seul est de preuve (le pays des selfies), et c'est lui qu'il faut lever en priorité, parce qu'il porte sur des données biométriques.

Décrire le pays de destination. Pour le Maroc et pour la Côte d'Ivoire, où se trouve l'éditeur de NYANGA, l'auditeur dispose des fiches pays du Chapitre 3 (section 3.4) : une loi de protection des données, une autorité, des engagements internationaux. Ces éléments entrent dans le rapport à titre d'information. Ils ne lèvent pas le NEK de critère sur le niveau de protection, que seule la liste de l'Autorité camerounaise pourra lever.

14.4.1 Les données qui reviennent de l'Union européenne

Un transfert a deux sens. Les 6 840 clients de NOUN DIASPORA résident en France et en Belgique. Leurs données sont collectées dans l'Union, puis consultées depuis Douala par les équipes de NOUN PAY. Pour le droit européen, cette consultation est un transfert vers un pays tiers, soumis au chapitre V du règlement. Le Cameroun ne bénéficie pas d'une décision d'adéquation de la Commission. Le transfert doit donc s'appuyer sur une autre garantie, en pratique les clauses contractuelles types de 2021 [8], complétées par une évaluation de la législation du pays de destination [7].

L'auditeur cote alors deux exigences distinctes pour le même flux. Au titre de la loi camerounaise, le traitement à Douala de données venues de l'étranger reste un traitement

soumis à l'article 19. Au titre du règlement, l'exigence est « une garantie du chapitre V couvre le transfert vers le Cameroun », cotable sur pièces. À NOUN PAY, aucune clause n'a été signée : la cote est NON. Cette double lecture est celle du Chapitre 4 (section 4.6).

14.5 Transferts et Coopération Pénale

Les transferts ne concernent pas que les entreprises. Quand un officier de police judiciaire camerounais demande à un fournisseur étranger de conserver des données, ou quand une autorité étrangère demande au Cameroun des données sur un suspect, des données personnelles franchissent une frontière. La Convention de Budapest, à laquelle le Cameroun est Partie, prévoit en son article 29 une procédure de conservation rapide entre États. La loi n° 2024/017 soumet les transferts à autorisation préalable (article 32), sous réserve des textes spécifiques à la justice (article 72).

L'auteur de ce cours et ses coauteurs analysent cette rencontre comme une « tension transfrontalière » dans un travail en cours [29] : elle n'est pas, selon eux, une incompatibilité, mais elle impose de distinguer conservation, préservation, production, transmission et transfert, qui peuvent relever de régimes différents. Le Chapitre 19 présente cette piste de recherche.

14.6 Ce que les Transferts demandent à chaque Métier

Application Délégué à la protection des données

Tenir une liste des transferts, avec pour chacun le pays, les données, le prestataire, le contrat et l'état de la demande d'autorisation. Exiger de chaque nouveau service en ligne la localisation de ses serveurs avant de l'adopter.

Application RSSI

Fournir les traces des flux sortants et l'inventaire des bibliothèques intégrées aux applications ; bloquer les services non déclarés.

Application Juriste conformité

Préparer les dossiers d'autorisation : description du transfert, garanties contractuelles, informations sur le pays, et, en attendant les clauses types de l'Autorité, des clauses de protection équivalentes.

★ À retenir

- Tout acheminement de données au-delà des frontières est un transfert, y compris l'hébergement, les services en ligne et la consultation à distance.
- L'article 32 subordonne le transfert à une autorisation préalable, après quatre vérifications dont un instrument signé avec le pays de destination.
- Sans liste de pays ni clauses types publiées, deux de ces vérifications sont des

NEK de critère ; les autres se cotent sur pièces.

- Le lieu de stockage se prouve par le contrat ou la documentation, pas par la localisation d'une adresse IP.
- Le transfert sans autorisation est puni administrativement (article 60) et pénalement (article 69).

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- dire si un service en ligne constitue un transfert ;
- énoncer les quatre vérifications de l'article 32 ;
- distinguer un NEK de critère d'un NEK de preuve dans un audit des transferts.

✍ Exercice 14.1. Transfert ou non ★☆☆

(a) Un médecin de MBOLO consulte un dossier depuis un congrès à Paris ; (b) NYANGA stocke ses sauvegardes chez un prestataire à Douala ; (c) NOUN PAY envoie ses SMS par un opérateur camerounais ; (d) le logiciel bancaire de NYANGA est hébergé à Abidjan ; (e) un formulaire de satisfaction en ligne dont les serveurs sont aux États-Unis.

✍ Exercice 14.2. Le dossier d'autorisation ★★☆

Rédigez le dossier de demande d'autorisation du transfert d'hébergement de NOUN PAY, rubrique par rubrique, en vous appuyant sur l'article 32. Indiquez les pièces que vous joindrez.

✍ Exercice 14.3. Les selfies ★★☆

Proposez une démarche pour établir le pays de traitement des selfies. Quelles pièces demandez-vous au prestataire ? Que recommandez-vous si NOUN PAY ne parvient pas à l'établir ?

✍ Exercice 14.4. Abidjan ★★★

Le logiciel bancaire de NYANGA est hébergé en Côte d'Ivoire, qui dispose de sa propre loi de protection des données. (a) Ce fait suffit-il à satisfaire la première vérification de l'article 32 ? (b) Quelles autres vérifications restent à satisfaire ? (c) Comment cotez-vous la proposition « le transfert vers Abidjan est conforme » au 30 septembre 2026 ?

Note

Pour aller plus loin.

- Les recommandations 01/2020 du Comité européen de la protection des données [7], pour la méthode d'évaluation d'un pays de destination.
- L'ISO/IEC 27018 [16], pour les obligations des hébergeurs.

Note

Transition. Une donnée qui sort sans autorisation est un écart ; une donnée qui sort par effraction est une violation. Comment la détecter, la qualifier et en informer qui de droit ? C'est l'objet du Chapitre 15.

15

LES VIOLATIONS DE DONNÉES

> « Une violation tenue secrète protège l'organisation un temps, et laisse la personne sans défense. »
>
> Principe du cours

Niveau : *Intermédiaire* • Chapitres 12 et 6 ; réponse à incident (UE MSN-2S3-SEC07)

✦ Objectifs du chapitre

- ➢ Reconnaître une violation de données au sens de l'article 5, y compris l'accès interne non autorisé.
- ➢ Appliquer l'obligation d'information « sans délai » de l'article 22.
- ➢ Qualifier une violation du point de vue des personnes.
- ➢ Auditer le dispositif de gestion des violations et le registre qui les documente.
- ➢ Analyser la rencontre entre l'obligation d'informer et le secret d'une enquête pénale.

Avant de commencer : une lettre de l'OPJ

Bafoussam, vendredi 21 août 2026. Dans le dossier de l'incident de mars 2025, Mme BELLO trouve une lettre de l'adjudant-chef NANA, officier de police judiciaire, datée du 20 mars 2025 : « Dans l'intérêt de l'enquête, il vous est demandé de ne pas informer vos clients de la compromission avant instruction contraire. » Aucune instruction contraire n'a été donnée. Le jugement a été rendu en février 2026. Le 21 août, les 18 412 personnes dont les dossiers ont été copiés n'ont toujours reçu aucune information.

Le directeur général s'en tient à la lettre : « La police nous a demandé de nous taire. » L'auditrice note que la lettre visait l'enquête, que l'enquête est close, et que personne n'a vérifié depuis si la demande tenait toujours.

© MaletYon

★ Attention

Violation typique. Traiter une violation comme un problème technique à corriger en silence, ou s'abriter indéfiniment derrière une demande de discrétion devenue sans objet.

Règle : une violation s'informe « sans délai » à l'Autorité et aux personnes (article 22). Une raison de différer, si elle existe, se documente, se limite dans le temps et se réexamine ; quand elle cesse, l'information est due.

15.1 Qu'est-ce qu'une Violation

■ Définition

Violation de données à caractère personnel : selon l'article 5, « toute atteinte à la sécurité des données à caractère personnel entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation non autorisée desdites données transmises, conservées ou traitées d'une autre manière, ou l'accès non autorisé à de telles données ».

La définition est large. Une violation n'est pas forcément une attaque : une erreur d'envoi, un ordinateur portable perdu, une sauvegarde effacée par erreur en sont. Elle n'est pas forcément externe : l'accès non autorisé d'un agent à un dossier, comme à MBOLO, en est une. Elle n'est pas forcément une fuite : la destruction ou l'indisponibilité de données indispensables en est une aussi.

Atteinte	Exemple	Risque pour la personne
Confidentialité	Fichier clients copié, dossier consulté sans raison, courriel au mauvais destinataire	Fraude, chantage, discrimination, atteinte à la réputation
Intégrité	Résultat d'analyse attribué au mauvais patient	Soin inadapté, décision erronée
Disponibilité	Dossiers chiffrés par un rançongiciel, sauvegardes détruites	Soin retardé, droits impossibles à exercer

Tableau 15.1. Les trois atteintes et leurs effets

15.2 L'Obligation d'Informer

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 22 [26] : *« (1) Dès connaissance de toute violation des données à caractère personnel, le responsable du traitement ou le sous-traitant est tenu d'informer sans délai, l'Autorité de protection des données à caractère personnel et la personne concernée. (2) En tout état de cause, et sans préjudice des dispositions de l'alinéa 1 ci-dessus, le responsable du traitement ou le sous-traitant est tenu de mettre en œuvre les mesures de protection techniques et organisationnelles appropriées, telles que le chiffrement, l'instauration des autorisations restrictives d'accès aux données. »*

Portée. L'obligation est plus large que dans le droit européen sur deux points : elle vise *toute* violation, sans seuil de risque, et elle impose d'informer la personne dans tous les cas. Elle est moins précise sur un troisième : « sans délai » n'est pas chiffré, et le contenu de l'information n'est pas fixé.

En l'absence de contenu fixé, le cours retient une information minimale, déclarée comme critère : la nature de la violation, les catégories et le nombre approximatif de personnes et de données touchées, les conséquences probables pour les personnes, les mesures prises et celles que la personne peut prendre elle-même (changer un mot de passe, surveiller ses comptes), et un contact. Pour « sans délai », l'audit mesure le temps écoulé entre la connaissance de la violation et chaque information, et le rapproche des raisons documentées d'un éventuel retard.

Deux horloges pour une organisation exposée au RGPD. Le règlement européen suit une autre logique. Son article 33 demande de notifier l'autorité de contrôle « dans les meilleurs délais et, si possible, 72 heures au plus tard après en avoir pris connaissance », sauf si la violation n'est pas susceptible d'engendrer un risque. Son article 34 réserve l'information des personnes aux violations qui présentent un risque élevé [35]. Une violation qui touche les clients de NOUN DIASPORA déclenche donc les deux textes.

Question	Loi n° 2024/017, art. 22	RGPD, art. 33 et 34
Quelles violations	Toutes	Celles qui présentent un risque
Qui informer	L'Autorité et la personne	L'autorité ; la personne si le risque est élevé
Dans quel délai	« Sans délai », non chiffré	72 heures pour l'autorité
Cote du délai	Temps mesuré, rapproché des raisons du retard	OUI ou NON sur l'horodatage

Tableau 15.2. La même violation sous deux textes

L'auditeur porte deux cotes et ne les fond pas. Une organisation peut avoir notifié l'autorité européenne en soixante heures, ce qui vaut OUI pour le règlement, et n'avoir informé aucune personne, ce qui vaut NON pour la loi camerounaise. La règle pratique est d'appliquer à chaque question la plus exigeante des deux réponses : informer toutes les personnes, comme le veut l'article 22, et tenir les 72 heures, comme le veut l'article 33.

Note

Le sous-traitant aussi. L'article 22 vise « le responsable du traitement ou le sous-traitant ». Le contrat doit organiser qui informe qui, et dans quel ordre : un prestataire qui découvre une violation doit au moins prévenir immédiatement son client (clause 9 du Chapitre 13).

15.3 Gérer une Violation

Démarche d'audit

Auditer le dispositif de gestion des violations.

1. Vérifier qu'une procédure écrite existe, connue des équipes et des sous-traitants, avec un point de contact unique.
2. Vérifier la détection : comment l'organisation apprend-elle une violation (alertes, revues de journaux, signalements) ?
3. Obtenir le registre des violations ; à défaut, le reconstituer à partir des incidents de sécurité, des plaintes et des sinistres.
4. Pour chaque violation, relever les dates de connaissance, de confinement, d'information de l'Autorité et des personnes.
5. Vérifier la qualification : données, personnes, conséquences pour elles.
6. Vérifier le contenu des informations envoyées.
7. Vérifier les enseignements tirés et les mesures correctives.

La loi n'impose pas explicitement un registre des violations. Il découle cependant de deux obligations : prouver qu'on a informé « sans délai » suppose de dater la connaissance ; et la traçabilité de l'article 27 suppose de pouvoir reconstituer ce qui s'est passé. Un registre où chaque violation, même non notifiée, est décrite avec sa date, sa qualification et sa décision, est la seule manière de le démontrer.

15.4 Informer pendant une Enquête Pénale

L'affaire de NYANGA pose une question que la loi ne règle pas. L'article 22 impose d'informer sans délai les personnes ; la procédure pénale protège le secret de l'enquête. Dans leur travail en cours, l'auteur de ce cours et ses coauteurs relèvent que le Code de procédure pénale impose le secret de la procédure durant l'enquête de police judiciaire

(article 102) et le secret de l'information judiciaire (article 154) [29]. Une information des personnes peut révéler l'existence de l'enquête, l'identité d'un suspect ou une opération en cours.

Les auteurs qualifient cette rencontre de « tension procédurale », et non d'incompatibilité : les deux obligations peuvent être conciliées si l'on organise le moment et les modalités de l'information. Ils proposent qu'un mécanisme permette au magistrat compétent d'apprécier ce moment lorsque l'information risque de compromettre l'enquête. En attendant un tel mécanisme, l'auditeur vérifie quatre choses :

1. la demande de différer existe par écrit, émane d'une autorité compétente et vise l'enquête ;
2. l'Autorité de protection a été informée, ou l'organisation a documenté pourquoi elle ne pouvait pas l'être ;
3. l'organisation a réexaminé la demande à intervalles réguliers ;
4. l'information a été donnée dès que la raison de différer a cessé.

S'y ajoute une question de temps, que les mêmes auteurs nomment « tension temporelle » : la violation de NYANGA date du 14 mars 2025, après la promulgation de la loi mais pendant le délai de mise en conformité de l'article 73. L'obligation d'informer s'appliquait-elle déjà ? L'auditeur ne tranche pas cette question de droit ; il constate en revanche qu'au 24 juin 2026, à l'échéance du délai, la violation n'était pas réparée du point de vue des personnes, et qu'aucune raison documentée ne justifiait plus le silence. Le Chapitre 19 présente ces deux tensions comme des pistes de recherche.

15.5 Les Violations de NYANGA et de MBOLO

Scénario Opérationnel · Missions NYANGA et MBOLO. Deux violations, deux traitements

NYANGA. Connaissance : 14 mars 2025, 9 heures. Qualification technique faite par l'enquête (3,2 Go, 18 412 fichiers). Aucune qualification du point de vue des personnes. Demande de l'OPJ du 20 mars 2025, jamais réexaminée. Jugement le 15 février 2026. Au 31 août 2026, aucune information des personnes ni de l'Autorité ; aucun registre des violations.

MBOLO. Connaissance : 13 mai 2026, par la plainte de la patiente. Investigation le jour même (journal des consultations), comptes désactivés, procédure disciplinaire. Patiente informée par écrit le 15 mai, avec la liste des consultations non justifiées et les mesures prises. L'Autorité n'a pas été informée ; la directrice a noté au registre, créé le 14 mai, qu'aucun interlocuteur n'était identifié.

Analyse (confiance élevée). MBOLO a traité sa violation comme la loi le demande pour ce qui dépendait de lui, et l'a documentée. NYANGA a traité la sienne comme un dossier pénal, sans jamais la regarder comme une violation de données envers ses clients.

Lecture auditologique · Le domaine D5, violations, à NYANGA

Exigence	Cote	Preuve
Une procédure de gestion des violations existe	NON	Aucune
Un registre des violations est tenu	NON	Aucun
La violation de 2025 est qualifiée pour les personnes	NON	Rapport technique seul
La demande de différer est écrite et motivée	OUI	Lettre du 20 mars 2025
La demande a été réexaminée	NON	Aucune démarche
Les personnes ont été informées quand la raison a cessé	NON	Rien au 31 août 2026
L'Autorité a été informée	NEK	Autorité non organisée, aucune démarche documentée
L'obligation d'informer s'appliquait en mars 2025	NEK	Question de droit non tranchée

Décompte. Un OUI, cinq NON, deux NEK sur huit. $\mu = 0{,}125$ · $U = 0{,}25$ · $H = 1{,}30$ **bit**

Lecture. Les deux NEK ne changent pas la recommandation : quelle que soit la réponse à la question de droit, la raison de se taire a cessé en février 2026, et l'information des 18 412 personnes est due. C'est la première recommandation du rapport.

15.6 Ce que les Violations demandent à chaque Métier

Application Responsable de traitement

Désigner un point de contact pour les violations, décider de l'information et la signer. Réexaminer par écrit toute demande de discrétion et lever le silence dès qu'elle cesse.

Application RSSI

Alimenter le registre des violations depuis les incidents de sécurité, avec les éléments techniques, et apporter la qualification du point de vue des données touchées.

Application Juriste conformité

Articuler l'obligation d'informer avec les demandes des autorités judiciaires : obtenir des demandes écrites, limitées dans le temps, et documenter chaque décision.

★ À retenir

- Une violation est toute atteinte à la confidentialité, à l'intégrité ou à la disponibilité de données personnelles, accidentelle ou illicite, interne ou externe.
- L'article 22 impose d'informer sans délai l'Autorité et la personne, pour toute violation.
- Un registre des violations est la seule manière de prouver le respect du « sans délai ».
- L'information peut rencontrer le secret de l'enquête pénale : une demande de différer se documente, se limite et se réexamine.
- À NYANGA, 18 412 personnes n'avaient toujours pas été informées en août 2026 ; MBOLO a informé sa patiente en deux jours.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- reconnaître une violation interne ;
- rédiger l'information d'une personne après une violation ;
- auditer une demande de différer l'information.

✍ Exercice 15.1. Violation ou non ★☆☆

(a) un relevé de compte envoyé au mauvais client ; (b) une tentative d'intrusion bloquée par le pare-feu ; (c) un serveur indisponible deux jours, sans perte de données ; (d) un portable chiffré perdu dans un taxi ; (e) un portable non chiffré volé.

✍ Exercice 15.2. Informer M. TAGNE ★★☆

Rédigez l'information que NYANGA doit adresser aux 18 412 personnes, selon le contenu minimal du cours. Que dites-vous du retard ?

✍ Exercice 15.3. La chronologie ★★☆

À partir des dates de la section 15.5, calculez pour NYANGA le délai entre la connaissance de la violation et le jugement, puis entre le jugement et le 31 août 2026. Rédigez la phrase du rapport sur le respect du « sans délai ».

✍ Exercice 15.4. La demande de l'OPJ ★★★

Un OPJ demande aujourd'hui à MBOLO de ne pas informer des patientes dont les dossiers ont été consultés par un agent sous enquête. Rédigez la réponse de MBOLO à l'OPJ et la note au registre des violations, en organisant la conciliation entre

l'article 22 et le secret de l'enquête.

Note

Pour aller plus loin.

- L'ISO/IEC 27035 [21] et le NIST SP 800-61 [5], pour la gestion des incidents.
- Le cours de forensique de l'auteur (UE MSN-2S3-SEC07), pour l'enquête sur l'incident de NYANGA.

Note

Transition. Les constats s'accumulent : registre, fondements, droits, sécurité, sous-traitants, transferts, violations. Il reste à les transformer en rapport et en programme de mise en conformité. C'est l'objet du Chapitre 16.

16

PROGRAMME DE CONFORMITÉ ET RAPPORT D'AUDIT

« Un rapport qui énumère des écarts sans les classer
laisse la direction choisir les plus faciles. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 8 à 15

✦ Objectifs du chapitre

- ➢ Rédiger une observation d'audit en sept éléments.
- ➢ Synthétiser les domaines d'un audit avec μ, U et H et conclure selon la règle de décision.
- ➢ Prioriser les recommandations selon la gravité pour les personnes.
- ➢ Construire un programme de mise en conformité daté, avec des indicateurs.
- ➢ Auditer la conservation et la purge des données (articles 13 et 28).

Avant de commencer : quarante-six exigences, une page

Yaoundé, lundi 14 septembre 2026. Les papiers de travail de la mission NYANGA remplissent deux classeurs : quarante-six exigences cotées dans six domaines, des dizaines de pièces. Le conseil d'administration, lui, attend une page. M. TCHOUA a prévenu : « Dites-nous ce qui est grave, ce qui coûte cher et ce que nous devons faire d'abord. »

Mme BELLO sait qu'une page ne peut pas contenir quarante-six constats. Elle sait aussi qu'une page qui ne dit pas ce qui reste inconnu tromperait le conseil. Elle choisit de construire le rapport en trois couches : une synthèse d'une page, un constat par domaine avec ses cotes, et les observations détaillées en annexe.

★ Attention

Violation typique. Remettre un rapport qui liste les écarts par ordre d'apparition, sans les relier à des articles, sans dire ce qui reste inconnu, et sans ordre de priorité.

© MaletYon

Règle : chaque constat se rattache à un article et à une preuve ; la synthèse dit, par domaine, ce qui est établi et ce qui ne l'est pas ; les recommandations sont classées par gravité pour les personnes, puis par exposition de l'organisation.

16.1 L'Observation en Sept Éléments

N°	Élément	Contenu
1	Norme	L'article de la loi, ou l'exigence de la norme, qui fonde le critère
2	Constatation	Le fait établi, chiffré, avec sa preuve et sa cote
3	Risques	Le risque pour les personnes, puis pour l'organisation
4	Contradictoire	La réponse de l'audité, datée
5	Analyse	La cause de l'écart, avec un niveau de confiance
6	Conclusion	La position de l'auditeur
7	Recommandation	Ce qu'il faut faire, en traitant la cause

Tableau 16.1. L'observation en sept éléments

Scénario Opérationnel · Mission NYANGA. Observation D2-06 : les oppositions non exécutées

Norme. Article 40 (droit d'opposition à la prospection) ; article 64 (délit de traitement maintenu malgré l'opposition).
Constatation. Cinq oppositions à la prospection reçues entre le 23 juin et le 31 août 2026, toutes acceptées par lettre. Trois des cinq numéros figurent dans la liste d'appels de prospection du 28 août (pièce D2-06-03). Cote NON.
Risques. Pour les personnes : sollicitations non voulues, perte de confiance dans l'exercice de leurs droits. Pour l'établissement : délit de l'article 64.
Contradictoire (18 septembre). « Les agents n'ont pas reçu la mise à jour de la liste. Nous corrigeons. »
Analyse (confiance élevée). La cause n'est pas l'agent : la liste d'appels est extraite chaque mois de la base des clients, et aucune procédure ne reporte les oppositions dans la base.
Conclusion. L'exigence n'est pas satisfaite ; l'écart est systémique.
Recommandation. Ajouter dans la base un indicateur d'opposition qui exclut automatiquement le client des extractions de prospection ; vérifier chaque mois, par sondage, l'absence des opposants dans les listes.

16.2 La Synthèse par Domaine

Cinq domaines ont été cotés dans les chapitres précédents : D1 (Chapitre 8), D2 (Chapitre 11), D3 (Chapitre 12), D4 (Chapitre 13) et D5 (Chapitre 15). Il reste le sixième, la gouvernance, que l'équipe cote en dernier parce qu'il dépend de tout ce qui précède.

Lecture auditologique · Le domaine D6, gouvernance, à NYANGA

Exigence	Cote	Preuve
Le risque de chaque traitement est évalué (art. 25)	NON	Aucune évaluation
Une évaluation d'impact précède les traitements à risque élevé (art. 33)	NON	Douze traitements, aucune
Un dossier de conformité peut être présenté au contrôle (art. 35)	NON	Pièces dispersées, aucun dossier
Le rapport annuel sur les mesures est adressé à l'Autorité (art. 27(2))	NEK	Autorité non organisée

Décompte. Aucun OUI, trois NON, un NEK sur quatre. $\mu = 0$ · $U = 0{,}25$ · $H = 0{,}81$ **bit**

Lecture. C'est le domaine le plus court et le plus net. Les critères de l'évaluation d'impact relèvent d'un texte à venir, mais l'absence de toute évaluation se constate sans lui : la cote est NON et non NEK. Le seul NEK est de critère. Ce domaine explique les cinq autres : personne n'est chargé du sujet, donc rien n'est évalué, tenu ni rendu.

Les quarante-six exigences sont réunies dans l'Annexe G, avec leur cote, leur preuve et la nature de chaque NEK.

Lecture auditologique · NYANGA CRÉDIT, synthèse des six domaines, 25 septembre 2026

Code	Domaine	O / N / K	μ	U	H
D1	Recensement et fondements	1 / 5 / 2	0,13	0,25	1,30
D2	Droits des personnes	1 / 7 / 2	0,10	0,20	1,16
D3	Sécurité et confidentialité	4 / 3 / 1	0,50	0,13	1,41
D4	Sous-traitants et transferts	1 / 5 / 2	0,13	0,25	1,30
D5	Violations	1 / 5 / 2	0,13	0,25	1,30
D6	Gouvernance	0 / 3 / 1	0	0,25	0,81
Total		8 / 28 / 10	0,17	0,22	1,35

Lecture. Cinq domaines sur six sont opaques au sens de la règle ($U \geq 0{,}20$) ; aucun ne peut être déclaré conforme. Le seul domaine clair, D3, ne l'est pas non plus : $\mu = 0{,}50$ atteint le seuil, mais trois NON portent sur la limitation des accès, et

la règle exige l'absence d'écart grave. Dans tous les domaines, les NON dominent : l'opacité n'est pas ce qui empêche de conclure. L'établissement n'est pas conforme, et l'audit sait pourquoi sur vingt-huit points précis.

La synthèse distingue trois messages qu'un conseil doit entendre séparément : ce qui est établi comme non conforme (vingt-huit écarts), ce qui reste inconnu et pourquoi (dix NEK, dont six de critère, liés aux textes d'application et à l'Autorité), et ce qui fonctionne (huit exigences, dont la moitié en sécurité). Fondre ces trois messages en une note globale effacerait l'information utile.

Une limite du plan, dite dans le rapport. Le domaine D4 s'intitule « sous-traitants et transferts ». Ses huit exigences portent sur les contrats. Le transfert vers Abidjan, où l'éditeur héberge le logiciel bancaire, n'y apparaît que par l'absence de clause de transfert. Le plan d'audit du 2 juillet ne l'avait pas isolé. Le rapport le signale et donne la cote hors décompte : « le transfert est autorisé » vaut NON, faute d'autorisation ; « le pays offre un niveau de protection suffisant » vaut NEK de critère, faute de liste (Chapitre 14). La recommandation n° 9 en découle. Un auditeur qui découvre en cours de mission une exigence oubliée ne modifie pas son décompte après coup. Il l'écrit, la cote à part et l'inscrit au plan de la mission suivante.

16.3 Prioriser les Recommandations

Les recommandations se classent d'abord par **gravité pour les personnes**, ensuite par **exposition de l'organisation** (sanctions encourues, contentieux), enfin par **effort**. L'ordre inverse, du plus facile au plus difficile, est tentant et dangereux : il traite d'abord ce qui protège le moins.

Rang	Recommandation	Articles	Échéance
1	Informer les 18 412 personnes de la violation de 2025	22	30 jours
2	Supprimer le classeur des mauvais payeurs	9, 36, 48, 66	Immédiat
3	Exécuter les oppositions et répondre aux demandes en attente	39, 40, 56, 64	30 jours
4	Désactiver le kit de mesure d'audience sans consentement	loi 2010/012, art. 47	Immédiat
5	Réécrire formulaires et notices, recueillir les consentements	9, 21	90 jours
6	Avenants aux contrats des sous-traitants, droit d'audit	16, 30	90 jours
7	Fixer et appliquer les durées de conservation, purger	13, 28	6 mois
8	Limiter les accès des agences à leurs clients	27	6 mois
9	Documenter les transferts, préparer les autorisations	19, 32	6 mois
10	Désigner un délégué à la protection des données (bonne pratique)	aucun	90 jours

Tableau 16.2. Les dix premières recommandations à NYANGA CRÉDIT

La dixième recommandation n'a pas de fondement légal ; le rapport le dit. Elle répond à une cause commune à presque tous les écarts : personne, dans l'établissement, n'est chargé de la protection des données.

16.4 L'Exposition Juridique

Le conseil demandera ce que l'établissement risque. Dès le 10 août, M. NGANDO a rapproché les constats de terrain des articles qui les sanctionnent dans les deux lois (Chapitres 6 et 7).

Scénario Opérationnel · Mission NYANGA. La note juridique du 10 août 2026

Constatations (rapprochement des constats d'audit et des articles). Traitements sans autorisation : 47 (article 55). Demandes d'accès sans réponse : 12 (article 56). Oppositions non exécutées : 3 (article 64). Interconnexion sans obligation légale : 1, le classeur des mauvais payeurs (article 58). Données sensibles sans consentement exprès : au moins 4 traitements (article 66). Kit de mesure d'audience sans consentement : 1 (loi n° 2010/012, article 47).

Analyse (confiance moyenne). L'exposition théorique est élevée, mais sa réalisation dépend de l'organisation de l'Autorité, de l'action des personnes et du parquet. M. NGANDO déconseille de chiffrer une « amende probable » : aucune décision

n'existe encore pour en fonder une estimation. Il classe les écarts par gravité pour les personnes, pas par montant.

Cette note accompagne le rapport sans s'y substituer. Elle classe, elle ne chiffre pas.

16.5 La Conservation et la Purge

L'article 13 limite la conservation à la durée nécessaire, et l'article 28 renvoie la fixation du délai maximum au référentiel de l'Autorité, « compte tenu de la finalité du traitement ou de la nature des données collectées ». En attendant le référentiel, l'organisation fixe elle-même ses durées dans une politique de conservation, traitement par traitement, en distinguant trois périodes : la **base active** (le temps de la finalité), les **archives intermédiaires** (le temps d'une obligation légale ou d'un contentieux possible, avec accès restreint), et la **purge** (effacement, ou anonymisation prouvée pour les statistiques).

L'audit de la conservation compare, pour chaque traitement, la date des données les plus anciennes à la durée fixée. Le laboratoire APDC-LAB-09 exerce ce calcul sur un extrait de la base des comptes de NYANGA.

Scénario Opérationnel · Mission NYANGA. La politique de conservation proposée

Traitement	Base active	Archive	Justification
Comptes clients	Durée du compte	10 ans après la clôture	Obligations comptables (dix ans en droit OHADA)
Prospects	1 an sans contact	Aucune	Finalité seule
Candidats non retenus	6 mois	Aucune	Finalité seule
Images des agences	30 jours	Durée d'une procédure si incident	Sécurité
Appels du service client	6 mois	Durée d'un litige	Preuve (loi 2010/012, art. 45)

Constatation (31 août). 22 950 comptes clos avant 2016 dépassent déjà la durée d'archive proposée ; la base des prospects contient des entrées de 2017.

16.6 Le Programme de Mise en Conformité

Un rapport d'audit se clôt par des recommandations ; un programme les transforme en projet. Il fixe pour chaque recommandation un responsable, une échéance, une preuve

d'achèvement et un indicateur, puis il prévoit un audit de suivi.

Indicateur	Définition
Couverture du registre	Traitements découverts et inscrits, sur traitements existants
Traitements documentés pour autorisation	Dossiers complets, sur traitements du registre
Délai médian de réponse aux demandes	Médiane du délai entre réception et réponse complète
Exécution des oppositions	Opposants absents des listes de prospection, par sondage mensuel
Contrats conformes	Contrats aux douze clauses, sur contrats de sous-traitance
Violations informées dans les délais	Violations informées dans le délai cible, sur violations du registre
Données au-delà de la durée	Enregistrements dépassant la durée fixée

Tableau 16.3. Indicateurs d'un programme de conformité

L'article 27, alinéa 2, impose en outre un rapport annuel à l'Autorité sur l'état des mesures de sécurité. Le programme peut en préparer la matière dès maintenant : les indicateurs de sécurité du programme en sont le cœur, et le format sera fixé quand le référentiel sera publié.

16.7 Ce que le Rapport demande à chaque Métier

Application Auditeur de la protection des données

Rédiger chaque observation en sept éléments, synthétiser par domaine avec les trois mesures, séparer établi, inconnu et satisfaisant, et classer les recommandations par gravité pour les personnes.

Application Responsable de traitement

Répondre au contradictoire par écrit, accepter ou motiver le refus de chaque recommandation, et nommer un responsable par action.

Application Délégué à la protection des données

Piloter le programme, mesurer les indicateurs chaque mois, et préparer l'audit de suivi.

★ À retenir

➢ L'observation d'audit compte sept éléments, dont le contradictoire et une recommandation qui traite la cause.

- La synthèse par domaine sépare ce qui est établi non conforme, ce qui est inconnu et pourquoi, et ce qui fonctionne.
- Les recommandations se classent par gravité pour les personnes, puis par exposition, puis par effort.
- La conservation se gère en trois périodes : base active, archive, purge ; l'audit compare l'âge des données aux durées fixées.
- À NYANGA, vingt-huit écarts établis, dix NEK dont six de critère, et l'information des 18 412 personnes en première recommandation.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- rédiger une observation en sept éléments ;
- conclure sur un domaine à partir de ses cotes ;
- ordonner des recommandations et justifier l'ordre.

✍ Exercice 16.1. Ordonner ★☆☆

Classez par gravité pour les personnes : (a) le registre incomplet ; (b) les selfies traités dans un pays inconnu ; (c) un contrat de papeterie sans clause de protection des données ; (d) le pointage biométrique des salariés ; (e) l'absence de délégué.

✍ Exercice 16.2. Une observation ★★☆

Rédigez l'observation D1-04 « le classeur des mauvais payeurs » en sept éléments, à partir des Chapitres 9 et 10. Inventez de façon cohérente la réponse de la direction.

✍ Exercice 16.3. La page du conseil ★★☆

Rédigez la synthèse d'une page destinée au conseil d'administration de NYANGA, sans jargon, en trois paragraphes : ce qui est établi, ce qui est inconnu, ce qu'il faut faire d'abord.

✍ Exercice 16.4. L'audit de suivi ★★★

Six mois après le rapport, NYANGA annonce que « toutes les recommandations sont mises en œuvre ». Construisez le plan de l'audit de suivi : exigences retestées, preuves attendues, échantillons, et la manière de présenter l'évolution de μ, U et H par domaine.

Note

Pour aller plus loin.

- L'ISO 19011 [14], pour le rapport d'audit et le suivi.
- T. E. Minka Mi Nguidjoï [27], pour la lecture des trois mesures.

Note

Transition. Un traitement de NOUN PAY n'a pas encore été audité : la notation automatique qui décide des crédits. Profilage, décisions automatisées, biométrie : ce sont les défis de la Partie V, et l'objet du Chapitre 17.

partie VI

Défis Avancés

© MaletYon

17

PROFILAGE, DÉCISIONS AUTOMATISÉES ET INTELLIGENCE ARTIFICIELLE

« Un modèle qui décide d'un crédit
doit pouvoir être expliqué à celui qu'il refuse. »

Principe du cours

Niveau : *Expert* • Chapitres 2, 10, 11 et 14

✦ Objectifs du chapitre

- ➢ Reconnaître un profilage et une décision fondée exclusivement sur un traitement automatisé.
- ➢ Appliquer l'article 44 et vérifier les garanties dues à la personne : intervention humaine, point de vue, contestation.
- ➢ Lire l'article 65 et dire ce que l'auditeur peut en conclure.
- ➢ Auditer un modèle de notation : données d'entrée, finalité, information, non-discrimination.
- ➢ Traiter les données biométriques au regard des articles 5 et 48.

Avant de commencer : « l'ordinateur a dit non »

Bafoussam, mercredi 12 août 2026. M. ATANGANA, couturier, demande à NOUN PAY un microcrédit de 150 000 francs CFA pour acheter une machine. La réponse arrive en quatre secondes : refusé. Il appelle le service client, qui lui explique que « l'ordinateur a dit non » et qu'aucun agent ne peut revenir sur la décision. Il écrit pour demander pourquoi.

Personne, à NOUN PAY, ne sait le lui dire. Le modèle NOUN SCORE a été entraîné en 2025 par un prestataire sur les historiques de 210 000 utilisateurs. Il utilise une soixantaine de variables : régularité des recharges de crédit téléphonique, montants reçus, heure habituelle des transactions, nombre de contacts dans le répertoire du téléphone, et localisation approximative. L'équipe produit connaît les variables ; elle ne sait pas lesquelles ont pesé pour M. ATANGANA.

★ Attention

Violation typique. Laisser un modèle décider seul d'une question importante pour une personne, sans pouvoir expliquer la décision ni la faire réexaminer par un humain.

Règle : la personne a le droit de s'opposer à une décision fondée exclusivement sur un traitement automatisé, et, en tout cas, d'obtenir une intervention humaine, d'exprimer son point de vue et de contester (article 44). Elle doit avoir été informée de la logique sous-jacente (article 21).

17.1 Profilage et Décision Automatisée

■ Définition

Profilage : selon l'article 5, « traitement automatisé de données à caractère personnel consistant à les utiliser pour évaluer certains aspects personnels relatifs à une personne physique, notamment sa santé, ses préférences, sa localisation et sa situation économique ».

Le profilage *évalue* ; la décision automatisée *décide*. Un score de solvabilité est un profilage ; le refus de crédit prononcé par le système sans intervention humaine est une décision automatisée. Les deux se recouvrent souvent, mais pas toujours : un score présenté à un agent qui décide réellement est un profilage sans décision automatisée.

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 44 [26] : *« (1) La personne concernée a le droit de s'opposer à toute décision basée exclusivement sur le traitement automatisé de ses données à caractère personnel, y compris le profilage. (2) Les dispositions de l'alinéa 1 ci-dessus ne s'appliquent pas si : la personne concernée est informée de l'utilisation du système automatisé de prise de décision et a donné son consentement préalable, explicite et éclairé ; le traitement est autorisé par la loi, sous réserve qu'elle prévoit des mesures appropriées pour la sauvegarde des droits et libertés et des intérêts légitimes de la personne concernée. (3) La personne concernée a également le droit : d'obtenir une intervention humaine de la part du responsable du traitement ; d'exprimer son point de vue ; de contester la décision fondée sur le traitement automatisé. »*

Portée. L'alinéa 3 ne connaît pas d'exception : même quand la personne a consenti, elle conserve le droit à une intervention humaine et à la contestation. Un système « non révisable » méconnaît l'article 44.

17.2 L'Article 65

Jurisprudence & Droit applicable

Loi n° 2024/017, article 65 [26] : *« Est puni d'un emprisonnement de trois (03) à dix (10) ans et d'une amende de un million (1 000 000) à vingt millions (20 000 000) de francs CFA, ou de l'une de ces deux peines seulement, le responsable de traitement ou le sous-traitant qui procède ou fait procéder à un traitement de données à caractère personnel à des fins de profilage. »*

Pris isolément, le texte punit tout profilage. Lu avec l'article 44, qui admet les décisions automatisées, y compris le profilage, sous conditions, il pourrait viser seulement le profilage réalisé hors de ces conditions. Les deux lectures sont défendables ; seul un juge, ou un texte d'application, les départagera.

L'auditeur ne tranche pas. Il fait trois choses. Il signale la difficulté au commanditaire, en citant les deux articles. Il cote NEK de critère la proposition « le profilage pratiqué est licite au regard de l'article 65 ». Et il vérifie, sur pièces, toutes les conditions qui rendraient le profilage défendable dans la lecture la plus favorable : autorisation demandée, consentement préalable, explicite et éclairé, information sur la logique, intervention humaine effective, absence de discrimination. Si l'une manque, la recommandation ne dépend plus de la lecture de l'article 65.

17.3 Auditer un Modèle de Notation

L'audit d'un modèle ne demande pas d'être statisticien ; il demande de poser, sur chaque élément du modèle, les questions de la loi.

Élément	Question d'audit	Articles
Données d'entraînement	Collectées pour cette finalité, ou détournées ? Consentement ?	9, 11, 67
Variables	Chacune a-t-elle un lien avec la solvabilité ? Une variable révèle-t-elle une donnée sensible ou une origine ?	11, 17, 48
Décision	Exclusivement automatisée ? Intervention humaine possible et effective ?	44
Information	La personne est-elle informée de la logique et des conséquences ?	21
Non-discrimination	Les taux de refus diffèrent-ils selon la région, la langue, le sexe ?	17
Prestataire	Le modèle est-il hébergé ou réentraîné à l'étranger ?	30, 32

Tableau 17.1. Les questions de la loi sur un modèle de notation

17.3.1 Les variables qui révèlent

Une variable anodine peut révéler une donnée sensible. La localisation habituelle peut révéler l'origine régionale ou le lieu de culte ; l'heure des transactions, la religion pendant un jeûne ; le répertoire des contacts, des données sur des tiers qui n'ont jamais consenti. L'article 17 impose de traiter les données « sans tenir compte de la classe sociale, de l'origine ethnique ou régionale, de l'appartenance syndicale, de l'opinion politique ou de la conviction religieuse de la personne concernée » : une variable qui sert d'intermédiaire à l'une d'elles fait entrer ce critère dans la décision.

17.3.2 Mesurer une discrimination

L'auditeur compare les taux de refus entre groupes de personnes. Si les demandeurs d'une région sont refusés deux fois plus que ceux d'une autre à revenus comparables, le modèle traite probablement une origine régionale par intermédiaire. Cette comparaison exige de connaître le groupe des personnes ; si l'organisation ne le connaît pas, et elle ne doit pas collecter une donnée sensible pour le savoir, l'auditeur utilise un indicateur indirect déclaré (la région de l'agence d'inscription) et cote avec prudence. Le laboratoire APDC-LAB-10 conduit ce calcul.

17.4 Les Données Biométriques

La biométrie figure dans la liste des données sensibles de l'article 5, et l'article 48, alinéa 1, interdit le traitement des données relatives « à la génétique et à la biométrie en matière de santé ». Le Chapitre 1 a relevé l'ambiguïté de cette fin de phrase. Deux usages du cours la mettent à l'épreuve :

- le **selfie de vérification d'identité** de NOUN PAY, comparé automatiquement à la photographie de la pièce d'identité ;
- le **pointage par empreinte digitale** du personnel de MBOLO, en place depuis 2023, qui n'a rien de médical mais se déroule dans un établissement de santé.

Dans les deux cas, l'auditeur établit les faits (quelles données, où elles sont stockées, combien de temps, qui y accède), vérifie le consentement exprès que l'article 66 exige pour conserver des données sensibles, et cote NEK de critère la licéité au regard de l'article 48 tant qu'aucune autorisation ni aucun texte ne l'éclaire. Il recommande dans tous les cas une solution de rechange non biométrique et le stockage du gabarit sur un support détenu par la personne plutôt que dans une base centrale.

17.5 L'Intelligence Artificielle : Trois Textes à Connaître

La loi n° 2024/017 ne contient pas le mot « intelligence artificielle ». Elle saisit ces systèmes par leurs données et par leurs décisions : les articles 44 et 65 pour la décision automatisée, les principes pour les données d'entraînement. Trois textes extérieurs

complètent ce regard. Aucun n'est un critère obligatoire au Cameroun. L'auditeur doit pourtant les connaître, parce que les organisations qu'il audite achètent des modèles conçus sous leur empire.

Texte	Nature	Ce que l'auditeur en retient
NIST AI RMF 1.0 (2023) [31]	Cadre volontaire	Quatre fonctions : gouverner, cartographier, mesurer, gérer. Une liste de qualités attendues d'un système, dont l'équité, l'explicabilité et le respect de la vie privée
Règlement (UE) 2024/1689 [43]	Texte obligatoire dans l'Union	Une approche par niveau de risque : pratiques interdites, systèmes à haut risque soumis à des obligations, obligations de transparence. La notation de solvabilité des personnes physiques figure parmi les usages à haut risque
Stratégie continentale de l'Union africaine (2024) [42]	Orientation politique	Un appel aux États à se doter de cadres nationaux et à protéger les données dans le développement de l'intelligence artificielle

Tableau 17.2. Trois textes sur l'intelligence artificielle

17.5.1 Ce que ces textes changent pour l'audit

Le règlement européen s'applique à qui met un système sur le marché de l'Union ou l'y utilise. NOUN SCORE note des clients camerounais et n'en relève pas. La question se poserait si le modèle servait à NOUN DIASPORA : l'équipe juridique devrait alors l'instruire, comme elle le fait pour le RGPD (Chapitre 4).

Le cadre du NIST fournit un vocabulaire et une liste de vérification. Il aide à ne rien oublier : qui répond du modèle, sur quelles données il a appris, comment sa performance et ses écarts entre groupes sont mesurés, qui décide de le retirer. L'auditeur peut l'emprunter comme critère volontaire, à condition de le déclarer (Chapitre 5).

La stratégie africaine ne crée aucune obligation pour une entreprise. Elle annonce la direction que prendront les textes nationaux.

★ Attention

Violation typique. Écrire dans un rapport qu'un modèle « n'est pas conforme au règlement européen sur l'IA » alors que ce règlement ne s'applique pas à l'organisation.

Règle : un texte étranger se cite pour ce qu'il est. S'il s'applique, c'est un critère obligatoire et le rapport dit pourquoi. S'il ne s'applique pas, c'est une référence empruntée, déclarée au plan, qui ne fonde aucune non-conformité légale.

17.5.2 Les questions propres aux systèmes qui apprennent

Un modèle qui apprend pose quatre questions que la notation classique ne posait pas.

1. **Les données d'entraînement.** D'où viennent-elles, et les personnes ont-elles été informées de cet usage (articles 9, 11 et 21) ?
2. **La dérive.** Le modèle est-il réentraîné, et qui vérifie que ses résultats ne changent pas en silence ?
3. **L'explication.** L'organisation sait-elle dire à une personne pourquoi elle a été refusée, dans des mots qu'elle comprend (article 44) ?
4. **Le fournisseur.** Si le modèle vient d'un tiers, que dit le contrat sur la réutilisation des données des clients pour améliorer le produit (articles 30 et 32) ?

Quand l'organisation ne peut pas répondre, la cote est NEK de preuve. Elle se lève par des pièces : la fiche du modèle, le journal des réentraînements, le contrat.

17.6 L'Audit de NOUN SCORE

Scénario Opérationnel · Mission NOUN PAY. La notation automatique, octobre 2026

Constatations.

- 100 % des demandes de microcrédit sont décidées par NOUN SCORE sans intervention humaine ; aucune procédure de réexamen.
- Les conditions d'utilisation mentionnent « l'utilisation d'algorithmes » sans décrire la logique ni les conséquences ; le consentement est une case unique couvrant tous les services.
- Le modèle utilise le nombre de contacts du répertoire, collecté par l'application sans consentement distinct.
- Sur les 41 200 demandes de juillet à septembre 2026, le taux de refus est de 38 % pour les inscrits des agences de l'Ouest et de 61 % pour ceux de l'Extrême-Nord, à tranches de revenus déclarés comparables.
- Aucune demande d'autorisation, aucune évaluation d'impact.

Analyse (confiance moyenne sur la discrimination, élevée sur le reste). L'écart de taux de refus, à revenus comparables, suggère que des variables de localisation servent d'intermédiaire à une origine régionale ; l'indicateur indirect retenu (l'agence d'inscription) ne permet pas de l'établir avec certitude. Les autres écarts sont établis.

Lecture auditologique · NOUN SCORE, octobre 2026

Exigence	Cote	Preuve
Une intervention humaine est possible (art. 44(3))	NON	Procédure absente, refus à M. ATANGANA
La personne est informée de la logique (art. 21)	NON	Conditions d'utilisation
Le consentement à la décision automatisée est explicite (art. 44(2))	NON	Case unique
Les variables sont liées à la finalité (art. 11)	NON	Répertoire des contacts
Le modèle ne discrimine pas selon l'origine (art. 17)	NEK	Écart de refus, indicateur indirect
Une évaluation d'impact a été conduite (art. 33)	NON	Aucune
Le traitement est autorisé (art. 19)	NON	Aucune autorisation
Le profilage est licite au regard de l'article 65	NEK	Lecture non tranchée

Décompte. Zéro OUI, six NON, deux NEK sur huit. $\mu = 0$ · $U = 0{,}25$ · $H = 0{,}81$ **bit**

Lecture. Aucune exigence n'est satisfaite. Les deux NEK portent sur les questions les plus graves, discrimination et délit, mais la recommandation n'en dépend pas : les six NON suffisent à demander la suspension des refus automatiques jusqu'à la mise en place d'une intervention humaine.

17.7 Ce que le Profilage demande à chaque Métier

Application Responsable de traitement

Ne jamais mettre en production un modèle qui décide sans prévoir le réexamen humain, l'explication et la contestation. M. NJOYA a suspendu les refus automatiques le 20 octobre : tout refus est désormais revu par un agent.

Application Auditeur de la protection des données

Poser les questions de la loi variable par variable, mesurer les écarts de traitement entre groupes avec un indicateur déclaré, et signaler la difficulté de l'article 65 sans la trancher.

Application Juriste conformité

Rédiger l'information sur la logique de la décision dans des termes que la personne comprend, et prévoir le circuit de contestation.

★ À retenir

- Le profilage évalue ; la décision automatisée décide ; les deux se recouvrent souvent sans se confondre.
- L'article 44 garantit, même après consentement, l'intervention humaine, l'expression du point de vue et la contestation.
- L'article 65 punit le traitement à des fins de profilage ; sa portée exacte n'est pas tranchée, et l'auditeur le dit.
- Une variable anodine peut servir d'intermédiaire à une donnée sensible ; l'audit compare les taux de décision entre groupes.
- À NOUN PAY, aucune exigence n'est satisfaite ; les refus automatiques ont été suspendus.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- distinguer profilage et décision automatisée ;
- énoncer les droits de l'article 44(3) ;
- repérer une variable qui sert d'intermédiaire à une origine.

✍ Exercice 17.1. Profilage, décision, ni l'un ni l'autre ★☆☆

(a) Un score de solvabilité montré à un conseiller qui décide ; (b) un refus de crédit automatique ; (c) une liste de clients triés par ancienneté ; (d) une publicité ciblée selon la localisation ; (e) le blocage automatique d'une transaction suspecte.

✍ Exercice 17.2. Répondre à M. ATANGANA ★★☆

Rédigez la réponse de NOUN PAY à M. ATANGANA : information sur la logique, réexamen humain, possibilité de contester. Que lui dites-vous des variables utilisées ?

✍ Exercice 17.3. Les taux de refus ★★☆

Calculez le rapport des taux de refus entre l'Extrême-Nord et l'Ouest. Que faudrait-il connaître de plus pour passer la proposition « le modèle discrimine selon l'origine » de NEK à OUI ou à NON ? Quelles données ne devez-vous pas collecter pour le savoir ?

✍ Exercice 17.4. Le pointage biométrique ★★★

Le Dr ABENA veut conserver le pointage par empreinte « parce que les salariés trichaient avec les badges ». Analysez le traitement au regard des articles 5, 9, 48 et 66. Proposez deux solutions, et dites comment vous coterez la licéité de chacune.

Note

Pour aller plus loin.

- L'ISO/IEC 27701 [24], pour l'encadrement des décisions automatisées.
- Le cours de gouvernance des SI de l'auteur (UE MSN-2S3-MSI03), chapitre sur la gouvernance des données et de l'IA.

Note

Transition. La santé, la banque, la justice et l'état civil sont renvoyés par la loi à des textes particuliers. Comment auditer dans ces secteurs, quand le régime général et le régime spécial se rencontrent ? C'est l'objet du Chapitre 18.

18

LES SECTEURS SENSIBLES

« Quand la loi renvoie à un texte particulier,
l'auditeur cherche le texte avant de conclure. »

Principe du cours

Niveau : *Expert* • Chapitres 1, 2 et 6

✦ Objectifs du chapitre

- ➢ Identifier les traitements que la loi renvoie à des textes particuliers (articles 4 et 72).
- ➢ Auditer quand régime général et régime spécial se rencontrent.
- ➢ Appliquer les règles propres aux données de santé, aux transactions bancaires et aux données des mineurs.
- ➢ Auditer une vidéosurveillance : fondement, information, durée, lieux filmés.
- ➢ Situer l'expert, l'OPJ et le magistrat au regard de la loi.

Avant de commencer : une caméra dans la salle d'attente

Bertoua, mardi 6 octobre 2026. Pour l'audit de suivi du CENTRE MÉDICAL MBOLO, Mme BELLO visite la pédiatrie. Une caméra filme la salle d'attente, où des mères allaitent et où des enfants attendent leurs vaccins. Les images sont affichées à l'accueil et enregistrées trente jours. Aucun panneau ne le signale. « C'est pour la sécurité, explique le surveillant, il y a eu des vols de téléphones. »

Au même moment, le service de facturation transmet chaque mois aux mutuelles des patients la liste des actes, avec le diagnostic en clair, « parce que les mutuelles le demandent ». Aucun texte n'a été montré à l'auditrice qui oblige à transmettre le diagnostic.

★ Attention

Violation typique. Justifier un traitement de données de santé ou de mineurs par la seule bonne intention (« la sécurité », « le remboursement ») sans vérifier le fondement, la proportion et les règles propres au secteur.

Règle : dans un secteur sensible, chaque traitement cumule les exigences de la loi générale, les règles propres aux données sensibles et, quand il existe, le texte particulier du secteur. Ce qui n'est pas prévu par un texte reste soumis à la loi générale.

18.1 Les Renvois à des Textes Particuliers

Deux articles de la loi renvoient à d'autres textes.

⚖ Jurisprudence & Droit applicable

Loi n° 2024/017, article 4 [26] : *« Tout traitement des données à caractère personnel effectué par les autorités compétentes en matière de sécurité et de défense est régi par des textes particuliers. »*

Loi n° 2024/017, article 72 [26] : *« Le traitement des données à caractère personnel relatif notamment à la sécurité, à la défense, à la santé, à la justice et à l'état civil est régi par des textes spécifiques, en tant que de besoin. »*

Portée. L'article 4 vise des *autorités* ; l'article 72 des *domaines*, avec « notamment » et « en tant que de besoin ». Ce dernier n'exclut pas ces domaines de la loi générale : il annonce des textes qui la complèteront ou l'adapteront. Tant qu'un texte spécifique n'est pas identifié, l'auditeur applique la loi générale et signale la réserve.

☑ Démarche d'audit

Auditer un traitement d'un secteur visé par l'article 72.

1. Rechercher le texte spécifique au secteur et au traitement ; noter la recherche et son résultat.
2. S'il existe, l'appliquer en même temps que la loi générale, et relever les points où il déroge.
3. S'il n'existe pas, appliquer la loi générale, et coter NEK de critère les seules exigences qu'un texte spécifique pourrait modifier.
4. Appliquer dans tous les cas les règles des données sensibles (articles 5, 48, 66) et des mineurs (articles 9(3), 18, 19(2), 40(3)).
5. Vérifier les secrets professionnels du secteur, qui s'ajoutent à la loi.

18.2 La Santé

Les données de santé sont sensibles (article 5). Le soin trouve un fondement dans la troisième dérogation de l'article 9 : le traitement « nécessaire [...] à la préservation de la santé de la personne concernée ou d'une autre personne physique ». Ce fondement couvre le soin, pas tout ce qui l'entoure : la facturation, la recherche, la formation, la communication avec les mutuelles ou les employeurs exigent chacun leur propre fondement.

Les professionnels de santé sont en outre tenus au secret médical, protégé par le droit pénal et par la déontologie médicale. Le secret ne se partage qu'entre ceux qui participent à la prise en charge, et dans la mesure nécessaire : c'est la règle que l'auditeur applique aux journaux de consultation (Chapitre 12), et c'est elle qui interdit de transmettre un diagnostic à une mutuelle sans texte ou sans consentement du patient.

18.3 La Banque et la Finance

Les transactions bancaires sont des données sensibles (article 5), et l'article 48, alinéa 2, interdit leur traitement « sans autorisation préalable des administrations et structures compétentes, dans les conditions et suivant les modalités prévues par les lois en vigueur ». La loi ne désigne pas ces administrations ; il peut s'agir des autorités de régulation bancaire ou monétaire. Pour l'auditeur, une microfinance comme NYANGA ou une fintech comme NOUN PAY doit pouvoir montrer, outre la demande d'autorisation à l'Autorité de protection, les agréments et autorisations de son régulateur sectoriel, et le texte qui encadre l'usage des données dans son activité. Faute de désignation claire, l'exigence « autorisation des administrations compétentes au titre de l'article 48(2) » est un NEK de critère.

Le secteur financier connaît aussi des obligations de conservation et de transmission (lutte contre le blanchiment, déclarations aux autorités) qui fondent des traitements au titre de l'obligation légale (article 9(2)). L'auditeur demande le texte précis ; une « obligation réglementaire » invoquée sans référence reste une déclaration.

18.4 Les Mineurs

La loi protège les mineurs à quatre endroits : le consentement d'un mineur de dix-huit ans n'est valable qu'appuyé par celui de ses parents ou de son représentant légal (article 9(3)) ; les traitements de leurs données en vue d'une offre de services doivent être « adéquat[s], pertinent[s] et limité[s] » (article 18) ; l'interconnexion de fichiers de données sensibles relatives aux mineurs exige une autorisation propre (article 19(2)) ; les parents peuvent s'opposer au traitement des données de leur enfant collectées sans leur consentement (article 40(3)).

En pédiatrie, l'enfant est soigné sur le fondement de la préservation de sa santé, et les parents consentent aux actes ; le consentement aux autres traitements (photographies pour un dossier de formation, participation à une étude) doit être recueilli auprès des parents, et l'enfant informé à sa mesure.

18.5 La Vidéosurveillance

La vidéosurveillance d'un lieu ouvert au public filme des personnes identifiables : c'est un traitement de données personnelles. La loi n'en fait pas un régime particulier ; elle s'applique donc entièrement, et la difficulté vient du fondement (Chapitre 2) : ni l'intérêt légitime ni le contrat n'existent dans la loi, et le consentement de chaque personne filmée est irréaliste. L'auditeur cote NEK le fondement tant qu'aucune autorisation ne l'a précisé, et vérifie tout ce qui ne dépend pas du fondement : la finalité, les lieux filmés, l'information par panneau, la durée de conservation, les personnes qui voient les images.

Question	Ce que l'auditeur vérifie
Finalité	Une seule, écrite : sécurité des biens et des personnes ; pas de contrôle du travail
Lieux filmés	Pas de lieu de soin, de toilettes, de vestiaire, d'espace d'allaitement
Information	Panneau visible à l'entrée de la zone filmée
Durée	Courte, fixée, appliquée (quelques semaines au plus, sauf incident)
Accès aux images	Personnes désignées, consultation journalisée
Affichage	Écrans hors de la vue du public

Tableau 18.1. Les questions d'audit d'une vidéosurveillance

18.6 Les Télécommunications

L'article 72 ne cite pas les télécommunications. Le secteur est pourtant celui où les textes particuliers sont les plus anciens et les plus nombreux (Chapitre 7). Un opérateur détient trois familles de données que peu d'organisations réunissent : l'identité de chaque abonné, ses données de trafic et sa localisation.

Donnée	Texte particulier	Question d'audit
Identité de l'abonné	Décret n° 2015/3759 du 3 septembre 2015 sur l'identification des abonnés et des terminaux	Quelles pièces sont copiées, où sont-elles gardées, qui y accède dans les points de vente ?
Contenu des communications	Loi n° 2010/012, articles 41 à 48	Le secret est-il garanti, y compris envers les salariés de l'opérateur ?
Données de connexion et de trafic	Loi n° 2010/012, article 29	Quelle durée est appliquée, et qui peut interroger ces données ?
Droits de l'utilisateur	Directive n° 07/08-UEAC-133-CM-18 de la CEMAC [4]	L'abonné est-il informé et peut-il s'opposer à la prospection ?

Tableau 18.2. Les données d'un opérateur et leurs textes

18.6.1 L'identification des abonnés

L'obligation d'identifier chaque abonné fonde le traitement au titre de l'obligation légale (article 9(2) de la loi n° 2024/017). Elle ne règle pas tout. L'auditeur vérifie quatre points que le texte particulier laisse à la loi générale.

1. **La minimisation.** L'opérateur collecte-t-il seulement ce que le texte demande, ou ajoute-t-il des données pour ses besoins commerciaux ?
2. **Les points de vente.** Les revendeurs photographient les pièces d'identité avec leur propre téléphone. Ces copies sont-elles effacées après transmission ?
3. **La réutilisation.** Les données d'identification servent-elles à la prospection ou à la notation, ce qui serait un détournement de finalité (article 11) ?
4. **La fin du contrat.** Que deviennent les données d'un abonné qui résilie ?

18.6.2 L'opérateur comme sous-traitant

Un opérateur est aussi le prestataire de ses clients. Celui qui envoie les SMS de NYANGA CRÉDIT reçoit des numéros et des messages de relance. Pour ces envois, il est sous-traitant de la microfinance. Pour l'acheminement lui-même et pour les données de trafic qu'il conserve, il est responsable de son propre traitement. Le contrat type qu'il impose ne distingue pas les deux rôles. C'est l'une des raisons du NEK relevé dans le domaine D4 (Chapitre 13).

Deux autorités se partagent le secteur : le régulateur des télécommunications pour les obligations de l'opérateur, l'Autorité de protection des données pour les droits des personnes. Tant que la seconde n'est pas organisée, l'auditeur note auprès de quelle autorité chaque exigence pourrait être vérifiée.

18.7 La Justice et la Chaîne Pénale

La justice figure parmi les domaines de l'article 72. L'expert judiciaire, l'officier de police judiciaire et le magistrat traitent tous des données personnelles : saisies, analyses, rapports, transmissions. Leur qualité au regard de la loi (responsable, sous-traitant, autre acteur habilité) n'est pas fixée par un texte.

Dans leur travail en cours, l'auteur de ce cours et ses coauteurs [29] proposent de déterminer cette qualité « opération par opération », et non selon la qualité institutionnelle : un expert qui collecte des données sur instruction d'une autorité judiciaire peut être sous-traitant pour cette opération, et devenir responsable pour la copie qu'il conserve pour ses propres besoins techniques. Le Chapitre 19 présente cette grille comme une piste de recherche. Pour l'audit d'un cabinet d'expertise, elle suggère une règle pratique : tenir un registre de ses traitements, et pour chaque mission, documenter qui a déterminé la finalité.

18.8 L'Audit de Suivi de MBOLO

Scénario Opérationnel · Mission MBOLO. Les traitements sensibles, octobre 2026

Constatations. La caméra de pédiatrie filme un espace où des mères allaitent ; aucun panneau ; écran visible depuis le couloir. Le diagnostic est transmis en clair aux mutuelles chaque mois, pour 1 640 patients en septembre ; aucun texte n'a été présenté, et les formulaires d'adhésion des mutuelles ne mentionnent pas cette transmission. Les consentements parentaux sont recueillis pour les actes, pas pour les photographies prises pour le dossier de formation des internes. Le texte spécifique au secteur de la santé annoncé par l'article 72 n'a pas été trouvé.

Lecture auditologique · Traitements sensibles de MBOLO, octobre 2026

Exigence	Cote	Preuve
Le soin repose sur la dérogation de l'article 9(2)	OUI	Finalité de soin
La transmission du diagnostic aux mutuelles a un fondement	NON	Aucun texte, aucun consentement
Les lieux filmés excluent les espaces intimes	NON	Salle d'allaitement filmée
La vidéosurveillance est signalée	NON	Aucun panneau
La vidéosurveillance a un fondement valable	NEK	Fondement incertain
Les photographies d'enfants ont le consentement des parents	NON	Dossier de formation
Un texte spécifique à la santé modifie ces exigences	NEK	Texte non trouvé

Décompte. Un OUI, quatre NON, deux NEK sur sept. $\mu = 0{,}14$ · $U = 0{,}29$ · $H = 1{,}38$ **bit**

Lecture. Domaine opaque, mais les quatre NON ne dépendent d'aucun texte spécifique : un texte de santé pourrait préciser la transmission aux mutuelles, il ne rendrait pas licite une caméra dans un espace d'allaitement.

18.9 Ce que les Secteurs demandent à chaque Métier

Application Juriste conformité

Tenir une veille des textes spécifiques annoncés par l'article 72, et une liste, par traitement, des textes sectoriels qui l'encadrent.

Application Auditeur de la protection des données

Documenter la recherche du texte spécifique, appliquer la loi générale en son absence, et ne coter NEK de critère que les exigences qu'un tel texte pourrait réellement modifier.

Application Responsable de traitement

Faire déplacer la caméra et retirer le diagnostic des listes transmises aux mutuelles dès le rapport : ces écarts ne dépendent d'aucun texte à venir.

★ À retenir

- L'article 4 renvoie la sécurité et la défense à des textes particuliers ; l'article 72 annonce des textes spécifiques pour la santé, la justice, l'état civil et d'autres domaines.
- En l'absence de texte spécifique, la loi générale s'applique, et l'auditeur signale la réserve.
- La préservation de la santé fonde le soin, pas la facturation, la formation ou la transmission aux tiers.
- Les mineurs bénéficient de quatre protections propres ; la vidéosurveillance se vérifie lieu par lieu.
- À MBOLO, quatre écarts sont établis indépendamment de tout texte sectoriel.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- lire l'article 72 sans en faire une exclusion générale ;
- auditer une vidéosurveillance ;
- dire ce que couvre la dérogation de santé de l'article 9.

✍ Exercice 18.1. Quel fondement ★☆☆

Quel fondement pour : (a) le dossier médical d'un patient ; (b) la facturation d'un acte ; (c) une étude sur le paludisme à partir des dossiers ; (d) la photographie d'une plaie pour la formation des internes ?

✍ Exercice 18.2. Les mutuelles ★★☆

Proposez un circuit de transmission aux mutuelles conforme à la loi et au secret médical : données transmises, fondement, information des patients.

✍ Exercice 18.3. La caméra ★★☆

Rédigez la recommandation sur la vidéosurveillance de la pédiatrie, en reprenant les questions du Tableau 18.1. Que reste-t-il NEK après sa mise en œuvre, et pourquoi ?

✍ Exercice 18.4. Un cabinet d'expertise ★★★

Un cabinet d'expertise judiciaire vous demande un audit. Pour trois de ses opérations (recevoir un scellé, analyser une copie, conserver une copie après la mission), proposez la qualification de l'expert au regard de la loi, en suivant la grille opération par opération, et dites quelles exigences vous auditerez pour chacune.

● Note

Pour aller plus loin.

- La loi n° 2024/017 [26], articles 4, 9, 18, 48 et 72.
- T. E. Minka Mi Nguidjoï, R. T. Massoussi Songo et D. Bialo [29], pour la chaîne pénale.

● Note

Transition. Tout au long du cours, des NEK se sont accumulés : de preuve et de critère, de faits et de textes. Peut-on mesurer cette incertitude, et que dit-elle de l'état du droit lui-même ? C'est la question de recherche du Chapitre 19.

partie VII

Recherche : Mesurer la Conformité, Articuler les Normes

© *MaletYon*

19

MESURER LA CONFORMITÉ, ARTICULER LES NORMES

« Ce que l'on ignore à cause des faits se cherche.
Ce que l'on ignore à cause des textes se signale. »

Principe du cours

Niveau : *Recherche* • Tout le cours, en particulier les Chapitres 8, 6 et 16

✦ Objectifs du chapitre

- ➢ Mesurer l'état de conformité d'une organisation par μ, U et H, et en suivre l'évolution.
- ➢ Distinguer et mesurer séparément l'incertitude de preuve et l'incertitude de critère.
- ➢ Présenter les pistes de recherche actuelles de l'auteur et de ses coauteurs sur l'articulation de la loi n° 2024/017 avec la chaîne pénale.
- ➢ Appliquer une matrice d'analyse des tensions normatives à un cas.
- ➢ Formuler une question de recherche sur la mesure de la conformité ou l'articulation des normes.

Avant de commencer : « dix inconnus, est-ce notre faute ? »

Bafoussam, vendredi 25 septembre 2026. Le conseil d'administration de NYANGA CRÉDIT a lu la synthèse : vingt-huit écarts, huit exigences satisfaites, dix inconnues. Un administrateur demande : « Ces dix inconnues, est-ce notre faute ? » Mme BELLO répond que quatre le sont : des pièces que l'établissement n'a pas pu produire. Les six autres ne dépendent de personne dans la salle : elles attendent un décret, une liste de pays, un référentiel, ou la décision d'un juge sur le sens d'un article.

La réponse ouvre deux questions de recherche. La première est de mesure : peut-on séparer, dans un rapport, ce que l'organisation ignore de ce que le droit lui-même ne dit pas encore ? La seconde est d'articulation : que faire quand deux textes applicables à la même donnée se rencontrent ?

© *MaletYon*

★ Attention

Violation typique. Imputer à l'organisation auditée toute l'incertitude d'un audit, y compris celle qui vient de textes absents ou contradictoires.

Règle : l'incertitude se décompose selon sa source. Le rapport distingue ce qui manque dans les preuves de ce qui manque dans les critères, et il présente les secondes comme une information sur l'état du droit, pas comme un défaut de l'organisation.

19.1 Mesurer l'État de Conformité

■ Définition

Pour un ensemble de n exigences cotées : $\mu = n_O/n$ (taux de conformité), $U = n_K/n$ (taux d'incertitude), $H = -\sum_c p_c \log_2 p_c$ (entropie de la répartition des cotes, en bits, entre 0 et $\log_2 3 \approx 1{,}585$) [27], [39].

⚖ Lecture auditologique · NYANGA CRÉDIT, deux instantanés

Date	n	O / N / K	μ	U	H	
6 juillet 2026	8	2 / 2 / 4	0,25	0,50	1,50	premier jour
25 septembre 2026	46	8 / 28 / 10	0,17	0,22	1,35	rapport

Lecture. Entre les deux dates, U baisse de 0,50 à 0,22 : l'audit a appris. μ baisse aussi, de 0,25 à 0,17, sans que l'établissement ait régressé : les NEK du premier jour se sont résolus surtout en NON. Une baisse de μ au cours d'un audit est donc souvent un signe de connaissance, pas de dégradation. Les deux instantanés ne portent pas sur le même ensemble d'exigences ; la comparaison n'est rigoureuse que sur les huit exigences communes.

La dernière remarque est une première question de recherche : comment comparer deux états de conformité mesurés sur des ensembles d'exigences différents, ou découpés différemment ? Les mesures dépendent de la granularité ; un domaine découpé en dix exigences pèse plus qu'un domaine découpé en quatre.

19.2 Deux Sortes d'Incertitude

Le cours a distingué tout au long deux sources de NEK :

- le **nek de preuve** : le critère est clair, la pièce manque ; il se lève en cherchant (audit du prestataire, examen des sauvegardes) ;
- le **nek de critère** : la pièce existerait, mais la règle qui permettrait de la juger n'est pas fixée ; il se lève avec un texte (décret, référentiel, liste de pays) ou une décision de justice.

Le cours propose, à titre de piste, de décomposer le taux d'incertitude en deux termes :

$$U = U_p + U_c, \qquad U_p = \frac{n_{K,p}}{n}, \qquad U_c = \frac{n_{K,c}}{n},$$

où $n_{K,p}$ et $n_{K,c}$ comptent les NEK de preuve et de critère. À NYANGA, sur 46 exigences, quatre NEK sont de preuve et six de critère : $U_p \approx 0{,}09$ et $U_c \approx 0{,}13$.

U_p mesure ce que l'organisation peut réduire. U_c mesure ce que l'état du droit laisse ouvert ; mesuré sur plusieurs organisations et plusieurs années, il pourrait servir d'indicateur de la maturité du cadre normatif lui-même, et décroître à mesure que les textes d'application paraissent. Cette décomposition n'est pas encore validée : elle suppose une règle sûre pour classer chaque NEK, et certains relèvent des deux sources à la fois.

19.3 Une Piste de Recherche Actuelle : la Loi et la Chaîne Pénale

Note

Statut de cette section. Elle présente un travail en cours de l'auteur de ce cours et de ses coauteurs, M. Robert Thierry MASSOUSSI SONGO et M. Dieudonné BIALO, intitulé « Protection des données personnelles et chaîne pénale au Cameroun : analyse des zones de tension normative autour de la Loi n°2024/017 » [29]. Ce manuscrit n'est pas encore publié ; ses analyses et ses propositions sont celles des auteurs, et elles peuvent évoluer. Les cas qu'il étudie sont construits à des fins d'analyse.

19.3.1 La question

Les auteurs partent d'un constat : la loi n° 2024/017 institue un régime général, mais ses articles 4 et 72 renvoient la sécurité, la défense et la justice à des textes particuliers ou spécifiques. Leur problématique est de savoir dans quelle mesure la loi constitue le régime de référence pour les traitements de la chaîne pénale (police judiciaire, expertise, magistrature), et quelles zones de tension subsistent avec les autres instruments applicables : le Code pénal, le Code de procédure pénale, la loi n° 2010/012, la Convention de Budapest à laquelle le Cameroun est Partie, et la Convention de Malabo, signée mais non ratifiée.

19.3.2 Trois niveaux d'articulation

Les auteurs distinguent trois situations entre deux normes applicables à la même opération :

- la **compatibilité** : elles s'appliquent simultanément sans difficulté ;
- la **tension** : leur application simultanée crée une difficulté qui demande une interprétation ou des garanties ;

➢ l'**incompatibilité** : les deux obligations ne peuvent pas juridiquement être satisfaites ensemble.

Cette distinction, selon eux, évite de transformer toute difficulté d'articulation en conflit de normes.

19.3.3 La matrice d'analyse

N°	Étape	Question
1	Applicabilité	Chaque norme est-elle applicable ?
2	Qualification	Quelle est la qualification juridique de l'opération ?
3	Concurrence	Les normes portent-elles sur la même opération ?
4	Conciliabilité	Imposent-elles réellement des obligations simultanées ?
5	Interprétation	Peut-on les concilier par interprétation ?
6	Qualification de la tension	Compatibilité, tension ou incompatibilité ?
7	Mécanisme	Quel mécanisme de résolution est envisageable ?
8	Proposition	Quelle solution proposer ?

Tableau 19.1. La matrice des auteurs (d'après [29])

19.3.4 Trois zones de tension

Zone	Nature	Description
T1	Temporelle	Les données collectées avant la loi, puis conservées, analysées ou produites en justice après son entrée en vigueur : quelle loi régit chaque opération ?
T2	Procédurale	L'information « sans délai » de la personne (article 22) et le secret de l'enquête et de l'information judiciaire (articles 102 et 154 du Code de procédure pénale)
T3	Transfrontalière	La conservation rapide de la Convention de Budapest (article 29) et l'autorisation préalable des articles 19 et 32, sous réserve de l'article 72

Tableau 19.2. Les trois zones de tension (d'après [29])

Pour la zone temporelle, les auteurs privilégient une solution où la légalité de la collecte est régie par la loi en vigueur au moment de la collecte, en distinguant ensuite conservation et traitement ultérieur. Pour la zone transfrontalière, ils recommandent de distinguer conservation, préservation, production, transmission et transfert, qui peuvent

relever de régimes différents. Leur conclusion est que ces zones ne constituent pas, à ce stade, des incompatibilités irréductibles : leur résolution appelle, selon les cas, une clarification jurisprudentielle, réglementaire ou législative.

19.3.5 Une quatrième zone, proposée par ce cours

Les trois zones qui précèdent viennent du manuscrit cité. Le cours en propose une quatrième, que les missions du livre ont rencontrée à chaque audit. Elle n'engage pas les coauteurs du manuscrit.

Zone	Nature	Description
T4	Conservation	La durée limitée à la finalité (articles 13 et 28 de la loi n° 2024/017) et les conservations longues imposées par d'autres textes : dix ans pour les données de connexion et de trafic (article 29 de la loi n° 2010/012), dix ans pour les pièces comptables

Appliquons la matrice. Les deux séries de textes visent des objets voisins : un journal contient des données personnelles, une pièce comptable aussi. Elles poursuivent des finalités différentes, protéger la personne d'un côté, permettre la preuve de l'autre. Elles ne sont pas incompatibles, car l'article 9(2) admet le traitement fondé sur une obligation légale. La tension naît de deux silences. Aucun texte ne dit quels journaux l'article 29 vise au juste (Chapitre 7). Le texte d'application des articles 13 et 28 sur les durées n'est pas publié.

Pour l'auditeur, la conséquence est celle de l'hypothèse énoncée plus bas : l'exigence « la durée de conservation est conforme » est un NEK de critère pour toute donnée que deux textes se disputent. La règle pratique du cours tient en trois gestes. Séparer ce que le texte long vise de ce qu'il ne vise pas. Garder le premier pendant la durée imposée, avec un accès restreint à la seule finalité de preuve. Appliquer au reste la durée la plus courte que la finalité justifie.

19.3.6 Qualifier les acteurs opération par opération

Acteur	Qualification possible selon les auteurs
Magistrat	Responsable du traitement lorsqu'il détermine les finalités et les principaux éléments du traitement, sous réserve des circonstances
OPJ	Responsable du traitement ou autre acteur habilité, selon le cadre institutionnel, les finalités et son autonomie de décision
Expert	Sous-traitant possible lorsqu'il traite pour le compte d'un responsable sans déterminer lui-même les finalités

Tableau 19.3. La grille fonctionnelle (d'après [29])

19.3.7 Quatre propositions

Les auteurs formulent quatre propositions : clarifier le champ d'application de la loi aux traitements judiciaires ; distinguer les opérations dans les échanges transfrontaliers ; prévoir un mécanisme qui permette au magistrat compétent d'apprécier le moment et les modalités de l'information quand elle risque de compromettre une enquête ; élaborer une doctrine sur la temporalité des traitements. Ils annoncent des études complémentaires sur l'effet d'une éventuelle ratification de la Convention de Malabo, sur la jurisprudence à venir, et sur les textes d'application de la loi lorsqu'ils seront publiés.

19.4 Deux Échelles à Trois Niveaux

Le cours rapproche, à titre de question ouverte, deux instruments de l'auteur. Les cotes OUI, NON, NEK portent sur des *faits* : une exigence est-elle satisfaite, au vu des preuves ? L'échelle compatibilité, tension, incompatibilité porte sur des *normes* : deux textes peuvent-ils être satisfaits ensemble ?

Une hypothèse de recherche se dessine : une exigence qui relève d'une zone de tension non résolue produit, dans un audit, un NEK de critère. La compatibilité permettrait de coter normalement ; l'incompatibilité obligerait à choisir un texte et à le dire ; la tension laisserait un NEK tant qu'aucune interprétation ne s'impose. Si cette hypothèse se vérifiait, le taux U_c d'un audit pourrait se rattacher aux zones de tension recensées par l'analyse juridique. Rien de cela n'est encore établi ; c'est un programme de travail.

19.5 Questions Ouvertes

- **La granularité.** Comment normaliser le découpage des exigences pour comparer des audits entre eux ?
- **La pondération.** Toutes les exigences ne pèsent pas autant pour les personnes. Faut-il pondérer μ et U par la gravité, et comment éviter que la pondération ne devienne arbitraire ?
- **La classification des nek.** Quelle règle permet de classer sûrement un NEK en preuve ou en critère ?
- **La maturité normative.** Le taux U_c mesuré sur plusieurs organisations permet-il de suivre la mise en place des textes d'application ?
- **L'articulation des normes.** La matrice des auteurs peut-elle être outillée pour guider l'auditeur devant une exigence prise entre deux textes ?

Note

Construire un sujet de mémoire.

1. Choisir un objet : une organisation, un secteur, un type de traitement, une zone de tension.
2. Fixer l'ensemble des exigences et la règle de cotation.

3. Recueillir des cas réels anonymisés, avec l'accord des organisations, ou des cas construits et documentés.
4. Mesurer μ, U_p, U_c et H, ou appliquer la matrice des tensions.
5. Confronter les résultats à un jugement d'experts.
6. Dire les limites : taille de l'échantillon, subjectivité des cotes, état des textes à la date de l'étude.

19.6 Ce que la Mesure demande à chaque Métier

Application Auditeur de la protection des données

Classer chaque NEK en preuve ou en critère, publier U_p et U_c à côté de μ, et dire dans le rapport ce qui ne dépend pas de l'organisation.

Application Juriste conformité

Tenir la liste des zones de tension qui touchent l'organisation, avec, pour chacune, l'interprétation retenue et sa justification, en attendant les textes ou la jurisprudence.

Application Responsable de traitement

Suivre d'un audit à l'autre l'évolution de U_p, qui mesure ce que l'organisation peut encore apprendre sur elle-même.

★ À retenir

- μ, U et H décrivent l'état de conformité ; une baisse de μ au cours d'un audit traduit souvent une connaissance nouvelle.
- Le cours propose de décomposer U en incertitude de preuve et incertitude de critère ; à NYANGA, $U_p \approx 0{,}09$ et $U_c \approx 0{,}13$.
- L'auteur et ses coauteurs étudient, dans un travail en cours, les tensions temporelle, procédurale et transfrontalière entre la loi et la chaîne pénale, avec une matrice en huit étapes.
- Ils distinguent compatibilité, tension et incompatibilité, et qualifient les acteurs opération par opération.
- Le rapprochement de cette échelle et des cotes OUI, NON, NEK est une question de recherche ouverte.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- calculer U_p et U_c pour un ensemble de cotes ;

- ➢ appliquer la matrice des tensions à un cas simple ;
- ➢ formuler une question de recherche et ses limites.

✍ Exercice 19.1. Calculer ★☆☆

Pour un audit de 20 exigences : 6 OUI, 9 NON, 3 NEK de preuve et 2 NEK de critère. Calculez μ, U, U_p, U_c et H.

✍ Exercice 19.2. Classer les NEK ★★☆

Classez en preuve ou en critère les NEK suivants, rencontrés dans le cours : (a) l'exécution des mesures par l'éditeur du logiciel bancaire ; (b) le niveau de protection de la Côte d'Ivoire ; (c) la licéité du profilage au regard de l'article 65 ; (d) le pays de traitement des selfies ; (e) l'application de l'article 22 en mars 2025.

✍ Exercice 19.3. La matrice ★★☆

Appliquez les huit étapes de la matrice à la tension T2 dans l'affaire NYANGA : la demande de l'OPJ du 20 mars 2025 et l'article 22. À quelle étape la situation change-t-elle en février 2026 ?

✍ Exercice 19.4. Un sujet de mémoire ★★★

Choisissez l'une des questions ouvertes de la section 19.5 et rédigez une proposition de mémoire d'une page : question, hypothèse, données, méthode, critère de validation, limites.

● Note

Pour aller plus loin.

- ➢ T. E. Minka Mi Nguidjoï, « Vers l'auditologie » [28].
- ➢ T. E. Minka Mi Nguidjoï, sur l'instrument trichotomique [27].
- ➢ T. E. Minka Mi Nguidjoï, R. T. Massoussi Songo et D. Bialo, manuscrit en préparation [29].

● Note

Fin du cours. L'affaire a commencé par une lettre, le lendemain d'une échéance : « Sommes-nous en règle ? » Elle s'achève sur un rapport qui répond non sur vingt-huit points, oui sur huit, et qui dit pourquoi il ne peut pas répondre sur dix. Entre les deux, l'audit a recensé, apprécié, vérifié, coté et recommandé. La conformité n'est pas un état que l'on déclare ; c'est une preuve que l'on construit, et dont on dit les limites.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les définitions données dans les chapitres. Les définitions tirées de l'article 5 de la loi n° 2024/017 sont paraphrasées ; le texte exact figure dans le chapitre indiqué.

Anonymisation Modification ou suppression d'informations pour rendre les données non attribuables à des personnes ; elle doit être prouvée (Ch. 1).

Autorisation préalable Acte de l'Autorité auquel la loi soumet tout traitement (art. 19) et tout transfert (art. 32) (Ch. 6).

Autorité de protection Organisme public indépendant chargé de veiller à l'application de la loi, créé et organisé par décret (art. 53) (Ch. 6).

Clauses contractuelles types Clauses élaborées et publiées par l'Autorité pour encadrer les transferts (Ch. 14).

Consentement Manifestation de volonté expresse, non équivoque, non contrainte, libre et éclairée ; préalable, spécifique et univoque selon l'article 9 (Ch. 2).

Constatation Fait vérifiable, rattaché à une pièce (Ch. 0).

Critère de substitution Critère déclaré dans le plan d'audit quand le texte applicable n'est pas publié (Ch. 11).

Décision automatisée Décision fondée exclusivement sur un traitement automatisé (art. 44) (Ch. 17).

Découverte des données Recherche, dans les supports réels, des données personnelles que le registre ignore (Ch. 9).

Délégué à la protection des données Fonction de bonne pratique, non prévue par la loi, chargée du registre, du conseil et des demandes (Ch. 0).

Destinataire Personne habilitée à recevoir une communication des données (Ch. 1).

Donnée à caractère personnel Information permettant d'identifier une personne directement ou indirectement (Ch. 1).

© *MaletYon*

Donnée sensible Donnée relative notamment aux opinions, aux transactions bancaires, à l'origine ethnique, linguistique ou régionale, à la vie sexuelle, à la génétique, à la biométrie, à la santé, aux poursuites et sanctions (Ch. 1).

Entropie (H) Dispersion des cotes d'un ensemble d'exigences, en bits (Ch. 8).

Évaluation d'impact Procédure qui analyse la probabilité et la gravité des risques pour les droits et libertés (art. 33) (Ch. 10).

Fichier Ensemble structuré de données personnelles accessibles selon des critères (Ch. 1).

Finalité But d'un traitement ; elle le définit et le limite (art. 11) (Ch. 2).

Interconnexion Mise en relation de données traitées pour une finalité avec d'autres données (art. 36) (Ch. 9).

nek de critère Incertitude qui tient à une règle non fixée (texte non publié, lecture non tranchée) (Ch. 8).

nek de preuve Incertitude qui tient à une pièce manquante (Ch. 8).

oui, non, nek Cotes d'une exigence : conformité établie, écart établi, connaissance insuffisante (Ch. 0).

Papier de travail Document qui trace un constat : exigence, critère, test, preuve, cote, auteur (Ch. 8).

Personne concernée Personne dont les données sont traitées (Ch. 1).

Portabilité Droit de recevoir gratuitement ses données dans un format structuré et de les faire transmettre (art. 43) (Ch. 11).

Profilage Traitement automatisé qui évalue des aspects personnels (santé, préférences, localisation, situation économique) (Ch. 17).

Pseudonymisation Remplacement des identifiants directs par des identifiants artificiels ; les données restent personnelles (Ch. 1).

Registre des activités de traitement Registre exigé par l'article 29 (Ch. 9).

Responsable du traitement Personne qui détermine les finalités et les moyens d'un traitement (Ch. 1).

Responsables conjoints Responsables qui déterminent ensemble finalités et moyens ; convention publique (art. 31) (Ch. 13).

Sous-traitant Personne qui traite des données pour le compte et sur instruction du responsable (Ch. 1).

Taux de conformité (μ) Part des exigences cotées OUI (Ch. 8).

Taux d'incertitude (U) Part des exigences cotées NEK ; décomposable en U_p et U_c (Ch. 19).

Tension normative Situation où l'application simultanée de deux normes demande une interprétation, entre la compatibilité et l'incompatibilité (Ch. 19).

Traitement Toute opération appliquée à des données personnelles, de la collecte à la destruction (Ch. 1).

Transfert international Acheminement de données au-delà des frontières (Ch. 14).

Violation de données Atteinte à la sécurité entraînant destruction, perte, altération, divulgation ou accès non autorisé (Ch. 15).

B

OUTILS

Les outils servent l'audit ; ils ne le remplacent pas. Chacun produit des pièces qu'il faut ensuite qualifier, coter et documenter. Les outils de découverte et d'analyse s'utilisent avec l'accord écrit du commanditaire, sur les seuls systèmes de l'organisation.

Besoin	Outil ou méthode	Chapitre
Tenir le registre	Tableur structuré selon le Tableau 9.1, ou base légère ; un modèle figure à l'annexe C	9
Découvrir les données	Recherche de motifs par expressions régulières (`grep`, `ripgrep`) sur les partages ; lecture des schémas de bases	9
Conduire une évaluation d'impact	Logiciel PIA de la CNIL (libre) ou modèle tableur	10
Analyser les flux d'une application	Mandataire d'interception sur un appareil de test (`mitmproxy`), journaux DNS, `Wireshark`	14
Repérer les traqueurs d'une application mobile	Analyse statique (`MobSF`), bases publiques de traqueurs (Exodus Privacy)	9
Exploiter des journaux d'accès	Tableur, `Python` et `pandas` pour le rapprochement avec les plannings	12
Mesurer μ, U, H	Tableur ou script ; formules du Chapitre 8	8
Comparer des taux de décision	Tableaux croisés par groupe déclaré	17
Protéger les données de l'audit	Conteneur chiffré, masquage des identités dans les papiers	8

Tableau B.1. Outils de l'audit de protection des données

Note

Un outil a ses angles morts. Une recherche de motifs ne voit pas les images scannées ; un mandataire d'interception ne voit pas les flux d'un serveur ; une analyse statique ne dit pas ce qu'une bibliothèque envoie vraiment. L'auditeur écrit, pour chaque outil, ce qu'il a couvert et ce qu'il n'a pas pu couvrir.

C

MODÈLES DE DOCUMENTS

Ces modèles sont des points de départ ; chaque mission les adapte et le dit.

C.1 Fiche de registre

Rubrique	Contenu
Nom et finalité	Une finalité, en une phrase
Responsable, sous-traitants	Noms et coordonnées, contrats
Personnes concernées	Catégories
Données	Catégories, données sensibles signalées
Fondement	Consentement ou dérogation de l'article 9, pièce
Destinataires	Internes, externes
Transferts	Pays, garanties, état de l'autorisation
Durée de conservation	Base active, archive, purge
Mesures de sécurité	Renvoi aux mesures de l'article 27
Autorisation	Numéro, ou état de la demande
Propriétaire, revue	Nom, date

C.2 Papier de travail

Rubrique	Contenu
Référence	Domaine, numéro de l'exigence
Exigence	Question fermée, atomique
Critère	Article, norme, ou critère de substitution déclaré
Test	Ce qui a été fait, sur quel échantillon
Preuve	Référence des pièces, sans données personnelles en clair
Cote	OUI, NON ou NEK (de preuve ou de critère)
Commentaire	Constatation, puis analyse avec niveau de confiance
Auteur, réviseur, dates	

C.3 Réponse à une demande d'accès

Objet : votre demande d'accès du [date]. Nous confirmons traiter des données vous concernant. Vous trouverez ci-joint : la liste de ces données et leur origine ; les finalités

des traitements ; les destinataires ou catégories de destinataires ; la durée de conservation ; les transferts éventuels hors du Cameroun. Vous pouvez demander la rectification, l'effacement ou la limitation de ces données, et vous opposer à leur traitement, en écrivant à [contact]. Vous pouvez également introduire une réclamation auprès de l'Autorité de protection des données à caractère personnel.

C.4 Information des personnes après une violation

Objet : incident concernant vos données. Le [date], nous avons constaté [nature de la violation]. Les données concernées sont [catégories]. Les conséquences possibles pour vous sont [conséquences]. Nous avons pris les mesures suivantes : [mesures]. Nous vous recommandons de [mesures à la portée de la personne]. Pour toute question : [contact].

C.5 Plan d'audit

Mandat (commanditaire, objectif, destinataires, date de remise) ; critères (articles, textes publiés, norme, politiques internes, critères de substitution déclarés) ; périmètre et exclusions ; domaines et exigences ; tests et échantillons ; traitement des données de l'audit ; règle de décision et seuils ; calendrier.

C.6 Clauses de sous-traitance

Les douze clauses du Tableau 13.1 du Chapitre 13.

D

TEXTES ET NORMES

Degré de vérification des textes cités

Texte	Source utilisée	Citation dans le cours
Loi n° 2024/017 du 23 décembre 2024	Copie certifiée conforme du Secrétariat général de la Présidence	Articles cités mot pour mot
Loi n° 2010/012 du 21 décembre 2010	Texte officiel	Articles 41 à 47 cités mot pour mot
Code de procédure pénale, articles 102 et 154	D'après Minka Mi Nguidjoï et al. (2026)	Paraphrasés, non cités
Convention de Malabo (2014)	Texte de l'Union africaine ; statut d'après Minka Mi Nguidjoï et al. (2026)	Paraphrasée
Convention de Budapest (2001)	Conseil de l'Europe ; statut d'après Minka Mi Nguidjoï et al. (2026)	Paraphrasée
RGPD (UE) 2016/679	Journal officiel de l'Union européenne	Paraphrasé, pour comparaison
Normes ISO et ISO/IEC	Sous licence	Paraphrasées, jamais reproduites
Méthode PIA de la CNIL	Publication libre	Paraphrasée

© MaletYon

Textes internationaux et étrangers cités

Texte	Nature	Place dans le cours
Lignes directrices de l'OCDE (1980, révisées en 2013) [34]	Recommandat	Origine des principes, Chapitre 3
Principes directeurs des Nations Unies (1990) [32]	Résolution	Chapitre 3
Convention 108 (1981) et protocole de 2018 [10], [12]	Traité du Conseil de l'Europe	Chapitre 3 ; fiches pays
Convention de Malabo (2014) [13]	Traité de l'Union africaine	Chapitre 3
Acte additionnel de la CEDEAO (2010) [1]	Acte communautaire	Comparaison, Chapitre 3
Directive n° 07/08-UEAC-133-CM-18 de la CEMAC (2008) [4]	Directive communautaire	Chapitres 7 et 18
Convention de Budapest (2001) [11]	Traité du Conseil de l'Europe	Chapitres 3, 14 et 19
RGPD (UE) 2016/679 [35]	Règlement européen	Chapitre 4 ; double cote aux Chapitres 14 et 15
Clauses contractuelles types de 2021 [8]	Décision de la Commission	Chapitre 14
Règlement (UE) 2024/1689 sur l'intelligence artificielle [43]	Règlement européen	Chapitre 17
Loi ivoirienne n° 2013-450 [36]	Loi étrangère	Fiche pays, Chapitre 3
Loi marocaine n° 09-08 [38]	Loi étrangère	Fiche pays, Chapitre 3
NIST Privacy Framework 1.0 [30]	Cadre volontaire	Chapitre 5
NIST AI RMF 1.0 [31]	Cadre volontaire	Chapitre 17
Stratégie continentale de l'Union africaine sur l'intelligence artificielle (2024) [42]	Orientation politique	Chapitre 17

Aucun de ces textes n'est un critère obligatoire pour une organisation qui ne traite que des données de personnes situées au Cameroun, à l'exception des traités auxquels le Cameroun est Partie et des actes de la CEMAC. Le Chapitre 7 donne la méthode pour choisir ses critères.

Textes d'application attendus

À la date du cours, l'auteur n'a pas trouvé de texte publié pour les dispositions suivantes, qui renvoient à la voie réglementaire ou à un référentiel de l'Autorité : organisation de l'Autorité (art. 53) ; modalités d'autorisation (art. 19, 32) ; critères d'évaluation du risque et de l'évaluation d'impact (art. 25, 33) ; durées de conservation (art. 13, 28) ; délais d'examen des demandes (art. 47) ; référentiel des mesures (art. 24, 27, 57) ; mécanisme de certification (art. 34) ; contrôle (art. 35) ; textes spécifiques des secteurs (art. 4, 72). Le lecteur vérifiera l'état de ces textes au moment où il lit.

Correspondance des articles et des chapitres

Articles	Chapitres
1 à 5	1
6 à 18	2
19	6
20, 30, 31	13
21, 37 à 47	2, 11
22	15
24 à 28	12, 16
29, 36	9
32	14
33	10
34	6, 5
44, 65	17
48 à 52, 72	1, 18
53 à 71	6
73	0, 19

E

BIBLIOGRAPHIE COMMENTÉE

Les textes. La loi n° 2024/017 [26] est la source première du cours ; on la lit en entier, une fois, avant d'auditer. La loi n° 2010/012 [25] reste utile pour la vie privée dans les communications.

Le cadre africain. La Convention de Malabo [13] et l'acte additionnel de la CEDEAO [1] situent la loi camerounaise dans son environnement régional.

La comparaison européenne. Le RGPD [35] et les recommandations du Comité européen [7] servent de référence, à condition de ne pas les confondre avec la loi camerounaise.

Les normes. L'ISO/IEC 29100 [23] pour le vocabulaire, l'ISO/IEC 27701 [24] pour le système de management, l'ISO/IEC 29134 [22] pour l'évaluation d'impact, l'ISO 19011 [14] pour la conduite de l'audit.

La méthode PIA de la CNIL. [9] La plus accessible des méthodes d'évaluation d'impact ; ses échelles sont reprises au Chapitre 10.

La vie privée. D. J. Solove [40] et H. Nissenbaum [33], pour comprendre ce que la protection des données protège.

La recherche de l'auteur. « Vers l'auditologie » [28] et l'instrument trichotomique [27] ; le manuscrit en préparation sur la chaîne pénale [29].

© *MaletYon*

F

CONTACTS ET RESSOURCES

Au Cameroun

Organisme	Rôle pour le cours
Autorité de protection des données à caractère personnel	Autorisations, plaintes, référentiel, liste des pays (art. 53) ; organisation renvoyée à un décret
Agence nationale des technologies de l'information et de la communication (ANTIC)	Sécurité des systèmes d'information ; agents habilités au titre de la loi n° 2010/012
Agence de régulation des télécommunications (ART)	Obligations des opérateurs ; identification des abonnés (Chapitre 18)
Commission bancaire de l'Afrique centrale (COBAC) et Banque des États de l'Afrique centrale (BEAC)	Régulation des banques, des microfinances et des services de paiement ; autorisations de l'article 48(2)
Autres régulateurs sectoriels	Textes particuliers annoncés par l'article 72 (santé, justice, état civil)
Juridictions	Référé et réparation (art. 62) ; poursuites pénales

© *MaletYon*

Autorités des pays où vont les données des trois missions

Pays	Autorité de protection des données
Côte d'Ivoire	Autorité de régulation des télécommunications (ARTCI)
Maroc	Commission nationale de contrôle de la protection des données à caractère personnel (CNDP)
France	Commission nationale de l'informatique et des libertés (CNIL)
Belgique	Autorité de protection des données (APD)
Union européenne	Comité européen de la protection des données, qui réunit les autorités nationales

L'auditeur consulte le site de l'autorité du pays de destination pour dresser la fiche pays du Chapitre 3 et note la date de sa consultation.

Ressources internationales

Ressource	Adresse
Méthode et logiciel PIA (CNIL)	`https://www.cnil.fr/`
Comité européen de la protection des données	`https://www.edpb.europa.eu/`
Union africaine, traités	`https://au.int/`
Base de traqueurs Exodus Privacy	`https://exodus-privacy.eu.org/`

Le cours

Dépôt du cours : `https://github.com/MaletYon/cours-apdc`. NDAP SUKULU en ligne : `https://maletyon.github.io/cours-apdc/ndap-sukulu/`. Compte de démonstration : matricule `ETU001`, mot de passe `eTU001`. Contact : maletyon@proton.me.

G

LES QUARANTE-SIX EXIGENCES DE LA MISSION NYANGA

Cette annexe réunit les exigences cotées par KORO AUDIT à NYANGA CRÉDIT du 24 juin au 25 septembre 2026. Elle permet de refaire chaque calcul du livre : 8 + 10 + 8 + 8 + 8 + 4 = 46 exigences, 8 OUI, 28 NON, 10 NEK. La dernière colonne donne la nature de chaque NEK : de *preuve* quand une pièce manque, de *critère* quand c'est le texte ou la référence qui manque.

D1. Recensement et fondements (Chapitre 8)

N°	Exigence	Cote	Preuve, nature du NEK
1	Les familles de données sont recensées	OUI	Inventaire du 7 juillet
2	Un registre des activités de traitement est tenu	NON	Aucun registre
3	Chaque traitement a un fondement valable	NON	Formulaires, cahiers
4	L'autorisation de l'Autorité est demandée	NON	Attestation
5	Une durée de conservation est fixée	NON	Aucune règle
6	L'information de l'article 21 est fournie	NON	Formulaire 2016
7	L'identification des clients repose sur une obligation légale	NEK	Texte non produit. *Critère*
8	La vidéosurveillance repose sur un fondement valable	NEK	Fondement incertain. *Critère*

© *MaletYon*

D2. Droits des personnes (Chapitre 11)

N°	Exigence	Cote	Preuve, nature du NEK
9	Les personnes sont informées de leurs droits	NON	Formulaire 2016
10	Une procédure de traitement des demandes existe	NON	Aucune
11	Un registre des demandes est tenu	NON	Reconstitué par l'audit
12	Les demandes d'accès reçoivent une réponse	NON	12 sur 31
13	Les réponses respectent le critère de 30 jours	NON	8 sur 12
14	Les oppositions sont exécutées dans les systèmes	NON	3 numéros encore appelés
15	La portabilité est possible	NON	Refus du 14 août
16	L'identité est vérifiée de façon proportionnée	NEK	Pratiques non documentées. *Preuve*
17	Les effacements acceptés sont exécutés	NEK	Sauvegardes non examinées. *Preuve*
18	La procédure de succession respecte l'article 45	OUI	Note de 2025, 3 dossiers

D3. Sécurité et confidentialité (Chapitre 12)

N°	Exigence	Cote	Preuve, nature du NEK
19	L'équipement à l'origine de l'incident est remplacé et tenu à jour	OUI	Bon de livraison, état des correctifs
20	Un inventaire des équipements est tenu	OUI	Inventaire de mars 2026
21	Les journaux sont centralisés et conservés	OUI	Console, treize mois en ligne
22	Les sauvegardes sont restaurables	OUI	Test du 3 septembre
23	Chaque agent n'accède qu'aux clients de son agence	NON	Test sur six comptes
24	Les relevés sont transmis par un canal maîtrisé	NON	Messagerie personnelle
25	Les habilitations sont revues	NON	Aucune revue depuis 2023
26	Les mesures suivent le référentiel de l'Autorité (art. 24)	NEK	Référentiel non publié. *Critère*

D4. Sous-traitants et transferts (Chapitre 13)

N°	Exigence	Cote	Preuve, nature du NEK
27	Chaque sous-traitant est lié par un contrat	OUI	Trois contrats
28	Les contrats définissent données et personnes (art. 30(3))	NON	SOREC, opérateur
29	Les contrats contiennent les douze clauses	NON	Un sur trois au mieux
30	Le droit d'audit est prévu	NON	Aucun contrat
31	SOREC détruit les données des dossiers clos	NON	Classeurs conservés
32	L'éditeur applique les mesures de sécurité convenues	NEK	Ni audit ni rapport. *Preuve*
33	L'opérateur de SMS limite l'usage des numéros	NEK	Aucune pièce. *Preuve*
34	La convention avec SAWA ASSURANCES est publique	NON	Inexistante

D5. Violations (Chapitre 15)

N°	Exigence	Cote	Preuve, nature du NEK
35	Une procédure de gestion des violations existe	NON	Aucune
36	Un registre des violations est tenu	NON	Aucun
37	La violation de 2025 est qualifiée pour les personnes	NON	Rapport technique seul
38	La demande de différer est écrite et motivée	OUI	Lettre du 20 mars 2025
39	La demande a été réexaminée	NON	Aucune démarche
40	Les personnes ont été informées quand la raison a cessé	NON	Rien au 31 août 2026
41	L'Autorité a été informée	NEK	Autorité non organisée. *Critère*
42	L'obligation d'informer s'appliquait en mars 2025	NEK	Question de droit non tranchée. *Critère*

D6. Gouvernance (Chapitre 16)

N°	Exigence	Cote	Preuve, nature du NEK
43	Le risque de chaque traitement est évalué (art. 25)	NON	Aucune évaluation
44	Une évaluation d'impact précède les traitements à risque élevé (art. 33)	NON	Douze traitements, aucune
45	Un dossier de conformité peut être présenté au contrôle (art. 35)	NON	Aucun dossier
46	Le rapport annuel sur les mesures est adressé à l'Autorité (art. 27(2))	NEK	Autorité non organisée. *Critère*

Récapitulation

Code	Domaine	oui	non	nek	de preuve	de critère
D1	Recensement et fondements	1	5	2	0	2
D2	Droits des personnes	1	7	2	2	0
D3	Sécurité et confidentialité	4	3	1	0	1
D4	Sous-traitants et transferts	1	5	2	2	0
D5	Violations	1	5	2	0	2
D6	Gouvernance	0	3	1	0	1
Total		8	28	10	4	6

Les quatre NEK de preuve se lèvent par le travail de l'auditeur ou de l'établissement : une procédure écrite, l'examen des sauvegardes, un audit des deux prestataires. Les six NEK de critère ne dépendent ni de l'un ni de l'autre. Ils attendent un texte d'application, l'organisation de l'Autorité ou une décision de justice (Chapitre 19). Le transfert vers Abidjan n'entre pas dans ce décompte : le Chapitre 16 dit pourquoi et le cote à part.

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] *Acte additionnel A/SA.1/01/10 relatif à la protection des données à caractère personnel dans l'espace de la CEDEAO*, 16 fév. 2010.

[2] S. Brooks, M. Garcia, N. Lefkovitz, S. Lightman et E. Nadeau, « An Introduction to Privacy Engineering and Risk Management in Federal Systems, » NIST, rapp. tech. NISTIR 8062, 2017.

[3] E. Casey, *Digital Evidence and Computer Crime*. Academic Press, 2004.

[4] CEMAC, *Directive n° 07/08-UEAC-133-CM-18 fixant le cadre juridique de la protection des droits des utilisateurs de réseaux et de services de communications électroniques au sein de la CEMAC*, Bangui, 19 décembre 2008, 2008.

[5] P. Cichonski, T. Millar, T. Grance et K. Scarfone, « Computer Security Incident Handling Guide, » National Institute of Standards et Technology, NIST Special Publication 800-61 Rev. 2, 2012.

[6] Comité européen de la protection des données, *Lignes directrices 3/2018 relatives au champ d'application territorial du RGPD (article 3)*, 2019.

[7] Comité européen de la protection des données, *Recommandations 01/2020 sur les mesures qui complètent les instruments de transfert destinés à garantir le respect du niveau de protection des données à caractère personnel de l'UE*, CEPD, 2021.

[8] Commission européenne, *Décision d'exécution (UE) 2021/914 relative aux clauses contractuelles types pour le transfert de données à caractère personnel vers des pays tiers*, 2021.

[9] Commission nationale de l'informatique et des libertés, *Analyse d'impact relative à la protection des données (PIA) : la méthode*, CNIL, Paris, 2018.

[10] Conseil de l'Europe, *Convention pour la protection des personnes à l'égard du traitement automatisé des données à caractère personnel*, STE n° 108, Strasbourg, 28 janvier 1981, 1981.

[11] Conseil de l'Europe, *Convention sur la cybercriminalité (Convention de Budapest, STE n° 185)*, Conseil de l'Europe, Budapest, 2001.

[12] Conseil de l'Europe, *Protocole d'amendement à la Convention pour la protection des personnes à l'égard du traitement automatisé des données à caractère personnel*, STCE n° 223, dite Convention 108+, 2018.

[13] *Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel*, Adoptée à Malabo, entrée en vigueur le 8 juin 2023 ; signée par le Cameroun le 12 août 2021, non ratifiée selon Minka Mi Nguidjoï, Massoussi Songo et Bialo (2026), 27 juin 2014.

[14] ISO, *ISO 19011:2018 – Lignes directrices pour l'audit des systèmes de management*, Genève : ISO, 2018.

[15] ISO, *ISO 31000:2018 – Management du risque – Lignes directrices*, Genève : ISO, 2018.

[16] ISO/IEC, *ISO/IEC 27018:2019 – Code of practice for protection of personally identifiable information in public clouds acting as PII processors*, Genève : ISO, 2019.

[17] ISO/IEC, *ISO/IEC 27007 – Information security, cybersecurity and privacy protection – Guidelines for information security management systems auditing*, Genève : ISO, 2020.

[18] ISO/IEC, *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*, Genève : ISO, 2022.

[19] ISO/IEC, *ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls*, Genève : ISO, 2022.

[20] ISO/IEC, *ISO/IEC 27557:2022, Sécurité de l'information, cybersécurité et protection de la vie privée. Application de l'ISO 31000:2018 pour le management des risques organisationnels liés à la vie privée*, 2022.

[21] ISO/IEC, *ISO/IEC 27035 · Information technology · Information security incident management*, International Organization for Standardization, Genève, 2023.

[22] ISO/IEC, *ISO/IEC 29134 – Information technology – Security techniques – Guidelines for privacy impact assessment*, Genève : ISO, 2023.

[23] ISO/IEC, *ISO/IEC 29100 – Information technology – Security techniques – Privacy framework*, Genève : ISO, 2024.

[24] ISO/IEC, *ISO/IEC 27701 – Privacy information management systems – Requirements and guidance*, Genève : ISO, 2025.

[25] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun*, 21 déc. 2010.

[26] *Loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel au Cameroun*, Copie certifiée conforme, Secrétariat général de la Présidence de la République, 23 déc. 2024.

[27] T. E. Minka Mi Nguidjoï. « Modelling epistemic uncertainty in information systems audit: A trichotomous response instrument and its information-theoretic properties. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701270. (22 juill. 2026), adresse : https://hal.science/hal-05701270.

[28] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. (22 juill. 2026), adresse : https://hal.science/hal-05701007.

[29] T. E. Minka Mi Nguidjoï, R. T. Massoussi Songo et D. Bialo, « Protection des données personnelles et chaîne pénale au Cameroun : analyse des zones de tension normative autour de la Loi n°2024/017, » Manuscrit en préparation, septembre 2026, 2026.

[30] National Institute of Standards and Technology, « NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0, » NIST, rapp. tech., 2020.

[31] National Institute of Standards and Technology, « Artificial Intelligence Risk Management Framework (AI RMF 1.0), » NIST, rapp. tech. NIST AI 100-1, 2023.

[32] Nations Unies, *Principes directeurs pour la réglementation des fichiers informatisés contenant des données à caractère personnel*, Résolution 45/95 de l'Assemblée générale, 14 décembre 1990, 1990.

[33] H. Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*. Stanford : Stanford University Press, 2010.

[34] OCDE, *Lignes directrices régissant la protection de la vie privée et les flux transfrontières de données de caractère personnel*, Organisation de coopération et de développement économiques, Révisées en 2013, 1980.

[35] *Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel et à la libre circulation de ces données (règlement général sur la protection des données)*, 27 avr. 2016.

[36] République de Côte d'Ivoire, *Loi n° 2013-450 du 19 juin 2013 relative à la protection des données à caractère personnel*, 2013.

[37] République du Cameroun, *Décret n° 2012/1643/PM du 14 juin 2012 fixant les conditions et les modalités d'audit de sécurité obligatoire des réseaux de communications électroniques et des systèmes d'information*, 2012.

[38] Royaume du Maroc, *Loi n° 09-08 relative à la protection des personnes physiques à l'égard du traitement des données à caractère personnel*, Dahir n° 1-09-15 du 18 février 2009, Bulletin officiel n° 5714 du 5 mars 2009, 2009.

[39] C. E. Shannon, « A Mathematical Theory of Communication, » *Bell System Technical Journal*, t. 27, n° 3, p. 379-423, 1948.

[40] D. J. Solove, *Understanding Privacy*. Cambridge (MA) : Harvard University Press, 2008.

[41] Union africaine, *Cadre stratégique de l'Union africaine en matière de données*, 2022.

[42] Union africaine, *Stratégie continentale sur l'intelligence artificielle*, Approuvée par le Conseil exécutif, Accra, juillet 2024, 2024.

[43] Union européenne, *Règlement (UE) 2024/1689 du Parlement européen et du Conseil du 13 juin 2024 établissant des règles harmonisées concernant l'intelligence artificielle*, Journal officiel de l'Union européenne, 12 juillet 2024, 2024.

INDEX

Anonymisation, 16

carte d'applicabilité, 91
cartographie des flux, 112
clauses contractuelles types, 155
Consentement, 27
constatations, 4
Cote OUI, NON, NEK, 7
critère de substitution, 55

Destinataire, 19
directement, 16
domaines, 103
Donnée à caractère personnel, 4
découverte des données, 112

Entropie, 104
exigences, 103

Fichier, 18
finalité, 18

indirectement, 16
interconnexion des fichiers, 112

niveaux, 64
noyau, 63

papier de travail, 103
Personne concernée, 19
processus, 111
profil, 63
Profilage, 182
Pseudonymisation, 16

responsabilité, 51
Responsable du traitement, 19
responsables conjoints, 19

Sous-traitant, 19

Taux d'incertitude, 104
Taux de conformité, 104
Traitement, 4, 18
Transfert international de données, 154

Violation de données à caractère personnel, 162

Évaluation d'impact sur la protection des données, 118

À propos de ce cours

Depuis le 23 juin 2026, les organisations camerounaises doivent appliquer la loi n° 2024/017 relative à la protection des données à caractère personnel. Dire qu'elles le font demande une preuve. Ce cours apprend à la chercher : recenser les traitements, apprécier le risque pour les personnes, vérifier les droits, la sécurité, les sous-traitants et les transferts, puis conclure en disant ce que l'on sait et ce que l'on ignore.

Il progresse en sept parties, précédées d'un prologue : les fondements, le contexte international (RGPD, NIST, normes ISO), le contexte national (lois de 2024 et de 2010), la méthode d'audit, la pratique, les défis avancés et la recherche sur la mesure de la conformité.

Il s'adresse aux étudiants du Master Professionnel en Sécurité des Systèmes Numériques et aux professionnels qui exercent comme auditeurs de la protection des données, délégués à la protection des données, juristes conformité, RSSI ou responsables de traitement.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information